This CIS Certified Policy is based on the CIS benchmark for Microsoft Windows Server 2012 R2, V2.2.0. This Policy contains all 'Level 1 and Level 2 Scored' types of checks from the benchmark which are of Profile - Member Server. The controls within the policy are configured on the basis of values specified by CIS. As this policy and the controls within the policy are CIS certified, the policy is LOCKED for prohibiting any changes to the controls or their configuration values. If the organizational security policy requires different configuration values, or changes to the policy, please create a copy of this policy to make the changes.

To successfully configure a Windows system to remotely scan/return results for all CIS requirements for this OS/version, the following must be done:

A. There must be 'Inbound' rules set on the network interface used by the Qualys scan via the 'Local Group Policy, Windows Firewall with Advanced Security on the Local Computer, Inbound Security Rules' configuration interface for a scan to succeed, as the OS blocks all other port openings by default once that specific network interface (Public, Private, or Domain) is set to 'Block':
1) TCP/UDP inbound ports--135,137,445,389 (Qualys port scan)
2) UDP inbound ports--135,137,445,389 (Qualys port scan),and
3) Remote Desktop--3389 (a predefined setting for RDP connections).
WARNING: This requirement may vary/be unnecessary depending on the Customers' requirements for specific ports used by the Customers 'remote management software, but the 'Built-in Administrative User' CAN BE LOCKED OUT of remote access if appropriate system management ports are not left open.

B. The requirement for opening the RDP port may vary depending on the Users' requirements for open ports in use by their 'remote management software,' rendering the RDP port unnecessary. HOWEVER, the 'Built-in Administrative User' required for scanning CAN BE BLOCKED if appropriate ports are not left open, resulting in empty Reports, necessitating rescans.

CIS has stated that these settings should be considered as minimum allowable values; if an Organization requires more stringency than the CIS minimum, these more restrictive and/or stringent values shall all be considered as a PASS. Before you apply the recommendations from the policy, check the relevant vendor documentation to avoid discrepancies. Also, it is recommended that these values be tested before applying to the Production Environment.

QUALYS EXPRESS

HomeRemit-test-10.111.100.118

March 21, 2017

Report Summary	
Created:	03/21/2017 at 17:14:46 (GMT+0500)
Company:	JS Bank
Address:	1st Floor, Shaheen Complex I. I. Chundrigar Road
City:	Karachi
State:	None
Zip:	75500
Country:	Pakistan
User Name:	Salman Shafiq
Login Name:	sbank-ss
User Role:	Manager

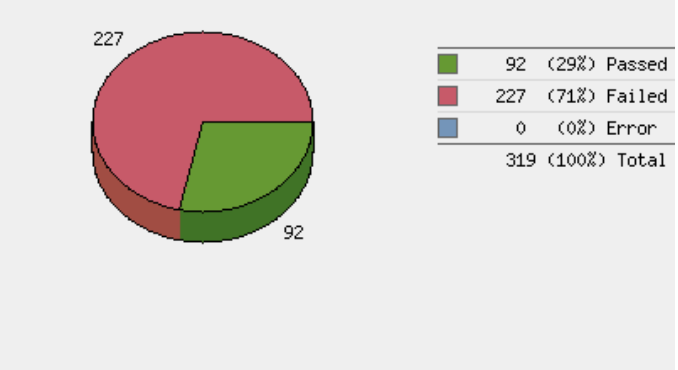
Report Summary

CENTER FOR INTERNET SECURITY

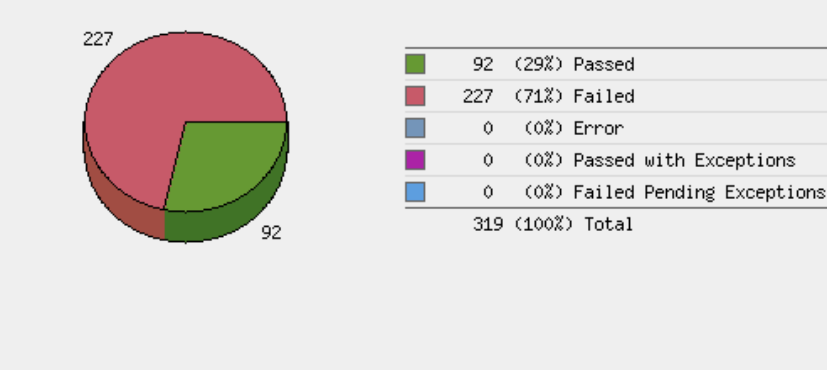
Policy:	CIS Benchmark for Microsoft Windows Server 2012 R2, v2.2.0, [Scored, Member Server, Level 1 + Level 2] v.4.0-HomeRemit-test
Policy Locking:	Locked - CIS Certified Policy
Template:	Policy Report Template
Asset Groups:	
Ips:	10.111.200.118
Asset Tags:	N/A
Active Hosts:	1
Controls:	319
Technologies:	1 (Windows Server 2012 R2)
Total Control Instances:	319
Total Passed:	92 (28.84%)
Total Failed:	227 (71.16%)
Total Error:	0
Approved Exceptions:	0
Pending Exceptions:	0
Policy Modified:	03/21/2017 at 16:56:21 (GMT+0500)
Policy Last Evaluated:	03/21/2017 at 17:09:10 (GMT+0500)

The following pie charts display the number of control instances and their states at the time this report was generated.

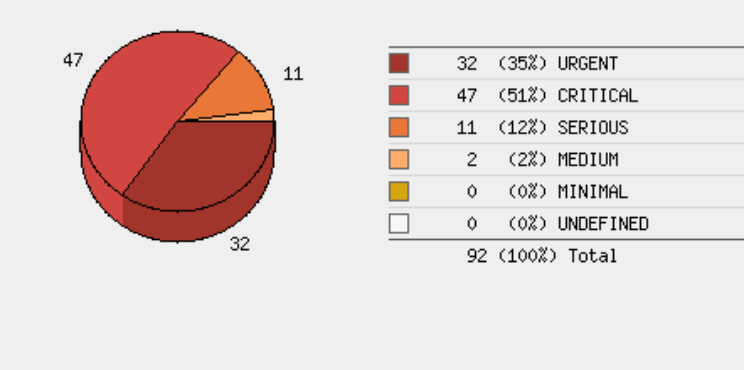
Pass/Fail/Error Summary



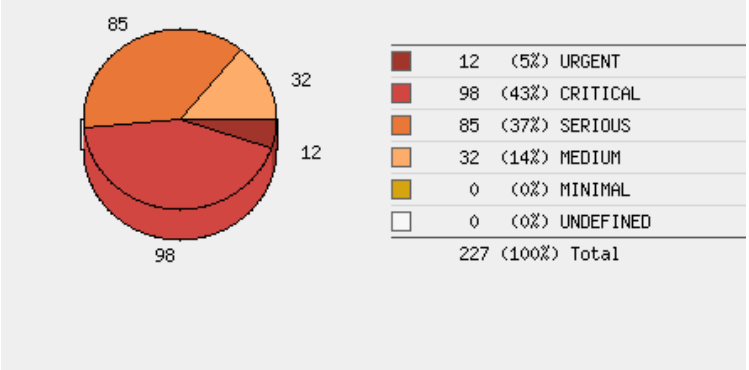
Pass/Fail/Error and Exceptions Summary



Pass Criticality Summary



Fail Criticality Summary



Host Statistics (Percentage of Controls Passed per Host)

IP	TRACKING	DNS Name	Netbios Name	OS	Last Scan Date	%
10.111.200.118	IP	s-hrt-p786-rm1.jsbl.com	S-HRT-P786-RM1	Windows Server 2012 R2 Standard 64 bit Edition	03/21/2017 at 17:02:53 (GMT+0500)	28.84% (92 of 319)

Detailed Results

10.111.200.118 (s-hrt-p786-rm1.jsbl.com, S-HRT-P786-RM1) — Windows Server 2012 R2 Standard 64 bit Edition

Controls:	319
Passed:	92 (28.84%)
Failed:	227 (71.16%)
Error:	0
Approved Exceptions:	0
Pending Exceptions:	0
Last Scan Date:	03/21/2017 at 17:02:53 (GMT+0500)
Tracking Method:	IP

Asset Tags:
Windows 2012 Test

Windows Server 2012 R2

1. Account Policies

(1.1) 1318 Status of the 'Enforce password history' setting — **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Among the characteristics that make 'user identification' via password a secure and workable solution is the 'password history' setting. By requiring that a series of password-choices be unique, not a repetition of something used recently, it reduces the risk of a malicious user breaking the password through dictionary/brute force attacks or fortuitous guessing based upon 'social engineering,' where a user has mentioned that one of his favorite password-creation strategies is such-and-such. With this password history requirement, users who wish to re-use the same password must select new and unique ones for a certain time period, before returning to their 'preferred' one. Each time a new password is chosen, it adds to the security value of using a password as a security tool--while no specific 'password history' can guarantee password security, twelve (12) is generally considered to be an adequate number. This, along with requiring other password security factors, such as increasing the variability of the symbol set-space by requiring mixed-cases, as well as other tactics, such as requiring a new password to be chosen every 45-90 days, further increases the difficulty of breaking any password by brute-force and social-engineering attacks.

This Integer value X indicates the current status of the Enforce Password History Within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Enforce password historysetting for the local accounts, which indicates the number of unique password entries that are required before one can be repeated.

Expected	**greater than or equal to**
	24
	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	5

(1.2) 3376 Status of the 'Maximum Password Age' setting (expiration) — **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

One characteristic that makes 'user identification' via password a secure/workable solution is setting a 'password expiration' requirement. Each time a new password is created, replacing one that has been in place for a given period of time, this resets the difficulty of breaking a password via brute-force to its maximum level; it can also help ensure that a compromised 'hack' account with a password that has expired is then closed. While no 'secure maximum' for limiting the use of a password has been agreed upon, ninety (90) days is generally considered to be the maximum allowed for most enterprise environments. However, this tactic should be used along with other password security factors, such increasing the complexity the password set-space by requiring mixed-cases and/or special characters, to further increase the difficulty of breaking any password by brute-force attacks.

This Integer value X indicates the current status of the Maximum Password Age Within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Maximum password agesetting for local accounts.

Expected	**in range**
	1-60
	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	30

(1.3) 1072 Status of the 'Minimum Password Age' setting **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Among the characteristics that make 'user identification' via password a workable security solution is setting a 'minimum password age.' Without this minimum age requirement, any user(s) who wish to re-use the same password can merely cycle through a number of previously used passwords until returning to the preferred one (this is determined by the 'Password History' setting). While no specific 'minimum password age' can guarantee password security, one (1) day is generally considered to be the shortest length of time permissible, along with requiring other password security factors, such as increasing the variability of the symbol set-space by requiring mixed-cases, special characters, further increases the difficulty of breaking any password using brute-force methods. Consider implementing this control for all account passwords in conjunction with CID 1318 (Password History) and CID 1071 (Minimum Password Length) and CID 1073 (Maximum Password Age).

The following Integer value X indicates the current status of the 'Minimum Password Age' (min_pass_age) within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Minimum password agesetting for local accounts.

Expected	**greater than or equal to**
	1
	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	0

(1.4) 1071 Status of the 'Minimum Password Length' setting **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Among the several characteristics that make 'user identification' via password a secure and workable solution is setting a 'minimum password length' requirement. Each character that is added to the password length squares the difficulty of breaking the password via 'brute force,' which attempts using every combination possible within the password symbol set-space, in order to discover a user's password. While no 'minimum length' can be guaranteed secure, eight (8) is commonly considered to be the minimum for most application access, along with requiring other password security factors, such as increasing the size of the symbol set-space by requiring mixed-cases, along with other forms of password variability creation, increases the difficulty of breaking any password by brute-force attack.

The following Integer value X indicates the current status of the Minimum Password Length (min_pass_len) setting for local accounts.

Expected	**greater than or equal to**
	14
	OR, any of the selected values below:
	☐ Attribute not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	8

(1.5) 1092 Status of the 'Password Complexity Requirements' setting **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Among the several characteristics that make 'user identification' via password a secure and workable solution is setting the 'password complexity' requirement. This makes the selection of mixed-case, numerical, and 'punctuation' symbols mandatory during password creation. This exponentially increases the size of the 'symbol-set' that must be addressed

when conducting a brute-force attack. For example, it makes the number of combinations that must be checked to match the correct combination for an eight-character password potentially '8!' or '8 factorial' to the 92nd power, which is up in the 'googol' range of combinations. When coupled with other measures for password security, such as maximum- and minimum-use duration, system lockout after a specified number of invalid attempts, and password-history requirements, 'password complexity' should only permit credentials to be compromised via blind luck, social engineering, or secretly installed keystroke-logging software on the system.

This Integer value X indicates the current status of the Password Complexity Requirements within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Password Policy\Password must meet complexity requirements setting for local accounts.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

(1.6) 2484 Status of the 'Store passwords using reversible encryption' setting **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Microsoft's 'Store passwords using reversible encryption' setting, the original LANMAN encryption scheme, is very vulnerable to cracking, due to its 'standard': It treats all characters as uppercase and truncates anything longer than 14 characters, while padding all shorter passwords up to 14 characters in length with the same padding characters. As using reversible encryption can allow a malicious user to crack the password fairly easily with tools available online, risking the compromise of any credentials copied from the server/workstation or 'sniffed' off the wire by a malicious user, the use of reversible encryption should be disabled/restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the Store passwords using reversible encryption setting for local accounts. A value of 0 indicates the setting is disabled; a value of 16 indicates the setting is enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ 1
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

(1.7) 2341 Status of the 'Account Lockout Duration' setting (invalid login attempts) **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Account Lockout Duration' setting determines the amount of time an account will be locked upon reaching the maximum number of login attempts allowed by the 'Account Lockout Threshold' setting. A user's password can be guessed or broken via repeated attempts to login by using a logical or known account name and changing the password until successful login occurs. If this is set to '0', the account will be locked until an Administrator or the system unlocks it. This policy setting only has meaning when the 'Account Lockout Threshold' setting is specified. In addition, the 'Account Lockout Duration' setting must be set to a value equal to or greater than that which is configured in the 'Reset Account Lockout Counter After' setting. If not, the 'Reset Account Lockout Counter After' settings will not increment any invalid attempts during the time in which the account has been re-enabled and when the counter is reset. Consider implementing this control in conjunction with CID 2342 and CID 2423.

The following Integer value X indicates the current status of the Account Lockout Duration (for invalid attempts)Withi the Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout durationsetting for local accounts.

Expected	**greater than or equal to**
	15

	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	30

(1.8) 2342 Status of the 'Account Lockout Threshold' setting (invalid login attempts) **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Account Lockout Threshold' parameter determines the number of invalid login attempts allowed before an account will be 'locked.' The 'Account Lockout Duration' parameter must be set to a value equal to or greater than that which is configured in the 'Reset Account Lockout Counter After' setting. If it is not set, the 'Reset Account Lockout Counter After' setting will not increment any invalid login attempts during the time in which the account has been re-enabled and when the counter is reset. As user passwords can be guessed or broken via repeated attempts to login by using a logical or known account name and launching a brute-force attack on the password until successful login occurs, this value should be set as appropriate to the needs of the business. NOTE: Consider implementing this control in conjunction with CID 2341 and CID 2343.

This Integer value X indicates the current status of the Account Lockout Threshold Within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Account lockout threshold setting for local accounts.

Expected	**in range**
	1-10
	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	3

(1.9) 2343 Status of the 'Reset Account Lockout Counter After' setting **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Reset Account Lockout Counter After' setting determines the minimum amount of time that must elapse before an account that has been locked, due to invalid logon attempts, will have its counter reset to zero. If the 'Account Lockout Threshold' setting is not enabled, the 'Account Lockout Counter After' parameter has no effect on the security of the accounts. In addition, the 'Account Lockout Duration' setting must be set to a value equal to or greater than that which is configured in 'Reset Account Lockout Counter After' setting. If not, the 'Reset Account Lockout Counter After' settings will not increment any invalid logon attempts during the time in which the account has been re-enabled and when the counter is reset. As having this parameter set appropriately makes it more difficult for a malicious user to break passwords, when implemented in conjunction with the 'Account Lockout Threshold' setting, this value should be set as appropriate to the needs of the business. NOTE: Consider implementing this control in conjunction with CID 2342 and CID 2343.

This Integer value X indicates the current status of the Reset account lockout counter after (in minutes) within the Computer Configuration\Windows Settings\Security Settings\Account Policies\Account Lockout Policy\Reset account lockout counter after setting for local accounts

Expected	**greater than or equal to**
	15
	OR, any of the selected values below:
	☐ Attribute not found
	☐ Unable to retrieve password policy
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	30

2. Local Policies

(2.1) 3924 Current list of Groups and User accounts granted the 'Access credential Manager as a trusted caller (SeTrustedCredManAccessPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Access credential Manager as a trusted caller (SeTrustedCredManAccessPrivilege)' setting permits a process to read any object/property in any directory, no matter what privileges are assigned. As this permission could allow the compromise of all system's information, this capability should be restricted according to the needs of the business. NOTE: A Domain Controller does require this capability.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Local Policies\User Rights Assignment\Access credential Manager as a trusted caller right.

Expected	**does not contain regular expression list**
	[A-Za-z0-9]
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.2) 2181 Current list of Groups and User Accounts granted the 'Access this computer from the network' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Access this computer from the network' right allows a User to interact with remote Windows systems. By Windows default, all user/computer accounts are granted this right when the 'Everyone' group is included during initial configuration; however, depending on the mix of folder/file permissions on the networked systems, certain files and/or other confidential information resources, such as print queues, may be inappropriately accessible. (This is especially true if the domain still retains NT4 RRAS servers, which allow anonymous network login--these Users can potentially access file servers with non-NTFS file systems, which only enforce folder-level access.) As the Manufacturer stipulates that the 'Everyone' group could be removed and the 'Authenticated Users' group substituted in its place (MS-KB 823659), this right should be limited as appropriate to the needs of the business. CAUTION: If the 'Everyone' group is being removed, the 'Authenticated Users' group must be added to this User Right BEFORE doing the update that changes this setting, or ALL systems shall be blocked from accessing remote hosts.

The following List String value(s) X indicate the current User Accounts defined within the Access this computer from the network policy.

Expected	**is contained in regular expression list**
	Administrators
	Authenticated Users
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Backup Operators
	BUILTIN\Users
	\Everyone

(2.3) 2182 Current list of Groups and User Accounts granted the 'Act as part of the operating system' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Act as part of the operating system' privilege allows a process to impersonate/gain access to the same local resources as the 'user' being impersonated, but without requiring authentication. (The Manufacturer recommends that any process that needs this privilege should work through the 'LocalSystem' account, not a separate/special user account.) If all servers are connecting to, or members of, the Win-2003 product line, this privilege is not required. As the use of Win-2000 or Win-NT 4.0 servers may be require that this privilege be used for applications that exchange clear-text passwords, this right should be limited as appropriate to the needs of the business. NOTE: There are further risks in this privilege in that potential access is not limited by what the user account is associated to by default; the calling process can request arbitrary, OS-level privileges and add these to the access token.

The following List String value(s) X indicate the current inventory of users assigned the user right to Act as part of the Operating System.

Expected	**does not contain regular expression list**
	[A-Za-z0-9]

	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.4) 2184 Current list of Groups and User Accounts granted the 'Adjust memory quotas for a process' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Adjust memory quotas for a process' would allow an application, process, service, or user to increase the processor power assigned to a specific process' execution, thus preempting other jobs in the processor queue. (In the default installation, this right is given only to 'Administrators,' 'Local Service,' and 'Network Service.' As this privilege could easily be misused to create a DoS condition, this right should be limited as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Adjust memory quotas for a process (SeIncreaseQuotaPrivilege) right.

Expected	**is contained in regular expression list**
	Administrators
	LOCAL SERVICE
	NETWORK SERVICE
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	IIS APPPOOL\.NET v2.0
	IIS APPPOOL\.NET v2.0 Classic
	IIS APPPOOL\.NET v4.5
	IIS APPPOOL\.NET v4.5 Classic
	IIS APPPOOL\Classic .NET AppPool
	IIS APPPOOL\CR
	IIS APPPOOL\DefaultAppPool
	IIS APPPOOL\JSBHMREMITSSL
	NT AUTHORITY\LOCAL SERVICE
	NT AUTHORITY\NETWORK SERVICE

(2.5) 2391 Current list of Groups and User Accounts granted the 'Allow log on locally (SeInteractiveLogonRight)' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Log on locally (SeInteractiveLogonRight)' user right allows a User to 'log on locally' via the console/keyboard. (In the default configuration for member servers/workstations, this right is given to Administrators, Power Users, Users, Guest, and Backup Operators; for DCs this is given to Account Operators, Administrators, Backup Operators, Print Operators, and Server Operators.) If certain Users are to be restricted from local logon, they must also be restricted from connecting via a remote desktop or terminal services session via the Remote Desktop Protocol (RDP). As unrestricted logon capability to a server could potentially allow a malicious user to attempt a brute-force attack, this capability should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Allow log on locally(SeInteractiveLogonRight) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Backup Operators
	BUILTIN\Users

(2.6) 2185 Current list of Groups and User Accounts granted the 'Allow logon through Terminal Services' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Allow logon through Terminal Services' right allows user logon via a Remote Desktop Protocol (RDP) connection. (In the default installation, this is limited to Administrators and Remote Desktop Users.) Any Group or User Account granted this user right is permitted to logon via Remote Desktop Protocol. As the ability to logon via Terminal Services can allow a malicious user to initiate a Denial of Service attack, Groups and User Accounts granted the 'Allow logon through Terminal Services' right should be restricted as appropriate to the needs of the business. NOTE: As the initial versions of RDP for Windows XP use weak encryption protocols, these versions should be patched to improve security.

The following List String value(s) X indicate the current Groups and Users granted the Allow logon through Terminal Services user right.

Expected	**is contained in regular expression list**
	Administrators
	Remote Desktop Users
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Remote Desktop Users

(2.7) 2186 Current list of Groups and User Accounts granted the 'Back up files and directories' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Back up files and directories' right allows the user to perform backups by circumventing file and directory permissions. (In the default installation, this right is granted to Administrators and Backup Operators.) As this right could be used to traverse and read attributes for all files and directories, Groups and User Accounts granted the 'Backup files and directories' right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Backup files and directories (SeBackupPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Backup Operators

(2.8) 2191 Current list of Groups and User Accounts granted the 'Change the system time' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Change the system time' user right allows users to alter the date/time on the system's internal clock. (The default configuration grants this right to Administrators and Power Users.) As this right would allow changes in the recording of times in the audit trail as stored by the Event Log, as well as being of critical importance for Kerberos authentication, Groups and User Accounts granted this right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Change the system time (SeSystemTimePrivilege) right.

Expected	**is contained in regular expression list**
	Administrators
	LOCAL SERVICE
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	NT AUTHORITY\LOCAL SERVICE

(2.9) 3925 Current list of Groups and User accounts granted the 'Change the time zone privilege (SeTimeZonePrivilege)' setting — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Change the time zone privilege (SeTimeZonePrivilege)' will allow the user to change the system's time zone. As this privilege could allow a user to alter the logging parameters times used by the system log or other time time-sensitive functions such as email, making accurate forensic tracking infeasible, it should be restricted according to the needs of the business.

The following List String value(s) X indicate the current list of User Defined Accounts within the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Change the time zone policy.

Expected	**is contained in regular expression list**
	Administrators
	LOCAL SERVICE
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	NT AUTHORITY\LOCAL SERVICE

(2.10) 2192 Current list of Groups and User Accounts granted the 'Create a Pagefile' right — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Create a Pagefile' right allows a user to call the application programming interface (API) that allows creation of a page file to add virtual memory space. (In the default installation, this right is given only to Administrators.) Pagefile alteration can allow a malicious user to slow down a process through lack of paging space. The pagefile may also retain confidential data after system shutdown if the 'Clear virtual memory pagefile' setting (CID-1048) has been disabled. As the Pagefile governs the behavior of the systems' virtual memory space, Groups and User Accounts granted the 'Create a Pagefile' right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Create a PageFile (SeCreatePagefilePrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.11) 2193 Current list of Groups and User Accounts granted the 'Create a Token Object' right — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Create a Token Object' right allows a process to create an [access] token object, which provides a security context for a process/thread. (In the default installation, this right is not assigned to any Groups or User Accounts.) As the 'Create a Token Object' right could be used for unauthorized user privilege escalation, Groups and User Accounts granted this right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Create a Token Object right.

Expected	**does not contain regular expression list**
	[A-Za-z0-9]
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.12) 3242 Current list of Groups and User Accounts granted the 'Create Global Objects' right — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Create Global Objects' user right allows a user to create global objects when connected to a Terminal Services session. All running processes on the system have access to global objects. (In the default installation this right is granted to Administrators, Interactive, and Service.) As the creation of global objects can negatively impact system processes, Groups and User Accounts granted the 'Create Global Objects' right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create global objects right.

Expected	**is contained in regular expression list**
	Administrators
	LOCAL SERVICE
	NETWORK SERVICE
	SERVICE
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	NT AUTHORITY\LOCAL SERVICE
	NT AUTHORITY\NETWORK SERVICE
	NT AUTHORITY\SERVICE

(2.13) 2194 Current list of Groups and User Accounts granted the 'Create Permanent Shared Objects' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Create Permanent Shared Objects' user right is necessary for the creation of 'permanent shared objects' in the name space of Windows' object manager. (A permanent shared object is one that Windows does not destroy after all references to it are deleted--during the default configuration, this right is assigned only to the 'Local System.') The manufacturer has indicated that this privilege shouldn't normally be required for any other user, but may need be needed for special situations, such as for accounts that run services deeply embedded within the OS. As there have been exploits based on permanent object creation for earlier versions of Windows server using 'lopht,' this right should be limited as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Create Permanent Shared Objects (SeCreatePermanentPrivilege) right.

Expected	**does not contain regular expression list**
	[a-z]*\
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.14) 3941 Status of the 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) right **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Create Symbolic Links' (SeCreateSymbolicLinkPrivilege) setting allow user to link and potentially change permissions on files. As this capability can permit a malicious user to exploit security vulnerabilities in an application resource that was not designed to use symbolic links, this should be restricted according to the needs of the business.

The following List String value(s) X indicate the current list of the User Defined Accounts within the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Create symbolic links policy.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.15) 2195 Current list of Groups and User Accounts granted the 'Debug Programs' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Debug Programs' user right allows a user to attach a debugger to any process. (The default configuration assigns this right only to Administrators.) As this right would allow a user to capture critical and/or sensitive data from any operating program, Groups and User Accounts granted the 'Debug Programs' right should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Debug Programs (SeDebugPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.16) 2196 Current list of Groups and User Accounts granted the 'Deny Access to this computer from the network' right **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Deny Access to this computer from the network' user right revokes the right of a User to interact with this Windows system remotely. As this right can lock out both potentially malicious users and those who require system access, it should be configured according to the needs of the business. CAUTION: If the 'Everyone' group is added to this setting, ALL systems will be blocked from accessing this system remotely. Also, as the Qualys scan uses the 'Administrator' login by default to run its checks, one should be very careful about adding the 'ADMINISTRATOR' to this group, as it will block network-based local or 'BUILTIN' 'Administrator' access.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Deny Access to this computer from the network (SeDenyNetworkLogonRight) right.

Expected	**contains regular expression list**
	(Guests|Guest)
	Local Account
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.17) 2197 Current list of Groups and User Accounts granted the 'Deny logon as a batch job' right **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The Current list of Groups and User Accounts granted the 'Deny logon as a batch job' setting determines which accounts are prevented from logging on as a batch job. As the capability to log on by using a batch-queue tool could be exploited by unauthorized users used to schedule jobs that could create a denail-of-service condition, this should be restricted according to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Deny logon as a batch job (SeDenyBatchLogonRight) right.

Expected	**contains regular expression list**
	(Guests|Guest)
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.18) 2198 Current list of Groups and User Accounts granted the 'Deny logon as a service' right **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The Current list of Groups and User Accounts granted the Deny logon as a service setting determines which users and groups are prevented from logging on as a service. As this setting is usually restricted to Administrators and system account, it should be configured according to the needs of the business.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Deny logon as a service (SeDenyServiceLogonRight) right.

Expected	**contains regular expression list**
	(Guests|Guest)
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.19) 2199 Current list of Groups and User Accounts granted the 'Deny log on locally' right **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Deny logon locally' right prohibits a user from logging on directly at the console. (In the default installation for XP, only the 'Guest' account is included in this setting--for servers, only privileged administrative accounts have console logon capability.) As use of a grant of this right could facilitate creation of a number of SYSTEM-level DoS exploits, this right's usage should be set as appropriate to the needs of the business. NOTE: If the 'Everyone' user group is assigned this logon right, all Users will be barred from console logon, so if network access is lost and serial access capability hasn't been added, the only way to access the system is through the Recovery Console.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Computer Configuration\Windows Settings\Local Policies\User Rights: 'Deny log on locally'(SeDenyInteractiveLogonRight) right.

Expected	**contains regular expression list**
	(Guests|Guest)
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.20) 2200 Current list of Groups and User Accounts granted the 'Deny logon through terminal (Remote Desktop) service' right **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Deny logon through terminal service' or 'Deny log on through Remote Desktop Services' user right prohibits a user from logging on using the Remote Desktop Protocol (RDP) to connect to Terminal Services. In the default installation for XP, no accounts are included in this group, but Users other than Administrators must be granted the right to log in with RDP. For servers, only privileged accounts have RDP logon capability and the 'Guest' account is included in this 'Deny' group. (This may differ if the system offers Terminal Server services.) As RDP connections can provide a way to launch exploits against the system, membership in this group should be set appropriate to the needs of the business. NOTE: If the 'Everyone' user group is assigned this logon right, all Users will be barred from RDP-based access to the system, so if network access is lost and serial access capability hasn't been added, the only way to access the system is through the console.

The following List String value(s) X indicate the current Groups and Users Accounts granted the Deny logon through terminal service (SeDenyRemoteInteractiveLogonRight) right.

Expected	**contains regular expression list**
	(Guests|Guest)
	Local account
	OR, any of the selected values below:
	☐ Right not assigned

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	JSBL\DomainJoin

(2.21) 2383 Current list of Groups and User Accounts granted the 'Enable computer and user accounts to be trusted for delegation' right — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Enable computer and user accounts to be trusted for delegation (SeEnableDelegationPrivilege)' privilege is not assigned to any system but a domain controller, as it permits a computer/user to alter the 'Trusted for Delegation' setting for objects in Active Directory (Workstations and Servers that are not functioning as Domain Controllers can also be checked to ensure default values have not been changed in the Local Security Policy). This will allow a front-end service/ process to function with the rights of a given client's credentials when authenticating itself to a back-end process/service. As this user right should be limited to Domain Controller Administrators and can be a powerful method to facilitate system penetration, allowing Trojans to send out under impersonated accounts, this privilege should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current list of Enable computer and user accounts to be trusted for delegation granted theComputer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Enable computer and user accounts to be trusted for delegation(SeEnableDelegationPrivilege) right.

Expected	**does not contain regular expression list**
	[a-z]*\
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.22) 2384 Current list of Groups and User Accounts granted the 'Force shutdown from a remote system' right — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Force shutdown from a remote system (SeRemoteShutdownPrivilege)' User Right allows the system to be shutdown remotely. In the default configuration this right is assigned only to Administrators on workstations/member servers and to Administrators and Server Operators on Domain Controllers. As this right can create a denial-of-service condition, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Local Policies\User Rights Assignment\Force shutdown from a remote system(SeRemoteShutdownPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.23) 2385 Current list of Groups and User Accounts granted the 'Generate Security Audits' right — Failed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Generate Security Audits' (SeAuditPrivilege) User Right permits the generation of security log records. (In the default configuration it is assigned to the Local Service and Network Service on workstations and domain controllers and the Local System on member servers.) As this right can create a condition causing the generation of many spurious log entries, making it difficult to sort out any actual attack traces and can also create a DoS condition if the 'shutdown the system immediately if unable to generate security audits' setting has been enabled, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Generate security audits (SeAuditPrivilege) right.

Expected	**is contained in regular expression list**
	LOCAL SERVICE
	NETWORK SERVICE

	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	IIS APPPOOL\.NET v2.0
	IIS APPPOOL\.NET v2.0 Classic
	IIS APPPOOL\.NET v4.5
	IIS APPPOOL\.NET v4.5 Classic
	IIS APPPOOL\Classic .NET AppPool
	IIS APPPOOL\CR
	IIS APPPOOL\DefaultAppPool
	IIS APPPOOL\JSBHMREMITSSL
	NT AUTHORITY\LOCAL SERVICE
	NT AUTHORITY\NETWORK SERVICE

(2.24) 2642 Current list of Groups and User Accounts granted the 'Impersonate a client after authentication' right — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Impersonate a client after authentication' user right allows programs that are run of behalf of the user to impersonate a client. A common usage of this permission is to grant the right to a service account in order to pass client authentication to another service. In the default installation this right is only assigned to Administrators and Service. As the 'Impersonate a client after authentication' user right allows the impersonation of a user with specific rights, the granting of this right to Groups and User Accounts should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Impersonate a client after authentication right.

Expected	**is contained in regular expression list**
	Administrators
	LOCAL SERVICE
	NETWORK SERVICE
	SERVICE
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\IIS_IUSRS
	NT AUTHORITY\LOCAL SERVICE
	NT AUTHORITY\NETWORK SERVICE
	NT AUTHORITY\SERVICE

(2.25) 2386 Current list of Groups and User Accounts granted the 'Increase Scheduling Priority' right — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Increase Scheduling Priority' (SeIncreaseBasePriorityPrivilege) User Right allows the user/process to increase the 'base class' assigned to a process. (In the default configuration for all workstations, servers, and domain controllers, this right is only assigned to Administrators.) As this privilege could allow critical processes to be superseded by those that are rarely needed, but consume a great many CPU cycles, facilitating a DoS condition, this setting should be restricted as appropriate to the needs of the business. NOTE: This privilege is not required for use of any administrative tools that are part of the default OS, but may be needed during the software development process.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Increase scheduling priority (SeIncreaseBasePriorityPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	Right not assigned

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.26) 2387 Current list of Groups and User Accounts granted the 'Load and unload device drivers' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Load and unload device drivers' (SeLoadDriverPrivilege) User Right permits installation and removal of device drivers for the 'Plug and Play' installation process. (During the default installation, this right is assigned only to Administrators.) As a malicious program masquerading as a device drivers could unintentionally be installed with 'trusted' privileges in this manner, this setting should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Load and unload device drivers (SeLoadDriverPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.27) 2388 Current list of Groups and User Accounts granted the 'Lock Pages in Memory' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Lock Pages in Memory (SeLockMemoryPrivilege)' user right allows a User, Application, or Process to maintain data in physical memory, which prevents this data from being sent to a pagefile in virtual memory. (In the default installation for XP, this isn't assigned to any user. For servers, only the Administrator is granted this right be default.) As use of this privilege could tie up large amounts of RAM, this setting should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Lock pages in memory (SeLockMemoryPrivilege) right.

Expected	**does not contain regular expression list**
	[a-z]*\
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.28) 2392 Current list of User Accounts granted the 'Manage Auditing and Security Log (SeSecurityPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Manage Auditing and Security Log' (SeSecurityPrivilege) privilege assignment determines which user can specify 'object access' audit monitoring for various resources, such as files, registry keys, and AD items. (In the default configuration for all Windows systems, this is assigned only to Administrators.) Assigning user accounts to this privilege does allow/enable the assignees to carry out generalized object or access auditing--to have that occur it must be enabled in the 'Computer Configuration\Windows Settings\Security Settings\Local Policies\Audit Policies' setting. As any holder of this privilege can clear the log files, to preserve system audit trails, this capability should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Manage auditing and security log (SeSecurityPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.29) 4232 Current list of Groups and User Accounts granted the 'Modify an object label (SeRelabelPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Modify an object label (SeRelabelPrivilege)' Group Policy setting determines which user account(s) is/are permitted to alter the 'integrity label' of system objects, including files, registry keys, and/or processes that others own. As this capability may lead to the compromise of confidential information or privilege escalation, it should be carefully restricted and access monitored according to the needs of the business.

The following List String value(s) X indicate the current list of User Defined Accounts within the Computer Configuration\Windows Settings\Local Policies\User Rights Assignment\Modify an object label(SeRelabelPrivilege) policy.

Expected	**does not contain regular expression list**
	[a-z]*\
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.30) 2393 Current list of Groups and User Accounts granted the 'Modify firmware environment values (SeSystemEnvironmentPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Modify firmware environment values (SeSystemEnvironmentPrivilege)' user right allows the modification of the system environment variables, to permit a user or process to change the locations where a program operational files are kept. (In the default installation, this right is given only to Administrators, but may be needed during the application development or installation process.) As this privilege could allow the refocusing of system environment targets onto a rogue program source, this capability should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Modify firmware environment values (SeSystemEnvironmentPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.31) 2394 Current list of Groups and User Accounts granted the 'Perform Volume Maintenance Tasks (SeManageVolumePrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Perform Volume Maintenance Tasks (SeManageVolumePrivilege)' user right permits non-administrative and/or remote users to manage volumes or disks. (In the default configuration, this is assigned only to Administrators.) As malicious use of the capability could result in a DoS, data loss, data disclosure (by reading disk areas containing restricted data), and even performance issues, this capability should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Perform volume maintenance tasks (SeManageVolumePrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.32) 2395 Current list of Groups and User Accounts granted the 'Profile Single Process (SeProfileSingleProcessPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Profile Single Process (SeProfileSingleProcessPrivilege)' user right allows users to review the operation/performance of non-OS processes. (The default system configuration grants this privilege to Administrators, Power Users (on workstations), and the Local System.) As it may be necessary to grant this privilege for use of the System Monitor when it is set to gather I/O data via Windows Management Instrumentation, it should otherwise be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile single process (SeProfileSingleProcessPrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.33) 2396 Current list of Groups and User Accounts granted the 'Profile System Performance (SeSystemProfilePrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Profile System Performance (SeSystemProfilePrivilege)' user right allows users to review the operation/performance of system processes. (The default system configuration grants this privilege to Administrators and the Local System, which may not appear but is included). As it is not usually necessary to grant this privilege for use of the System Monitor, but may be required when gathering data via Windows Management Instrumentation, due to its capability to permit a malicious user to gather system data, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Profile system performance (SeSystemProfilePrivilege) right.

Expected	**is contained in regular expression list**
	Administrators
	NT\sSERVICE\\WdiServiceHost
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	NT SERVICE\WdiServiceHost

(2.34) 2398 Current list of Groups and User Accounts granted the 'Replace a process level token (SeAssignPrimaryTokenPrivilege)' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Replace a process level token (SeAssignPrimaryTokenPrivilege)' privilege permits the replacement of a process token of a child process, which can include altering authorization levels. (The default installation configuration grants this right to the Local Service and network Services, while the Local System already has the right.) As this right could be used for privilege escalation, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Replace a process level token (SeAssignPrimaryTokenPrivilege) right.

Expected	**is contained in regular expression list**
	LOCAL SERVICE
	NETWORK SERVICE
	OR, any of the selected values below:

	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	IIS APPPOOL\.NET v2.0
	IIS APPPOOL\.NET v2.0 Classic
	IIS APPPOOL\.NET v4.5
	IIS APPPOOL\.NET v4.5 Classic
	IIS APPPOOL\Classic .NET AppPool
	IIS APPPOOL\CR
	IIS APPPOOL\DefaultAppPool
	IIS APPPOOL\JSBHMREMITSSL
	NT AUTHORITY\LOCAL SERVICE
	NT AUTHORITY\NETWORK SERVICE

(2.35) 2399 Current list of Groups and User Accounts granted the 'Restore files and directories (SeRestorePrivilege)' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Restore files and directories (SeRestorePrivilege)' user right allows a user or process access to cross file and directory permissions when restoring files and directories, as well as act as the 'valid security principal' for any object being restored. (In the default installation configuration, this right is granted to Administrators and Backup Operators.) As this privilege could be used to overwrite a valid file with malicious content, this capability should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current user accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Restore files and directories(SeRestorePrivilege) right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Backup Operators

(2.36) 2400 Current list of Groups and User Accounts granted the 'Shut down the system (SeShutdownPrivilege)' right **Failed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Shut down the system (SeShutdownPrivilege)' user right allows the user or process to shut down the [local] system. (In the default installation, this is restricted to Administrators, Backup Operators, Power Users, and [ordinary] Users for workstations, to Administrators, Backup Operators, Print Operators, and Server Operators on member servers, and to Administrators and Server Operators for domain controllers.) As this privilege can cause a DoS condition if abused, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Shut down the system right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators
	BUILTIN\Backup Operators

(2.37) 2401 Current list of Groups and User Accounts granted the 'Synchronize directory service data (SeSynchAgenPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Synchronize directory service data (SeSynchAgenPrivilege)' user right allows the user or process to read/synchronize the objects in Active Directory, regardless of access controls on the object. (In the default configuration, this right is assigned only to Administrators on Domain Controllers (DCs) and has no applicability to Member Servers, Workstations, and Servers that are not functioning as Domain Controllers; it can, however, be checked to ensure default values have not been changed in the Local Security Policy). As this right can transverse the AD tree on a DC and read all object configurations regardless the permissions levels, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Local Policies\User Rights Assignment\Synchronize directory service data right.

Expected	**does not contain regular expression list**
	[a-z]*\
	OR, any of the selected values below:
	☑ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Right not assigned

(2.38) 2402 Current list of Groups and User Accounts granted the 'Take ownership of files or other objects (SeTakeOwnershipPrivilege)' right **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Take ownership of file or other objects (SeTakeOwnershipPrivilege)' user right allows a user to take over any object in the system, such as files/folders, printers, processes, registry keys, and/or services. (In the default installation this right is only assigned to Administrators.) As this privilege would allow capturing and controlling any system object, it should be restricted as appropriate to the needs of the business.

The following List String value(s) X indicate the current Groups and User Accounts granted the Computer Configuration\Windows Settings\Security Settings\Local Policies\User Rights Assignment\Take ownership of files or other objects right.

Expected	**matches regular expression list**
	Administrators
	OR, any of the selected values below:
	☐ Right not assigned
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BUILTIN\Administrators

(2.39) 8365 Status of the local Administrator account (enabled/disabled) **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The local Administrator account has full access to the system and if compromised by a malicious user, the entire system is at risk. As reducing this risk is by disabling the Administrator account reduces the attack surface for unauthorized users, this account should be disabled/restricted according to the needs of the business.

The following List String value(s) X indicate the current status of the Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Administrator account status setting.

Expected	**matches regular expression list**
	((Disabled))|((0))|((Enabled))|((1))
	OR, any of the selected values below:
	☐ No results found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled

Extended Evidence:

Account Desc	Username	Status
Built-in account for administering the computer/ domain	Administrator	Enabled

(2.40) 8141 Status of the Security Options 'Accounts: Block Microsoft accounts' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The "Accounts: Block Microsoft accounts' to 'Users can't add or log on with Microsoft accounts" policy setting prevents users from adding new Microsoft accounts on the computer. If the option "Users can't add Microsoft accounts" is selected, User will not be able to create new Microsoft accounts, switch to Microsoft account, or connect a domain account to a Microsoft account and if the option "Users can't add or log on with Microsoft accounts" is selected then existing Microsoft account users will not be able to log on to Windows. Companies/organizations that want to effectively implement identity management policies and maintain control of the accounts which are used to log on to their computers will probably want to block Microsoft accounts. Microsoft account will be blocked to meet requirements of compliance standards that apply to their information system.

This integer value X indicates the status of the setting Accounts: Block Microsoft accounts using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\NoConnectedUser.

Expected **any of the selected values below:**

- ☐ This policy is disabled(0)
- ☐ Users cant add Microsoft accounts(1)
- ☑ Users cant add or log on with Microsoft accounts(3)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	NoConnectedUser	

(2.41) 8364 Status of the local 'Guest' account (enabled/disabled) **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Guest' account on the local system (Member Server or Domain Controller) can be employed when a user needs to be granted access to the system, but does not need any of the typical rights/privileges granted to an ordinary 'Authenticated User,' such as for use in a 'kiosk' role. As there are known exploits for the 'Guest' role, including allowing non-authenticated users to create a mail relay when the domain 'Guest' account is enabled, it should be disabled whenever feasible to do so. NOTE: In order to prevent a malicious user from identifying the account by its SID after renaming the Guest account, disable the anonymous Security (SID)/Name translation setting.

The following List String value(s) X indicate the current status of the Accounts: Guest account status in the Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Guest account status registry key.

Expected **matches regular expression list**

((Disabled))|((0))

OR, any of the selected values below:

- ☐ No results found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled

Extended Evidence:

Account Desc	Username	Status
Built-in account for guest access to the computer/domain	Guest	Disabled

(2.42) 1366 Status of the 'Accounts: Limit local account use of blank passwords to console logon only' setting **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

At times, having a blank password for user login is acceptable, especially at kiosk-type machine that are for public access. However, as allowing remote users to log in without passwords can be a serious security risk, this capability should be restricted appropriately, such as limiting this capability to the physical console.

This Integer value X from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\LimitBlankPasswordUse registry key indicates the current status of whether or not local accounts that are not password protected can be used to logon from anywhere other than the console. A value of 1 indicates that blank password use has been enabled for console logon only; a value of 0 indicates that blank password use is allowed when accessing the host from a remote location.

Expected **any of the selected values below:**

Disabled(0)
Enabled(1)
RegSubKey not found
Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	LimitBlankPasswordUse	1

(2.43) 8367 Status of the name of the 'Built-in Administrator' account — Failed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Built-in Administrator' account has full access to the system, including all files, directories, and processes. As knowing the name of a valid account with super-user privileges is half the battle in crafting a brute-force exploit, coupled with the fact that the 'Administrator' cannot be locked out, the Administrator account name-value should be set as appropriate to the needs of the business.

The following List String value(s) X indicate the current status of the Accounts: Rename administrator account setting in the Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename administrator account registry key.

Expected **matches regular expression list**

^Account Renamed$

OR, any of the selected values below:

No results found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Account not Renamed

Extended Evidence:

Account Desc	Username	Status
Built-in account for administering the computer/ domain	Administrator	Account not Renamed

(2.44) 8366 Status of the name of the 'Built-in Guest' account — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Guest' account can be employed when a user needs to be granted access to the system, but does not need any of the typical rights/privileges granted to an ordinary 'Authenticated User,' such as for use in a 'kiosk' role. As there are known exploits for the 'Guest' role, including allowing non-authenticated users to create a mail relay when the domain 'Guest' account is enabled, this account should be renamed to something unique for your organization and set as appropriate to the needs of the business. NOTE: In order to prevent a malicious user from identifying the account by its SID after renaming the Guest account, disable the anonymous Security (SID)/Name translation setting.

The following List String value(s) X indicate the current status of the Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename guest account setting.

Expected **does not contain regular expression list**

Account not Renamed

OR, any of the selected values below:

No results found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Account not Renamed

Extended Evidence:

Account Desc	Username	Status
Built-in account for guest access to the computer/ domain	Guest	Account not Renamed

(2.45) 2608 Status of the 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' setting — Failed — CRITICAL

The 'Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings' setting determines how the system applies audit policy settings. Windows Vista has the capability of managing audit policy through the use of audit policy subcategories. However, if audit policy is set at the category level, subcategory audit policy settings are overwritten by default. Enabling this setting addresses this issue by forcing the audit policy subcategory settings to override the audit policy category settings. When this setting is enabled, audit policy can be managed at the subcategory level without requiring changes to the Group Policy.

This Integer value X indicates the current status of the Audit: Force audit policy subcategory settings (Windows Vista or later) to override audit policy category settings setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\Currentcontrolset\Control\Lsa	SCENoApplyLegacyAuditPolicy	

(2.46) 1156 Status of the 'Audit: Shut Down system immediately if unable to log security audits' setting **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Audit: Shut down system immediately if unable to log security audits' setting is responsible for ensuring that all security related events are captured in the Security Event Logs. If, for any reason, security events are not able to be captured when this setting is enabled, the system will immediately shut down which could negatively impact operations. If a system is shut down as a result, a member of the Administrator Group will be required to log in and archive the logs to allow for further review in order to determine the cause and respond accordingly. It is important to coordinate the enabling of this setting with requirements stipulated within internal policies and procedures for backup and retention of activity logs. As maximum effectiveness of this setting requires considering setting of the 'Security Log Retention Method' to 'Overwrite Events by Days' or 'Do Not Overwrite Events,' this value should be set according to the needs of the business.

This Integer value X indicates the current status of the Audit: Shut Down system immediately if unable to log security audits setting as defined within the HKLM\System\CurrentControlSet\Control\Lsa\CrashOnAuditFail registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ RegSubKey not found
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\SYStem\CurrentControlSet\Control\Lsa	CrashOnAuditFail	0

(2.47) 1052 Status of the 'Devices: Allowed to format and eject removable media' setting (NTFS formatted devices) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The ability to format/eject removable media allows the user to create and/or erase a data or system partition on a removable storage device, such as floppy disks, 'Jaz' and 'Zip' drives, or USB-based 'flash memory' drives, that allow NTFS partition creation. As this capability may allow the copying of user-accessible sensitive data for removal from a restricted area or the destruction of vital information stored on the removable media, by accident of design, this capability should be restricted appropriately.

This Integer value X indicates the status of the groups permitted to Eject Removable Devices from the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\AllocateDASD registry key. A value of 0 indicates the Administrators group has access; a value of 1 indicates the Administrators and Power Users groups have access; a value of 2 indicates Administrators and Interactive Users groups have access.

Expected **any of the selected values below:**

- [x] Administrators(0)
- [ ] Administrators and Power Users(1)
- [ ] RegSubKey not found
- [ ] Administrators and Interactive Users(2)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon	AllocateDASD	

(2.48) 1163 Status of the 'Prevent users from installing printer drivers' setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Prevent users from installing printer drivers' setting provides protection from users installing unsigned or malware infected drivers onto the system. As installing printer drivers requires code to be loaded directly into operating system kernel's privileged space and a malicious user can use this vector to introduce invalid or Trojan-based print drivers in order to subvert the system, this parameter should be restricted/set according to the needs of the business. Note: By preventing users of the system from installing printer drivers could result in increased calls to the Helpdesk for support. Consider implementing this control in conjunction with CID 1150 (Unsigned driver installation behavior).

This Integer value X indicates the current status of the Devices: Prevent users from installing printer drivers setting for the HKEY_LOCAL_MACHINE\ SYSTEM\CurrentControlSet\Control\Print\Providers\LanMan Print Services\servers\addprinterdrivers registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\Print\ Providers\LanMan Print Services\servers	addprinterdrivers	1

(2.49) 1370 Status of the 'Domain member: Digitally encrypt or sign secure channel data (always)' setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Digitally encrypt or sign secure channel data (always)' setting dictates that SMB data exchanged between a server and client (on a secure channel) must be either signed or sealed. If the domain controller on the other side of the channel does not support signing or sealing, the system can refuses to establish a channel--This provides the strongest security for inter-domain communication. As this setting may break the communication path to legacy applications, this should be changed only after careful testing and set as appropriate to business needs.

This Integer value X indicates the current status of the RequireSignOrSeal setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\ Services\Netlogon\Parameters\RequireSignOrSeal registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	RequireSignOrSeal	1

(2.50) 1371 Status of the 'Domain member: Digitally encrypt secure channel data (when possible)' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Digitally encrypt secure channel data (when possible)' entry is used when negotiating the conditions of a secure channel with a domain controller and specifies whether or not outgoing secure channel traffic is encrypted (sealed). Enabling this reduces the likelihood of successful sniffing or replay attacks. As enabling this setting may break the communication path to legacy applications, this should be changed only after careful testing and set as appropriate to business needs. NOTE: If the domain controller does not support this ability, traffic will be sent unencrypted regardless of the setting.

This Integer value X indicates the current status of the Domain member: Digitally encrypt secure channel data (when possible) setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\SealSecureChannel registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

☐ Disabled(0)
☑ Enabled(1)
☐ RegSubKey not found
☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	SealSecureChannel	1

(2.51) 1372 Status of the 'Domain member: Digitally sign secure channel data (when possible)' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Digitally sign secure channel data (when possible)' entry is used to specify whether or not outgoing secure channel traffic is signed. (This entry is used when negotiating the conditions of a channel with a domain controller.) Having the traffic digitally signed reduces the likelihood of successful spoofing and/or hijacking attempts going unnoticed, as alterations of the cryptographic hash on a traffic segment will cause error conditions. NOTE: If the domain controller does not support this ability, traffic will be sent unsigned.

This Integer value X indicates the current status of the Digitally sign secure channel data (when possible) setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\SignSecureChannel registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

☐ Disabled(0)
☑ Enabled(1)
☐ RegSubKey not found
☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	SignSecureChannel	1

(2.52) 1373 Status of the 'Domain member: Disable machine account password changes' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Disable machine account password changes' used to authenticate/authorize a system within a domain; this value is set to be changed every 30 days by default. By having the 'Disable machine account password changes' setting configured to 'disabled,' the systems domain account password will be changed automatically by the workstation. If this parameter is set to 'enabled,' the workstation will not manage its system domain account password automatically and the password will never be changed, which may be a condition required by certain legacy programs. As keeping the same password for a long period of time can allow a malicious user to attempt to break it, this value should be set as appropriate to the needs of the system and its role in the application provision process.

The following Integer value X indicates the current status of the Domain Member: Disable machine account password changes [for the local machine account] setting from the HKLM\System\CurrentControlSet\Services\Netlogon\Parameters\disablepasswordchange registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	DisablePasswordChange	0

(2.53) 1374 Status of the 'Domain member: Maximum machine account password age' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Maximum machine account password age' used to authenticate/authorize a system within a domain; this value is set to be changed every 30 days by default. As this setting determines how often the system resets its own password and will have no discernible impact on the end-user, it should be set as appropriate to the environment and business needs.

This Integer value X indicates the current status of the Domain Member: Maximum machine account password age setting (in days) from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\MaximumPasswordAge registry key.

Expected	**in range**
	1-30
	OR, any of the selected values below:
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	30

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	MaximumPasswordAge	30

(2.54) 1375 Status of the 'Domain member: Require strong (Windows 2000 or later) session key' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Domain member: Require strong (Windows 2000 or later) session key' is to require a 128-bit key for encrypted secure channel data. When a system joins a domain, an account is created. Thereafter, when the system starts, it uses the computer account password to create a secure channel to domain controller--This channel is used for NTLM passthrough authentication, LSA SID\Name Lookup, etc. As this setting requires that all 'secure traffic' between domain controllers and workstations use a 128-bit key to encrypt the traffic, this should be tested carefully and set as appropriate, for it may otherwise break Unix/Windows network integrations or other legacy connections.

This Integer value X indicates the current status of the RequireStrongKey setting requiring the trusted domain controller to use keys of 128-bit or greater from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netlogon\Parameters\RequireStrongKey registry key. A value of 0 indicates the RequireStrongKey setting is disabled; a value of 1 indicates the RequireStrongKey is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Netlogon\Parameters	RequireStrongKey	1

(2.55) 1190 Status of the 'Interactive Logon: Do Not Display Last User Name' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Interactive Logon: Do Not Display Last User Name' setting prevents the name of the last authorized user login form being automatically displayed. As this information is half of what is needed by a malicious user to log in and there is an increased risk that an unauthorized user may gain knowledge of the client domain naming standards and obtain a valid username (for use in a brute-force attack), this 'last username' display capability should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the Interactive Logon: Do Not Display Last User Name setting defined within the HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System\DontDisplayLastUserName registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	DontDisplayLastUserName	0

(2.56) 1376 Status of the 'Interactive Logon: Do not require CTRL+ALT+DEL' setting — Passed — URGENT

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The Windows OS behaves differently when the 'CTRL+ALT+Delete' is invoked before login--this guarantees that the authentication process for the system is engaged. Otherwise, when only the two-line login screen is presented, it is possible that a Trojan program is displaying a phony userid/password login screen, which will collect the credentials and exit, leaving the user believing that he/she simply mistyped one or both of the required values. NOTE: As this is one of the reverse-logic controls, it is important to remember that this should be DISABLED to actually be enabled.

This Integer value X indicates the current status of the Interactive Logon: Do not require Ctl+Alt+Del setting from the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\DisableCAD registry key. A value of 0 indicates the setting is disabled, so use of the 'Ctl+Alt+Del' sequence is required to log on; a value of 1 indicates the setting is enabled, so use of the 'Ctl+Alt+Del' sequence is not required to log on.

Expected	**equal to**
	Disabled (0)

	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	DisableCAD	0

(2.57) 8145 Status of the Security Options 'Interactive logon: Machine inactivity limit' setting (seconds) — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Interactive logon: Machine inactivity limit' setting sets the limit in terms of amount of inactive time, when exceeded the screen saver is run, locking the session. As open sessions on systems that have been left unattended can be compromised by malicious users, potentially allowing them access to sensitive data and this can further be used to conserve the resources set aside for maintaining the connection for maximum performance. Thus, it is important to establish a limit in terms of specific amount of inactive time after which the session would be locked, allowing only the legitimate users to log back on to the session. However, setting this time to very low value could lock the legitimate sessions in less time. Thus, this value should be set as appropriate to the needs of the business.

This Integer value X indicates the current value of the setting Interactive logon: Machine inactivity limit using the registry path HKEY_LOCAL_MACHINE\ Software\Microsoft\Windows\CurrentVersion\Policies\System\InactivityTimeoutSecs.

Expected	**in range**
	1-900
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	InactivityTimeoutSecs	

(2.58) 3778 Status of the contents of the 'login banner' (Windows/Unix/Linux) — Passed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The logon banner provides a warning to inappropriate or unapproved users as to the consequences of accessing private systems and data illegally. By displaying a legal text message during the login process, all individuals attempting to access the system understand that monitoring of all system activity is performed and all violators may be prosecuted, to the full extent of the law. As implementing a logon banner to deter inappropriate use can provide a foundation for legal action against abuse, this 'warning' content should be set as appropriate to the needs of the business.

This String value X indicates the current Content of the Interactive Login Screen from the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\ CurrentVersion\Policies\System 'LegalNoticeText' Windows Registry key.

Expected	**regular expression match**
	[A-Za-z0-9]
	OR, any of the selected values below:
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

This system is restricted to authorized users for business purposes only (unless indicated otherwise). Unauthorized individuals attempting access will be liable to prosecution. Inappropriate use of the system, which can include personal communications, may result in disciplinary action.
The Company reserves the right to access, intercept and monitor all information contained within or transmitted via the Company networks for compliance and quality control purposes.

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	LegalNoticeText	This system is restricted to authorized users for business purposes only (unless indicated otherwise). Unauthorized individuals attempting access will be liable to prosecution. Inappropriate use of the system, which can include personal communications, may result in disciplinary action. The Company reserves the right to access, intercept and monitor all information contained within or transmitted via the Company networks for compliance and quality control purposes.

(2.59) 1134 Status of 'logon banner title' setting (Legal Notice) — Passed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Login/logon banners and any captions describing them are electronic messages that provide a notice of legal cautions to users of computing resources. As these generate consent to real-time monitoring of user retrieval of stored files and records, eliminates any reasonable expectation of privacy, and establishes the 'common authority' to consent to a search by law enforcement, this text value should be written according to the needs of the business.

The following String value X indicates the current status of the Caption set for the Interactive Login Screen as defined by the HKLM\Software\Microsoft\ Windows\CurrentVersion\Policies\System\LegalNoticeCaption registry key.

Expected **regular expression match**

[A-Za-z0-9]

OR, any of the selected values below:

- ☐ RegSubKey not found
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

IT IS AN OFFENSE TO CONTINUE WITHOUT PROPER AUTHORIZATION.

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	LegalNoticeCaption	IT IS AN OFFENSE TO CONTINUE WITHOUT PROPER AUTHORIZATION.

(2.60) 1155 Status of the 'Interactive Logon: Number of Previous Logons to Cache (in case domain controller is not available' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Interactive Logon: Number of previous logons to cache (in case domain controller is not available)' setting is responsible for allowing (or disallowing, by configuring this setting to a value of 'zero') interactive logons with domain accounts to authenticate on a workstation locally when a domain controller is unavailable. By allowing the authentication credentials to be cached locally creates an opportunity for exploitation by a malicious user in an effort to gain access to the system and/or sensitive data by using password cracking tools against them. Repeated invalid attempts at accessing the system will not lock the account since it is 'owned' by the domain and not the local system and domain policies have not yet been applied (such as User Account Lockout After Invalid Attempts settings). As users will not be prompted to change their password on a 'cached account,' which could result in increased calls to the Help Desk, due to locked accounts in the domain resulting from expiration or other reason, but not on the local system using the cached credentials, this value should be set according to the needs of the business. NOTE: Remember to consider remote users who may logon using cached credentials before establishing a Virtual Private Networking (VPN) connection to access internal resources when configuring this setting.

The Integer value X indicates the maximum number of Interactive logon: Number of previous logons to cache using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\CachedLogonsCount.

Expected **less than or equal to**

4

OR, any of the selected values below:

RegSubKey not found

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

10

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon	CachedLogonsCount	10

(2.61) 1091 Status of the number of days before a [Prompt user] password expiration warning prompt is displayed at login **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Among the several characteristics that make 'user identification' via password a secure and workable solution is setting the 'expiration warning date' requirement. This establishes the number of days before the host will begin to display 'password expiration warning' messages upon login. Without having a pre-expiration warning message, it is more likely that users will not prepare for this event, which may contribute to the selection of hard-to-remember or easily broken password sequences, which circumvents the intent of having rules for password complexity enforced. This may cause some users to forget or write down their new password, which can lead either to a system compromise or increased calls to Help Desk resources. (Interactive Logon: Prompt User to Change Password Before Expiration)

This Integer value X indicates the current status of the Interactive Logon: Prompt User to Change Password Before Expiration as a value for 'Days prior to expiration' from the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\PasswordExpiryWarning registry key.

Expected **in range**

5-14

OR, any of the selected values below:

RegSubKey not found

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

7

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon	PasswordExpiryWarning	7

(2.62) 1377 Status of the 'Interactive Logon: Require Domain Controller authentication to unlock workstation' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Enabling the 'Interactive Logon: Require Domain Controller authentication to unlock workstation' setting can help protect against attacks that occur when the system is in screen-saver mode, for if this is disabled, a malicious user could potentially succeed with a brute-force attack against the Administrator account in the local password cache. NOTE: When a user locks or uses hibernation on the workstation, the Domain Controller must be available to unlock it again.

This Integer value X indicates the current status of the Interactive logon: Require Domain Controller authentication to unlock setting from the HKLM\ Software\Microsoft\Windows NT\CurrentVersion\Winlogon\ForceUnlockLogon registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **equal to**

Enabled (1)

OR, any of the selected values below:

Disabled(0)

Enabled(1)

RegSubKey not found

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon	ForceUnlockLogon	0

(2.63) 1378 Status of the 'Interactive Logon: Smart Card Removal Behavior' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Interactive Logon: Smart Card Removal Behavior' setting allows the control of the status of the workstation when the smart card is removed, from 'no action' to 'log off' user. The 'Smart Cards' are part of the two-factor authentication system used in high security environments, providing a tamper-resistant/portable way to log on to a Microsoft Windows Server family domain, provide client authentication, sign code, and secure e-mail.

This Integer value X indicates the current status of the Interactive logon: Smart card removal behavior setting in the HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon (ScRemoveOption) Registry key. A value of 0 indicates the state will be No change; a value of 1 indicates the state will be Lock Workstation; a value of 2 indicates the state will be Force Logoff. For Microsoft Vista systems only, a value of 3 indicates the state will be Disconnect From Remote Terminal Server Session.

Expected — **equal to**

Lock workstation (1)

OR, any of the selected values below:

- [ ] No action(0)
- [x] Lock workstation(1)
- [ ] RegSubKey not found
- [ ] Force logoff(2)
- [ ] Disconnect if a remote desktop services session(3)
- [ ] Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

No action (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon	ScRemoveOption	0

(2.64) 1149 Status of the 'Microsoft network client: Digitally sign communications (always)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network client: Digitally sign communications (always)' setting is associated with the Server Message Block (SMB) protocol only. Whenever it is enabled, all signed communications will be negotiated with any server that supports it. As enabling this setting helps to reduce the potential for man-in-the-middle (MITM) attacks to occur by providing protection for packet tampering and supports mutual authentication, this value should be set according to the needs of the business.

This Integer value X indicates the status of the Microsoft network client: Digitally sign communications (always) for the HKEY_LOCAL_MACHINE\ SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters\RequireSecuritySignature registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected — **equal to**

Enabled (1)

OR, any of the selected values below:

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\ LanmanWorkstation\Parameters	RequireSecuritySignature	0

(2.65) 1379 Status of the 'Microsoft network client: Digitally Sign Communications (if server agrees) ' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network client: Digitally Sign Communications (if server agrees)' setting is used to specify whether or not to initiate traffic signing, based upon the receiving server agreeing to sign the traffic that it receives. When enabling this setting, all Server Message Block (SMB) communications by MS clients with servers using the Win2K or later OS will attempt to be negotiate signing, potentially guaranteeing message integrity, but not confidentiality, so this should be set as appropriate to business needs. NOTE: If the recipient server is not Win2K or above, SMB traffic will go through, but signing will not take place.

This Integer value X indicates the current status of the Microsoft network client: Digitally Sign Communications (if server agrees) setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\EnableSecuritySignature registry key. A value 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\ LanmanWorkstation\Parameters	EnableSecuritySignature	1

(2.66) 1380 Status of the 'Microsoft network client: Send Unencrypted Password to Connect to Third-Party SMB Server' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network client: Send Unencrypted Password to Connect to Third-Party SMB Server' setting will determine if using plain-text passwords is allowed when connecting to a third-party SMB server. As sending unencrypted passwords through a shared network can risk credentials being compromised by anyone using a packet sniffer on the network, this value should be set as appropriate to business needs.

This Integer value X indicates the current status of the Send Unencrypted Password to Connect to Third-Party SMB Server setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanWorkstation\Parameters\EnablePlainTextPassword registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\ LanmanWorkstation\Parameters	EnablePlainTextPassword	0

(2.67) 1199 Status of the 'Microsoft network server: Amount of Idle Time Required Before Suspending Session' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network server: Amount of Idle Time Required Before Suspending Session' setting establishes time limits on sessions between computers that share resources with other Windows systems and do so using the SMB protocol, which exchanges credentials, performs authentication and allocates resources for connection management. As open sessions on systems that have been left unattended can be compromised by malicious users, potentially allowing them access to sensitive data and this can further be used to conserve the resources set aside for maintaining the connection for maximum performance, establishing a specific amount of time that the system is allowed to be idle before the connection is closed automatically, this value should be set as appropriate to the needs of the business.

The Integer value X from the Windows Registry key indicates the amount of continuous idle time (in minutes) that must pass in an SMB session before the session is suspended due to inactivity using the registry key location - HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanManServer\Parameters\autodisconnect.

Expected **in range**

1-15

OR, any of the selected values below:

- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

15

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters	AutoDisconnect	15

(2.68) 1189 Status of the 'Microsoft network server: Digitally sign communication (always)' setting (SMB) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network server: Digitally sign communication (always)' setting requires that communication from the server must be digitally signed, thus ensuring its authenticity. (This still allows the messages contents to be intercepted and read.) As digitally signing SMB traffic reduces the risk of spoofing and 'man-in-the-middle' (MITM) attacks, this value should be set as appropriate to the needs of the business. (RequireSecuritySignature)

This Integer value X indicates the current status of the Microsoft network server: Digitally sign communications (always) setting defined within the HKLM\SYSTEM\CurrentControlSet\Services\lanmanserver\parameters\requiresecuritysignature registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **equal to**

Enabled (1)

OR, any of the selected values below:

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\lanmanserver\parameters	requiresecuritysignature	0

(2.69) 1381 Status of the 'Microsoft network server: Digitally Sign Communications (if Client agrees) setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

When enabling 'Microsoft network server: Digitally Sign Communications (if Client agrees) setting, all Server Message Block (SMB) communications by MS clients to servers using the Win2K or later OS will request signing, which guarantees message integrity, but not confidentiality. As this will potentially break legacy applications, this value should be set as appropriate to use requirements. NOTE: If the recipient server is not Win2K or above, SMB traffic will go through, but signing will not take place.

This Integer value X indicates the current status of the Microsoft network server: Digitally sign communications (if client agrees) setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\LanmanServer\Parameters\EnableSecuritySignature registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\ LanmanServer\Parameters	EnableSecuritySignature	0

(2.70) 1382 Status of the 'Microsoft Network Server: Disconnect clients when logon hours expire' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft Network Server: Disconnect clients when logon hours expire' setting forces workstation clients that are connected to services via the domain to disconnect from it when the permitted login period has expired, even though the User will not have the desktop forcibly closed. As this will also disconnect a workstation that is acting as a server, closing the network connections when the allotted time expires, this should be set as appropriate to business needs. NOTE: This lockout applies only to SMB-based connections.

This Integer value X indicates the current status of the Enable Forced LogOff setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\ Services\LanmanServer\Parameters\EnableForcedLogOff registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\ LanmanServer\Parameters	EnableForcedLogOff	1

(2.71) 5264 Status of the 'Microsoft network server: Server SPN target name validation level' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Microsoft network server: Server SPN target name validation level' setting determines the validation level against the SPN provided by clients when attempting to access shared folders/printers through the SMB protocol. This setting can assist in combating relay attacks on computers (or servers) using the SMB protocol. It can allow for a check against a list of SPN's on the computer/server before making the connection.

The following List Integer value(s) X indicate the current status of the Microsoft network server: Server SPN target name validation level setting defined within the HKLM\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters\SMBServerNameHardeningLevel registry key. The resulting values indicate: 0 for Off, 1 for Accept if provided by client, 2 for Required from client.

Expected	**matches list**
	Accept if provided by client (1)

	OR, any of the selected values below:
	☐ Off(0)
	☑ Accept if provided by client(1)
	☐ Required from client(2)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters	SMBServerNameHardeningLevel	

(2.72) 8279 Status of the Security Options 'Network Access: Allow Anonymous SID/Name Translation' setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Allow Anonymous SID/Name Translation' setting is used to disallow anonymous users from resolving to a username by using the associated security identifier (SID). User with local access could use the well-known Administrator's SID to learn the real name of the built-in Administrator account, even if it is renamed. The user could then use the account name to initiate a password guessing attack. Thus, this setting should be set as per the need of the organization.

This integer value X indicates the status of the setting Network Access: Allow Anonymous SID/Name Translation using the configuration path Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network access: Allow anonymous SID/Name translation. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Defined
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

(2.73) 1197 Status of the 'Network access: Do not allow anonymous enumeration of SAM accounts' setting — Passed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

If enabled, the 'Anonymous enumeration of SAM accounts' allows an anonymous user to request the translation of a security ID (SID) to a username. As an attacker could use a well-known SID, such as a local Administrator account, to access the system, this capability should be set in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the setting Do Not Allow Anonymous Enumeration of SAM Accounts using the registry key path - HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\RestrictAnonymousSAM. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	RestrictAnonymousSAM	1

(2.74) 1153 Status of the 'Network Access: Do not allow Anonymous Enumeration of SAM Accounts and Shares' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Do not allow Anonymous Enumeration of SAM Accounts and Shares' setting protects the list of user accounts and provides protection for the list of network file shares that have been established. As this helps to prevent malicious users from requesting the translation of a security ID (SID) to a username, such as that of the local Administrator account, to access the system, this value should be set according to the needs of the business. NOTE: Whenever enabling this setting, consider doing so in conjunction with CID 1197 (Anonymous enumeration of SAM accounts).

This Integer value X indicates the status of the Restrict SAM connections by Anonymous Users from the Windows Registry key HKLM\System\Currentcontrolset\control\lsa\RestrictAnonymous setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled. NOTE: For Windows 2000 systems, these values are reversed (e.g., A '0' indicates 'enabled' and a '1' indicates 'disabled').

Expected **equal to**

Enabled (1)

OR, any of the selected values below:

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
hklm\System\Currentcontrolset\control\lsa	RestrictAnonymous	0

(2.75) 2585 Status of the 'Network access: Do not allow storage of passwords and credentials for network authentication' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network access: Do not allow storage of passwords and credentials for network authentication' setting determines whether or not the Stored User Names and Passwords feature of Windows will save .NET Passports, credentials, or passwords. When this setting is enabled, the Stored User Names and Passwords feature is prevented from storing credentials and passwords. When credentials and passwords are stored as part of a user's Domain account information and a malicious user compromises the account, all credentials and passwords will be compromised as well. It is always best practice to turn off any unnecessary services to reduce the overall threat surface of the system. If this functionality is not required for the systems' operation, it should be disabled/restricted as appropriate to the needs of the business. Note: To set this setting, use the registry key/value at location - HKLM\System\CurrentControlSet\Control\Lsa (DisableDomainCreds).

This Integer value X indicates the current status of the setting Network access: Do not allow storage of passwords and credentials for network authentication using registry key path HKLM\System\CurrentControlSet\Control\Lsa\DisableDomainCreds. A value of 0 indicates the setting is Disabled; a value of 1 indicates the service is Enabled.

Expected **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found
- [ ] RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	DisableDomainCreds	0

(2.76) 1383 Status of the 'Network Access: Let Everyone permissions apply to anonymous users' setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Enabling the 'Network Access: Let Everyone permissions apply to anonymous users' setting would add the 'anonymous user,' with a 'null [authentication] session,' such as an unauthenticated web browser-connected user or null dial-up-connection user, to the all-inclusive 'Everyone' group. As this capability would grant an anonymous user the escalated network privileges that are assigned by default to the 'Everyone' group, this should be disabled/restricted as appropriate to business needs. NOTE: This setting is disabled by default and patches a security flaw in Windows NT4.0 that allowed null-session connections to LAN resources via dial-up.

This Integer value X indicates the current status of the Network access: Let Everyone permissions apply to anonymous users setting from the HKLM\System\CurrentControlSet\Control\Lsa\EveryoneIncludesAnonymous registry key. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	EveryoneIncludesAnonymous	0

(2.77) 5209 Status of the 'Network Access: Named Pipes that can be accessed anonymously' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Named Pipes that can be accessed anonymously' setting refers to the communication links established directly between local and remote 'host processes.' As this list defines which Pipes can be accessed remotely via a 'null session,' which can permit null [unauthenticated] process access and should be left empty (if null-session access should be blocked), this list should be populated in accordance with the needs of the business. NOTE: To properly use the 'Network Access: Named Pipes that can be accessed anonymously' setting, the 'Network Access: Restrict anonymous access to Named Pipes and Shares' option must first be enabled. This setting can be set by using the registry key/value at location - HKLM\System\CurrentControlSet\Services\LanManServer\Parameters\NullSessionPipes.

The following List String value(s) X indicate the current status of the Network access: Named Pipes that are accessed anonymously setting defined within the HKLM\System\CurrentControlSet\Services\LanManServer\Parameters\NullSessionPipes registry key.

Expected	**does not contain regular expression list**
	[A-Za-z0-9]
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	BROWSER
	COMNAP
	COMNODE
	LLSRPC
	lsarpc
	netlogon
	samr
	SPOOLSS
	SQL\QUERY

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	COMNAP
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	COMNODE
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	SQL\QUERY
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	SPOOLSS

HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	LLSRPC
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	BROWSER
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	netlogon
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	lsarpc
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionPipes	samr

(2.78) 5212 Status of the 'Network Access: Remotely accessible registry paths' setting (Windows 2003 and later) **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Remotely accessible registry paths' setting defines the registry paths/child paths which can be accessed from other systems across the network. This access depends on the enablement of the Remote Registry Service and requires authentication, however, opens up additional opportunity for a malicious user to gain access and make changes to the registry settings defining how the system will function. If access to the 'Network Access: Remotely accessible registry paths' service is not required for the system's operation, it should be restricted according to the needs of the business.

The following List String value(s) X indicate the current contents of the setting Network access: Remotely accessible registry paths and sub-paths using the registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\Winreg\AllowedExactPaths\Machine.

Expected	**matches regular expression list**
	System\\CurrentControlSet\\Control\\ProductOptions
	System\\CurrentControlSet\\Control\\Server\sApplications
	Software\\Microsoft\\Windows\sNT\\CurrentVersion
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Software\Microsoft\Windows NT\CurrentVersion
	System\CurrentControlSet\Control\ProductOptions
	System\CurrentControlSet\Control\Server Applications

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedExactPaths	Machine	System\CurrentControlSet\Control\ProductOptions
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedExactPaths	Machine	System\CurrentControlSet\Control\Server Applications
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedExactPaths	Machine	Software\Microsoft\Windows NT\CurrentVersion

(2.79) 5213 Status of the 'Network Access: Remotely accessible registry paths and subpaths' setting **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Remotely accessible registry paths and subpaths' setting defines the registry paths/child paths which can be accessed from other systems across the network. This access depends on the enablement of the Remote Registry Service and requires authentication, however, opens up additional opportunity for a malicious user to gain access and make changes to the registry settings defining how the system will function. If access to the 'Network Access: Remotely accessible registry paths and subpaths' service is not required for the system's operation, it should be restricted according to the needs of the business. Note: This setting can be set using the registry key/value at location - HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths (Machine).

The following List String value(s) X indicate the contents of the Network Access: Remotely accessible registry paths and subpaths setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths (Machine) registry key.

Expected	**matches regular expression list**
	System\\CurrentControlSet\\Services\\Eventlog
	Software\\Microsoft\\OLAP\sServer
	Software\\Microsoft\\Windows\sNT\\CurrentVersion\\Print

	System\\CurrentControlSet\\Control\\Print\\Printers
	Software\\Microsoft\\Windows\sNT\\CurrentVersion\\Perflib
	System\\CurrentControlSet\\Control\\Terminal\sServer\\DefaultUserConfiguration
	Software\\Microsoft\\Windows\sNT\\CurrentVersion\\Windows
	System\\CurrentControlSet\\Control\\ContentIndex
	System\\CurrentControlSet\\Services\\SysmonLog
	System\\CurrentControlSet\\Control\\Terminal\sServer\\UserConfig
	System\\CurrentControlSet\\Control\\Terminal\sServer
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Software\Microsoft\OLAP Server
	Software\Microsoft\Windows NT\CurrentVersion\Perflib
	Software\Microsoft\Windows NT\CurrentVersion\Print
	Software\Microsoft\Windows NT\CurrentVersion\Windows
	System\CurrentControlSet\Control\ContentIndex
	System\CurrentControlSet\Control\Print\Printers
	System\CurrentControlSet\Control\Terminal Server
	System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration
	System\CurrentControlSet\Control\Terminal Server\UserConfig
	System\CurrentControlSet\Services\Eventlog
	System\CurrentControlSet\Services\SysmonLog

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Control\Print\Printers
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Services\Eventlog
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	Software\Microsoft\OLAP Server
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	Software\Microsoft\Windows NT\CurrentVersion\Print
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	Software\Microsoft\Windows NT\CurrentVersion\Windows
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Control\ContentIndex
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Control\Terminal Server
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Control\Terminal Server\UserConfig
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Control\Terminal Server\DefaultUserConfiguration
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	Software\Microsoft\Windows NT\CurrentVersion\Perflib
HKLM\System\CurrentControlSet\Control\SecurePipeServers\Winreg\AllowedPaths	Machine	System\CurrentControlSet\Services\SysmonLog

(2.80) 1434 Status of the 'Network access: Restrict anonymous access to Named Pipes and Shares' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Anonymous access to Named Pipes and Shares' setting defines which Named Pipes can be accessed remotely, without authentication between two processes. As these processes may/may not be on the same system, with a communications model that is peer-to-peer, not client-server and has few security protections, this should be set according to the needs of the business. NOTE: This setting must be enabled for 'Network Access: Named pipes that can be accessed anonymously' or 'Network Access: Shares that can be accessed anonymously' to have any effect.

This Integer value X indicates the current status of the setting Network access: Restrict anonymous access to Named Pipes and Shares using the registry key path HKLM\System\CurrentControlSet\Services\LanManServer\Parameters\RestrictNullSessAccess. A value of 0 indicates the setting is disabled. A value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	RestrictNullSessAccess	0

(2.81) 5210 Status of the 'Network Access: Shares that can be accessed anonymously' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

Named Pipes' ACLs control access to network-based shares on a system. The 'Network Access: Shares that can be accessed anonymously' setting indicates the list of shares allowing null connection access. While shares can be opened up to the 'Everyone' group, this would not include the 'null' (unauthenticated) user. By adding a specific share name to this list, it could allow null connections access to the share; however, NTFS restrictions on the share could still apply. As null connections are a security risk, especially at the perimeter, this should be disabled/restricted appropriate to business needs. Note: This setting can be set by using the registry key/value at location - HKLM\System\CurrentControlSet\Services\LanManServer\Parameters (NullSessionShares).

The following List String value(s) X indicate the current contents of the Network access: Shares that can be accessed anonymously setting defined within the HKLM\System\CurrentControlSet\Services\LanManServer\Parameters (NullSessionShares) registry key.

Expected	**does not contain regular expression list**
	[A-Za-z0-9]
	OR, any of the selected values below:
	☑ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\LanManServer\Parameters	NullSessionShares	

(2.82) 1386 Status of the 'Network Access: Sharing and security model for local accounts' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Access: Sharing and security model for local accounts' setting determines how user privileges will be treated after network-based logons (using local account privileges) are authenticated. If the mode is set to 'Classic,' network-based logons that rely on local-account credentials will authenticate and be authorized via those local credentials. If set to 'Guest only,' network-based logons that would otherwise use, map, and authorize users according to local-account privileges are mapped instead to the 'Guest' account. As this setting can impede/restrict the activities of remote users who log onto domain-based workstations with 'local accounts,' by reducing the user's capability both for doing work and potentially for reducing harmful behavior, this should be set as appropriate to the business environment.

This Integer value X indicates the current status of the Network access: Sharing and security model for local accounts security setting from the HKLM\System\CurrentControlSet\Control\Lsa /ForceGuest registry key. A value of 1 indicates the option is set to the ForceGuest model (presents the simplified file security settings); a value of 0 indicates the option is set to Classic Sharing model (default).

Expected	**any of the selected values below:**
	☑ Classic - local users authenticate as themselves(0)
	☐ Guest only - local users authenticate as Guest(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Classic - local users authenticate as themselves (0)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	ForceGuest	0

(2.83) 5266 Status of the 'Network security: Allow Local System to use computer identity for NTLM' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network security: Allow Local System to use computer identity for NTLM' setting permits services that operate as Local System using the Negotiate method to use the computer's identity for authentication. In some instances, this could result in requests for authentication to fail between some Windows-based systems and send error messages to the logs. When this setting is not configured, such services will authenticate anonymously as was normal behavior in earlier versions of Windows. For Windows 7 or 2008 R2 systems connecting to Vista or 2008 systems, a NULL session will be used which employs a system-generated session key providing no protection whereas the computer identity method allows for signing and encryption. As with all security settings on critical devices, or those that process and/or store sensitive data, this should be set in accordance with organizational requirements and expectations.

The following List Integer value(s) X indicate the current status of the Network Security: Allow Local System to use computer identity for NTLM setting defined by the HKLM\System\CurrentControlSet\Control\Lsa\UseMachineID registry key. The resulting values indicate 0 for Disable and 1 for Enable.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	UseMachineID	

(2.84) 5265 Status of the 'Network security: Allow LocalSystem NULL session fallback' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network security: Allow LocalSystem NULL session fallback' setting determines the values a service will use on Windows systems to establish connections to a variety of Windows-based systems. When enabled, this setting will permit the use of system-generated keys for NULL sessions which could allow sensitive data to be exposed in transit, therefore, should be set in accordance with the requirements and expectations of the business. Note: If required to do so, you can reduce the risk level by using this setting in conjunction with the 'Network setting: Allow Local System to use computer identity for NTLM' (CID 5266) to allow for the use of the machine identity for Local System to protect data in transit with a well-known key.

The following List Integer value(s) X indicate the status of the Network Security: Allow LocalSystem NULL Session Fallback setting defined within the HKLM\System\CurrentControlSet\Control\Lsa\MSV1_0\allownullsessionfallback registry key. The resulting values indicate are: 0 for Disable and 1 for Enable.

Expected **matches list**

Disabled (0)

OR, any of the selected values below:

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa\MSV1_0	allownullsessionfallback	

(2.85) 5267 Status of the 'Network security: Allow PKU2U authentication requests to this computer to use online identities' setting **Failed** **CRITICAL**

The 'Network security: Allow PKU2U authentication requests to this computer to use online identities' setting is used to manage User IDs from authenticating to the system from the Internet via the PKU2U protocol. However, the use of this capability does not have any impact on the use of Domain/Local account authentication. As this capability may be a useful feature on systems that do not store or process sensitive or protected data, it certainly increases the threat landscape for those that do and should be configured in compliance with organizational requirements and expectations. Note: This setting can be set by using registry key/value at location - HKLM\System\CurrentControlSet\Control\Lsa\pku2u (AllowOnlineID).

The following List Integer value(s) X indicate the current status of the Network Security: Allow PKU2U authentication requests to this computer setting defined within the HKLM\System\CurrentControlSet\Control\Lsa\pku2u\AllowOnlineID registry key. The resulting values indicate 0 for Disable and 1 for Enable.

Expected	**matches list**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa\pku2u	AllowOnlineID	

(2.86) 8231 Configure 'Network Security:Configure encryption types allowed for Kerberos' **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The Network security: Configure encryption types allowed for Kerberos settings determines the encryption types that the Kerberos protocol is allowed to use. As encryption will not be enabled this is not set, it should be configured according to the needs of the business.

This Integer value X indicates the status of the service Network Security: Configure encryption types allowed for Kerberos using registery key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\Kerberos\Parameters\SupportedEncryptionTypes. A value of 0 indicates the setting is not Configured; a value of 1 indicates the setting is set to DES_CBC_CRC; a value of 2 indicates the setting is set to DES_CBC_MD5; a value of 4 indicates the setting is set to RC4_HMAC_MD5; a value of 8 indicates the setting is set to AES_128_HMAC_SHA1; a value of 16 indicates the setting is set to AES_256_HMAC_SHA1.

Expected	**any of the selected values below:**
	☐ Not Configured(0)
	☐ DES_CBC_CRC(1)
	☐ AES_256_HMAC_SHA1(16)
	☐ DES_CBC_MD5(2)
	☐ Future encryption types(2147483616)
	☐ All encryption types(2147483647)
	☐ Key not found
	☐ RC4_HMAC_MD5(4)
	☐ AES_128_HMAC_SHA1(8)
	☐ RC4_HMAC_MD5 and AES_128_HMAC_SHA1(12)
	☐ RC4_HMAC_MD5 and AES_256_HMAC_SHA1(20)
	☐ AES_128_HMAC_SHA1 and AES_256_HMAC_SHA1(24)
	☐ RC4_HMAC_MD5 and AES_128_HMAC_SHA1 and AES_256_HMAC_SHA1(28)
	☐ AES_128_HMAC_SHA1 and AES_256_HMAC_SHA1 and Future encryption types(2147483640)
	☑ RC4_HMAC_MD5 and AES_128_HMAC_SHA1 and AES_256_HMAC_SHA1 and Future encryption types(2147483644)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value

HKLM\SOFTWARE\Microsoft\Windows\ CurrentVersion\Policies\System\Kerberos\ Parameters	SupportedEncryptionTypes	

(2.87) 1164 Status of the 'Network Security: Do not store LAN Manager password hash value on next password change' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Network Security: Do not store LAN Manager password hash value on next password change' setting prevents LM password hashes from being stored on the system. Upon enabling this setting, you may want to force all user's to change their passwords as the hash values are not automatically deleted. (All pre-existing password hash values will remain in place until they have been cycled AFTER this setting has been enabled.) Also, when this setting is enabled on a member server or workstation, only the local SAM accounts will be protected on that system. To prevent Active Directory from allowing these hash values to be stored for domain accounts, use the Default Domain Controllers Group Policy Object. As enabling this setting should enhance the security baseline unless legacy issues require support for pre-Windows NT systems, this parameter should be restricted/set according to the needs of the business.

This Integer value X indicates the current status of the Network Security: Do not store LAN Manager password hash value on next password change setting for the HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\NoLMHash registry key. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\Lsa	NoLMHash	1

(2.88) 4469 Status of the 'Windows Network Access: Force logoff when logon hours expire' setting **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Windows Network Access: Force logoff when logon hours expire' setting is responsible for determining whether user's connected to local computer's outside the predetermined logon hours for the account should be disconnected from the SMB connection with the server. Whenever this policy is set to 'disabled,' an account that has already established a connection can continue to be connected beyond the predetermined hours defined. Run this check periodically to ensure security settings are configured and operating correctly to achieve the intended result for your security baseline requirements.

This Integer value X indicates the current status of the service Network Security: Force logoff when logon hours expire using the configuration setting Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Force logoff when logon hours expire. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Object Path
Computer Configuration\Windows Settings\Security Settings\Local Policies\Security Options\Network security: Force logoff when logon hours expire

(2.89) 1387 Status of the 'Network Security: LAN Manager Authentication Level' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

This check provides the current status of the 'Network Security: LAN Manager Authentication Level' setting. The earliest Windows network-based authentication scheme, 'LanManager' (LM), designed for Windows for Workgroups 3.11, can be easily broken by software available on the Internet. MS has responded over the years by creating more secure authentication protocols, with the strongest being 'NT LanManager, Version 2' (NTLM v2). The most secure setting, as specified by the manufacturer for all OS versions 'Win2K' and above, is to use 'Send NTLMv2 response only.' When there are no Win95/98 hosts on the network, LM can be superseded by NTLM (version 1); if no hosts below Win2K exist, such as Windows NT4.0 server/workstation, NTLM version 2 can be used exclusively, with both LM and NTLM deprecated, so this value should be set as appropriate to the needs of the business.

The following Integer value X indicates the current status of the Network security: LAN Manager Authentication Level setting from the registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\LmCompatibilityLevel.

Expected	**any of the selected values below:**
	☐ Send LM & NTLM responses(0)
	☐ Send LM and NTLM - use NTLMv2 session security if negotiated(1)
	☐ RegSubKey not found
	☐ Send NTLM response only(2)
	☐ Send NTLMv2 response only(3)
	☐ Key not found
	☐ Send NTLMv2 response only. Refuse LM(4)
	☑ Send NTLMv2 response only. Refuse LM and NTLM(5)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Lsa	LmCompatibilityLevel	

(2.90) 1388 Status of the 'Network Security: LDAP client signing requirements' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

One of the major shifts in user management has been to use the 'LDAP' (Lightweight Directory Access Protocol) model for extending the Windows OS into a truly extensible 'enterprise' account manager. The 'Network Security: LDAP client signing requirements' setting allows for requiring signing for LDAP communication, (requires specific configuration of the client and server) ensuring that the two systems' communications have been mutually authenticated, by using SSL/TLS 'LDAP signature' identification on the packets. As this security measure can prevent a malicious user from impersonating a secure host and carrying out 'man-in-the-middle' (MITM) attacks, it should be implemented as appropriate to the business need. NOTE: The 'Require Signing' setting can cause communication between server and client to fail if the two are not properly configured. Careful testing is strongly recommended before applying this to a Production environment.

This Integer value X indicates the current startup type of the LDAP Client Signing Requirements service from the HKLM\System\CurrentControlSet\Services\LDAP\LDAPClientIntegrity registry key. A value of 2 indicates the service is set to Require LDAP signing; a value of 1 indicates the service is set to Negotiate LDAP signing; a value of 0 indicates the service is set to No LDAP signing.

Expected	**any of the selected values below:**
	☐ None(0)
	☑ Negotiate signing(1)
	☑ Require signing(2)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Negotiate signing (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\LDAP	LDAPClientIntegrity	1

(2.91) 1389 Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) clients' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

This check provides the current status of the 'Network Security: Minimum session security for NTLM SSP based (including

secure RPC) clients' setting. Remote Procedure Call (RPC) provides a way for a remote user to execute an operation on the system as if sitting at the console. This can allow a malicious user to initiate RPC-based attacks that focus on 'privilege escalation.' By requiring message integrity, confidentiality, session security and high-strength encryption for clients, the problems with weak authentication that have made RPC vulnerable to 'man-in-the-middle' attacks can be overcome, so these should be deployed on the Client as appropriate to the needs of business. NOTE: The recommendation is to use Message Integrity, Message Confidentiality, NTLMv2 Session Security, and 128-bit Encryption: all these settings must be used together for the complete security process to be successful. (See MS-KB 239869)

This Integer value X indicates the current status of the security standards set for Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' using the registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\NTLMMinClientSec. A value of 16 indicates it is set to Require Message Integrity; A value indicates 32 it is set to Req Message Confidentiality; A value of 524288 indicates the setting is set toRequire NTLMv2 Session Security; A value of 536870912 indicates the setting is set to Require 128-bit encryption, A value of 537395248 indicates it is combined with all prior settings. NOTE: The final value for having NTLMv2 and 128-bit encryption set for post-Vista OSes is 537395200.

Expected **any of the selected values below:**

- ☐ No requirements(0)
- ☐ Key not found
- ☐ Require NTLMv2 session security(524288)
- ☐ Require 128-bit encryption(536870912)
- ☑ Combined settings(537395200)

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Require 128-bit encryption (536870912)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0	ntlmminclientsec	536870912

(2.92) 1390 Status of the 'Network Security: Minimum session security for NTLM SSP based (including secure RPC) servers' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

This check provides the current status of the 'Minimum session security for NTLM SSP based (including secure RPC) servers' setting. Remote Procedure Protocol (RPC) provides a way for a remote user to execute an operation on the system as if sitting at the console; this can allow a malicious user to initiate RPC-based attacks that focus on 'privilege escalation.' By requiring message integrity, confidentiality, session security and high-strength encryption for clients, the problems with weak authentication that have made RPC vulnerable to 'man-in-the-middle' attacks can be overcome, so these should be deployed on the Server as appropriate to the business' need. NOTE: The recommendation is to use NTLMv2 Session Security, and 128-bit Encryption: These two settings must be used together for the complete security process to be successful. (See MS-KB 239869)

This Integer value X indicates the current status of the setting Network security: Minimum session security for NTLM SSP based (including secure RPC) servers Using the registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Lsa\MSV1_0\NTLMMinServerSec . A value of 16 indicates it is set to Require Message Integrity; A value indicates 32 it is set to Req Message Confidentiality; A value of 524288 indicates the setting is set toRequire NTLMv2 Session Security; A value of 536870912 indicates the setting is set to Require 128-bit encryption, A value of 537395248 indicates it is combined with all prior settings. NOTE: The final value for having NTLMv2 and 128-bit encryption set for post-Vista OSes is 537395200.

Expected **any of the selected values below:**

- ☐ No requirements(0)
- ☐ Key not found
- ☐ Require NTLMv2 session security(524288)
- ☐ Require 128-bit encryption(536870912)
- ☑ Combined settings(537395200)

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Require 128-bit encryption (536870912)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\Lsa\MSV1_0	ntlmminserversec	536870912

(2.93) 1391 Status of the 'Recovery Console: Allow Automatic Administrative Logon' setting **Passed** **CRITICAL**

This check provides the current status of the 'Recovery Console: Allow Automatic Administrative Logon' setting. During the boot process on a Domain Controller, the 'Recovery Console' option allows the repair of Active Directory errors; this recovery capability can be set to require a password for use. As requiring a password to access administrative privileges at the command line in the Recovery Console can help defend against a malicious user with physical access to the system and command-line skills, who could add his/her logon to a privileged group, this should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting Recovery console: Allow automatic administrative logon using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Setup\RecoveryConsole\securitylevel. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Setup\RecoveryConsole	SecurityLevel	0

(2.94) 1392 Status of the 'Recovery console: Allow floppy copy and access to all drives and all folders' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

This check provides the current status of the 'Recovery console: Allow floppy copy and access to all drives and all folders' setting. During the boot process on a Domain Controller, the 'Recovery Console' option allows the repair of Active Directory errors; this recovery capability can be set to permit use of a floppy disk/CD-RW and granting it read/write access to all local HDD during Recovery Console use. As this capability could allow the copying of sensitive information from the local HDD to write-capable, as well as permit the insertion of malware onto the %SystemDrive%, potentially creating a backdoor to the OS, these permissions should be restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting Recovery console: Allow floppy copy and access to all drives and all folders using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Setup\RecoveryConsole\setcommand . A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Setup\RecoveryConsole	SetCommand	0

(2.95) 1369 Status of the 'Shutdown: Allow system to be shut down without having to log on' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Shutdown: Allow system to be shut down without having to log on' setting permits anyone with physical access to the console to shut down the system without entering logon credentials. As host shutdown without valid credentials could lead to a DoS condition, followed by the potential to load malicious code via a flash drive or CD-ROM during the reboot process, this should be disabled or restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting Shutdown: Allow system to be shut down without having to log on using the registry path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ShutdownWithoutLogon. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	ShutdownWithoutLogon	0

(2.96) 1188 Status of the 'System objects: Require case insensitivity for non-Windows subsystems' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

This check provides the current status of the 'System objects: Require case insensitivity for non-Windows subsystems' setting. Because Windows is case-insensitive, but a POSIX subsystem will support case sensitivity, failure to enable this policy setting would make it possible for a user of that subsystem to create a file with the same name as another file, but with a different mix of upper and lower case letters. As this situation could potentially confuse users when they try to access such files from normal Win32 tools, because only one of the files will be available, this should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting System objects: Require case insensitivity for non-Windows subsystems using the registry key pathHKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager\Kernel\ObCaseInsensitive. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Session Manager\Kernel	ObCaseInsensitive	1

(2.97) 1426 Status of the 'System objects: Strengthen default permissions of internal system objects' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'System objects: Strengthen default permissions of internal system objects' setting governs access permissions on system objects, such as shared physical and logical resources, including semaphores and DOS device names. As these can be more easily compromised if not sufficiently protected, access permissions should be set as appropriate to the business need.

This integer value X indicates the status of the setting System objects: Strengthen default permissions of internal system objects using the configurtaion path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Session Manager\ProtectionMode. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found

	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Control\Session Manager	ProtectionMode	1

(2.98) 2586 Status of the 'User Account Control: Admin Approval Mode for the Built-in Administrator account' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'User Account Control: Admin Approval Mode for the Built-in Administrator account' setting determines whether or not the Built-in Administrator account will logon to the system in Admin Approval Mode. When this setting is enabled, the Built-in Administrator account will logon to the system in Admin Approval Mode. Admin Approval Mode forces the system to prompt the administrator for consent when an operation requiring privilege elevation is requested. When this setting is disabled, the Built-in Administrator account will logon to the system in Windows XP compatible mode and the account will be granted full administrative privileges. NOTE: Consider implementing this control in conjunction with CID 2583 and CID 2587.

This Integer value X indicates the current status of the setting User Account Control: Admin Approval Mode for the Built-in Administrator account, using the registry key HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\FilterAdministratorToken. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	FilterAdministratorToken	0

(2.99) 3939 Status of the 'Allow UIAccess applications to prompt for elevation without using the secure desktop' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'Allow UIAccess applications to prompt for elevation without using the secure desktop' setting determines whether or not an application is able to go to an 'elevated privilege' status without going through the secure desktop--this may occur when the local user requests remote, interactive help. As allowing elevation without the secure desktop can expose the local user's home directory to the remote user, potentially allowing the release of confidential information, this capability should be set according to the needs of the business. Note: This setting can be set by using the registry key/value at location - HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System (EnableUIADesktopToggle).

This Integer value X indicates the current status of the Allow UIAccess applications to prompt for elevation without using the secure desktop policy in the HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System (EnableUIADesktopToggle) Registry key.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (0)

Extended Evidence:

Key	Name	Value

HKLM\SOFTWARE\Microsoft\Windows\ CurrentVersion\Policies\System	EnableUIADesktopToggle	0

(2.100) 2587 Status of the 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' setting determines how requests for an elevation in privileges by Administrators are handled. When an Administrator account logs into a Windows Vista, or later, operating environment, it is done in Protected [Administrator] Mode status. For certain tasks and actions to be performed on the system, the Administrator account will need to be placed into Elevated [Administrator] Mode. The act of going from Protected Mode to Elevated Mode can be configured by this setting to require credentials to be input or have no interaction to be required at all. When this is set to allow elevations in privileges to occur without any user interaction, it increases the likelihood that malware requiring to be run with Administrative privileges will be capable of executing its payload on the system without hindrance. Therefore, the risk associated with this setting should be considered and set in accordance with the needs and requirements of the business.

The following Integer value X indicates the current status of the setting User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ ConsentPromptBehaviorAdmin. A value of 0 indicates the setting is Elevate without prompting, A value of 1 indicates the setting is Prompt for credentials on the secure desktop, A value of 2 indicats the setting is Prompt for consent on the secure desktop, A value of 3 indicated the setting is Prompt for credentials, A value of 4 indicates the setting is Prompt for consent, A value of 5 indicates the setting is Prompt for consent for non-Windows binaries.

Expected	**any of the selected values below:**
	☐ Elevate without prompting(0)
	☐ Prompt for credentials on the secure desktop(1)
	☑ Prompt for consent on the secure desktop(2)
	☐ Prompt for credentials(3)
	☐ Key not found
	☐ Prompt for consent(4)
	☐ Prompt for consent for non-Windows binaries(5)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Prompt for consent for non-Windows binaries (5)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	ConsentPromptBehaviorAdmin	5

(2.101) 2605 Status of the 'User Account Control: Behavior of the elevation prompt for standard users' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'User Account Control: Behavior of the elevation prompt for standard users' setting determines how the system will display elevation prompts to standard users. Windows Vista uses User Account Control elevation to prompt the user for credentials or consent when a system operation requires administrative rights. This policy setting has two possible configurations that affect elevation requests: 1) Prompt for credentials - when this setting is enabled the user is prompted to provide administrator credentials in order for the operation to continue. 2) Automatically deny elevation requests - when this setting is enabled the system will not perform the requested operation and the user is presented with an access denied error message.

This Integer value X indicates the current status of the setting User Account Control: Behavior of the elevation prompt for standard users in the HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\ConsentPromptBehaviorUser registry key.

Expected	**equal to**
	Automatically deny elevation requests (0)
	OR, any of the selected values below:
	☑ Automatically deny elevation requests(0)
	☐ Prompt for credentials on the secure desktop(1)
	☐ Prompt for credentials(3)
	☐ Key not found

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Prompt for credentials (3)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	ConsentPromptBehaviorUser	3

(2.102) 2582 Status of the 'User Account Control: Detect application installations and prompt for elevation' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:08 (GMT+0500)

The 'User Account Control: Detect application installations and prompt for elevation' setting determines whether or not the user is presented with an elevation prompt when Windows Vista detects an installation application. When this setting is enabled, Windows Vista uses heuristic detection to identify installation applications. When Windows detects an installation application, the user is prompted for credentials or consent through an elevation prompt. When this setting is disabled, installation applications are prevented from running and the user is presented with a notification error message.

This Integer value X indicates the current status of the setting User Account Control: Detect application installations and prompt for elevation HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\System\EnableInstallerDetection using the registry key path. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	EnableInstallerDetection	1

(2.103) 2584 Status of the 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' setting determines whether or not the system will elevate applications that use a UIAccess integrity level check when requesting execution. When this setting is enabled, applications are permitted to launch with UIAccess integrity only if they reside in secure system folders. When this setting is disabled, applications are permitted to launch with UIAccess integrity regardless of their location in the file system. Restricting which applications are permitted to run with elevated permissions can reduce the risk of a malicious user gaining inappropriate access and/or control.

This Integer value X indicates the current status of the setting User Account Control: Only elevate UIAccess applications that are installed in secure locations using the registry key path HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v EnableSecureUIAPaths. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**equal to**
	Enabled (1)
	OR, any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	EnableSecureUIAPaths	1

(2.104) 2583 Status of the 'User Account Control: Run all administrators in Admin Approval Mode' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'User Account Control: Run all administrators in Admin Approval Mode' setting determines whether or not the system will prompt consent or credentials when an administrative operation is requested. When this setting is enabled, users and administrators are prompted for consent or credentials (depending on other Group Policy settings). When this setting is disabled, both the Windows Vista User Account Control functionality and Application Information Service are disabled. As disabling the functionality of User Account Control presents an attack surface that could allow a malicious user to gain inappropriate access and/or control, this setting should be enabled as appropriate to the needs of the business. NOTE: Consider implementing this control in conjunction with CID 2582, CID 2586, CID 2587, CID 2603, CID 2605, CID 2606.

This Integer value X indicates the current status of the User Account Control: Run all administrators in Admin Approval Mode Using the registry key path HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v EnableLUA, A value of 0 indicates the setting is Disabled; A value of 1 indicates the setting is Enabled.

Expected **equal to**

Disabled (0)

OR, any of the selected values below:

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	EnableLUA	1

(2.105) 2606 Status of the 'User Account Control: Switch to the secure desktop when prompted for elevation' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'User Account Control: Switch to the secure desktop when prompted for elevation' setting determines whether or not the system will switch to Secure Desktop when an executable file requests permission elevation. The Secure Desktop functionality changes the interactive user desktop into a secure 'alpha-blended bitmap' display in order to present the permission elevation prompt to the user. When this setting is enabled, the system will switch to the Secure Desktop for all elevation requests. When this setting is disabled, all elevation requests will be presented through the interactive user desktop. This functionality is designed to prevent malware from imitating the secure desktop by 'painting over' the interactive user desktop.

This Integer value X indicates the current status of the setting User Account Control: Switch to the secure desktop when prompting for elevation Using the registry key path HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v PromptOnSecureDesktop. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **equal to**

Enabled (1)

OR, any of the selected values below:

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	PromptOnSecureDesktop	1

(2.106) 3940 Status of the 'User Account Control: Virtualize file and registry write failures to per-user locations' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Virtualize file and registry write failures to per-user locations' setting will determine whether or not the recording of system 'failure' notifications will be directed to a predefined file-system/registry location. As this setting can help mitigate risks that may occur when run-time data is written to sensitive file and registry areas, this capability should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting User Account Control: Virtualize file and registry write failures to per-user locations using the registry key path HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System /v EnableVirtualization. A value of 0 indicates the policy is set to disabled; a value of 1 indicates the policy is set to enabled.

Expected **equal to**

Enabled (1)

OR, any of the selected values below:

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System	EnableVirtualization	1

3. Windows Firewall With Advanced Security

(3.1) 3952 Status of the 'Windows Firewall: Firewall state (Domain)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Firewall state (Domain)' setting identifies the Domain firewall profile is currently active. Examples of firewall profiles are 'Domain Profile is Active, Public Profile is Active, or Private Profile is Active. As enabling a firewall can reduce the number of potential number of network-based attack vectors, while expecting a locally trusted network to be secure enough to relax firewall standards can increase system vulnerability, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Firewall state using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\EnableFirewall. A value of 0 indicates the setting is set to Off, A value of 1 indicates the setting is set to On.

Expected **any of the selected values below:**

- ☐ Off(0)
- ☑ On(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Off (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\DomainProfile	EnableFirewall	0

(3.2) 3949 Status of the 'Windows Firewall: Inbound connections (Domain)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Inbound connections (Domain)' setting enables the operation of Windows Firewall 'Domain' profile setting, to allow domain selection of specific, permitted inbound connections for this system. As enabling a firewall can reduce the number of potential number of network-based attack vectors, while excessive rule-sets can block necessary connections, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Inbound connections (Domain) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DefaultInboundAction. A value of 0 indicates the setting is set to Allow, A value of 1 indicates the setting is set to Block.

Expected	**equal to**
	Block (1)
	OR, any of the selected values below:
	☐ Allow(0)
	☑ Block(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\DomainProfile	DefaultInboundAction	

(3.3) 8158 Status of the 'Windows Firewall: Allow Outbound connections (Domain)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

'The Windows Firewall: Outbound connections (Domain)' setting determines the behavior for outbound connections that do not match an outbound firewall rules. Denying Outbound connections for domain will cause users to deal with popups to authorize or block their applications, it should be used according to the needs of the business

The following Integer value(s) X indicates the current status of the setting Windows Firewall: Domain: Outbound connections using the registry key HKLM\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DefaultOutboundAction. A value of 0 indicates the setting is set to Allow, A value of 1 indicates the setting is set to Block.

Expected	**equal to**
	Allow (0)
	OR, any of the selected values below:
	☑ Allow(0)
	☐ Block(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\DomainProfile	DefaultOutboundAction	

(3.4) 3962 Status of the 'Windows Firewall: Display a notification (Domain)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Windows Firewall: Display a notification (Domain)' setting generates a user alert, showing that an exception is being added to a firewall policy by some application's activity. As adding an exception may increase the potential for a malware attack or unauthorized user entry, this capability should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Display a notification (Domain) using the registry key pathHKLM\Software\Policies\Microsoft\WindowsFirewall\DomainProfile /v DisableNotifications. A value of 0 indicates the policy is set to yes; a value of 1 indicates this policy is set to no.

Expected	**equal to**
	Yes (0)

	OR, any of the selected values below:
	☑ Yes(0)
	☐ No(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile	DisableNotifications	

(3.5) 8157 Status of the 'Windows Firewall: Allow unicast response (Domain)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The ‘Windows Firewall: Allow unicast response (Domain)' setting specifies whether to accept or discard the unicast packe ts sent in response to a multicast or broadcast request. As allowing this type of response facilitate attacks via malici ous payloads, this capability should be restricted according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Allow unicast response using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\DisableUnicastResponsesToMulticastBroadcast. A value of 0 indicates the setting is set to Yes, A value of 1 indicates the setting is set to No.

Expected	**equal to**
	No (1)
	OR, any of the selected values below:
	☐ Yes(0)
	☑ No(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile	DisableUnicastResponsesToMulticastBroadcast	

(3.6) 3945 Status of the 'Windows Firewall: Apply local firewall rules (Domain)' policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Apply local firewall rules (Domain)' policy setting enables local administrators to create local firewall rules that apply along with firewall rules set by Group policy. As this setting can affect overall security configurations locally, this should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Apply local firewall rules (Domain) using the registry key path HKLM\ Software\Policies\Microsoft\WindowsFirewall\DomainProfile /v AllowLocalPolicyMerge. A value of 0 indicates the policy is set to no; a value of 1 indicates this policy is set to yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile	AllowLocalPolicyMerge	

(3.7) 3961 Status of the 'Windows Firewall: Apply local connection security rules (Domain)' setting Failed CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Apply local connection security rules (Domain)' setting enables domain-based connection rules that govern IPSec connections. As this setting enables or restricts local administrative users from creating such local connection rules in addition to the connection security rules in Group Policies, which will increase the exposure of the system to remote attacks, this should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Apply local connection security rules using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\AllowLocalIPsecPolicyMerge. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected **equal to**

Yes (1)

OR, any of the selected values below:

- [ ] No(0)
- [x] Yes(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile	AllowLocalIPsecPolicyMerge	

(3.8) 1525 Status of the 'Windows Firewall: Log file path and name (Domain)' setting Failed SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Log file path and name (Domain)' setting allows specification of the exact path/filename for the Windows Firewall log file on the system, as required by the domain profile. As this will allow logging/tracking of rejected/ dropped packets in a log file, allowing for a later security review, this value should be set as appropriate to the needs of the business. (See CID-1523 regarding specific traffic to be logged.)

This Integer value X indicates the current status of the setting Domain Profile -- Log file path and name using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFilePath.

Expected **regular expression match**

\%SYSTEMROOT\%\\System32\\logfiles\\firewall\\domainfw\.log

OR, any of the selected values below:

- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile\Logging	LogFilePath	

(3.9) 1526 Status of the 'Windows Firewall: Log File Size (Domain)' setting Failed SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Log File Size (Domain)' setting will determine how much of the firewall activity is captured before the text is overwritten by more recent items. The Manufacturer recommends 4096KB (4 Megabytes), as a minimum, which should be enough to capture one (or more) day's worth of events, to allow backtracking of the audit trail should a system become infected by malware, or taken over by a malicious user. As this setting determines how much log information is saved, this value should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Logging: Size limit (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogFileSize.

Expected	**greater than or equal to**
	16384
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile\Logging	LogFileSize	

(3.10) 1524 Status of the 'Windows Firewall: Log dropped packets (Domain)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Log dropped packets (Domain)' setting will allow logging/tracking of rejected/dropped packets in a log file, allowing for a later security review. As it can be useful to understand know what sort of traffic is being discarded, to see if repeating patterns appear, which can indicate recurring exploit attempts, this capability should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Logging: Log dropped packets using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogDroppedPackets. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile\Logging	LogDroppedPackets	

(3.11) 1527 Status of the 'Windows Firewall: Log Successful Connections (Domain)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Log Successful Connections (Domain)' setting enables logging of all successful connections, to allow the tracking of all activity of network origin that could potentially affect the system. As this would provide an audit trail in case of a breach, this value should be set as appropriate to the needs of the business. NOTE: This setting has the potential to generate log files which may exceed the CIS-recommended maximum of 4096KB.

This Integer value X indicates the current status of the setting Windows Firewall: Domain: Logging: Log successful connections using the registry key path KEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\DomainProfile\Logging\LogSuccessfulConnections. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\DomainProfile\Logging	LogSuccessfulConnections	

(3.12) 3951 Status of the 'Windows Firewall: Firewall state (Private)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Firewall state (Private)' enables the operation of Windows Firewall as specified by the settings for this system on a 'home' or otherwise 'trusted' network. As enabling a firewall can reduce the number of potential number of network-based attack vectors, while expecting a locally trusted network to be secure enough to relax firewall standards can increase system vulnerability, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Firewall state using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\EnableFirewall. A value of 0 indicates the setting is set to Off, A value of 1 indicates the setting is set to On.

Expected	**equal to**
	On (1)
	OR, any of the selected values below:
	☐ Off(0)
	☑ On(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile	EnableFirewall	

(3.13) 8159 Status of the 'Windows Firewall: Outbound connections (Private)' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Outbound connections (Private)' policy setting determines if outbound connections match an outbound firewall rule for the 'Private' connection. As default outbound connections are allowed unless there is/are blocking firewall rule(s) this should be configured according to the business..

This Integer value X indicates the current status of the settingWindows Firewall: Private: Outbound connections using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DefaultOutboundAction. A value of 0 indicates the setting is set to Allow connections, A value of 1 indicates the setting is set to Block connections.

Expected	**equal to**
	Allow (0)
	OR, any of the selected values below:
	☑ Allow(0)
	☐ Block(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile	DefaultOutboundAction	

(3.14) 3964 Status of the 'Windows Firewall: Display a notification (Private)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Windows Firewall: Display a notification (Private)' setting generates a user alert, showing that a block was generated by a firewall policy due to some application/external user activity. As a policy exception added by an application may increase the potential for a malware attack or unauthorized user entry, this capability should be configured according to the

needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Display a notification using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DisableNotifications. A value of 0 indicates the setting is set to Yes, A value of 1 indicates the setting is set to No.

Expected	**equal to**
	Yes (0)
	OR, any of the selected values below:
	☑ Yes(0)
	☐ No(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile	DisableNotifications	

(3.15) 5261 Status of the 'Windows Firewall: Allow unicast response (Private)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Allow unicast response (Private)' setting determines whether unicast responses to the local system's outbound broadcast/multicast messages will be permitted or blocked. By blocking these types of responses, you can reduce the risk of attack by malformed ICMP packets. Note: This setting can be set using the registry key/value location - HKLM\SOFTWARE\Policies\Microsoft\WindowsFirewall\PrivateProfile (DisableUnicastResponsesToMulticastBroadcast).

This List Integer value(s) X indicate the current status of the setting Windows Firewall: Private: Allow unicast response using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DisableUnicastResponsesToMulticastBroadcast. A value of 0 indicates the setting is set to Yes, A value of 1 indicates the setting is set to No.

Expected	**matches list**
	No (1)
	OR, any of the selected values below:
	☐ Yes(0)
	☑ No(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\ WindowsFirewall\PrivateProfile	DisableUnicastResponsesToMulticastBroadcast	

(3.16) 3959 Status of the 'Windows Firewall: Apply local firewall rules (Private)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Apply local firewall rules (Private)' setting determines whether or not a local user with administrative privileges is allowed to create a firewall rule-set that may open potentially dangerous ports. As allowing this capability may expose network-based attack vectors on the system, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Apply local firewall rules using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\AllowLocalPolicyMerge. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)

Yes(1)

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile	AllowLocalPolicyMerge	

(3.17) 3963 Status of the 'Windows Firewall: Apply local connection security rules (Private)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Status of the 'Windows Firewall: Apply local connection security rules (Private)' setting enables or disables the ability to create and apply Private connection security rules. As this setting grants or restricts users with administrative privileges to create & apply local connection security rules that could endanger the system to remote attacks, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Apply local connection security rules using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\AllowLocalIPsecPolicyMerge. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected **equal to**

Yes (1)

OR, any of the selected values below:

No(0)

Yes(1)

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile	AllowLocalIPsecPolicyMerge	

(3.18) 8161 Status of the 'Windows Firewall: Log file path and name (Private)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Private: Logging: Name' setting is used to specify the size limit of the file in which Windows Firewall will write its log information. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Logging: Name using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogFilePath.

Expected **matches regular expression list**

\%SYSTEMROOT\%\\System32\\logfiles\\firewall\\privatefw\.log

OR, any of the selected values below:

Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile\Logging	LogFilePath	

(3.19) 8160 Status of the 'Windows Firewall: Log File Size (Private)' setting **Failed** **SERIOUS**

The 'Windows Firewall: Log File Size (Private)' setting is used to specify the size limit of the file in which Windows Firewall will write its log information. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Logging: Size limit (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogFileSize.

Expected **greater than or equal to**

16384

OR, any of the selected values below:

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile\Logging	LogFileSize	

(3.20) 8163 Status of the 'Windows Firewall: Log dropped packets (Private)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Private: Logging: Log dropped packets' setting is used to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Logging: Log dropped packets using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogDroppedPackets. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected **equal to**

Yes (1)

OR, any of the selected values below:

☐ No(0)

☑ Yes(1)

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PrivateProfile\Logging	LogDroppedPackets	

(3.21) 8162 Status of the 'Windows Firewall: Log Successful Connections (Private)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Private: Logging: Log successful connections'' setting is used to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Private: Logging: Log successful connections using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging\LogSuccessfulConnections. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected **equal to**

	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\Logging	LogSuccessfulConnections	

(3.22) 3950 Status of the 'Windows Firewall: Firewall state (Public)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Firewall state (Public)' enables the operation of Windows Firewall as specified by the settings for this system on a 'public' or otherwise 'untrusted' network. As enabling a firewall on a Public network can significantly reduce the number of potential network-based attack vectors, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Firewall state (Public) using the registry key path HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile /v EnableFirewall. A value of 0 indicates the policy is set to off; a value of 1 indicates the policy is set to on.

Expected	**equal to**
	On (1)
	OR, any of the selected values below:
	☐ Off(0)
	☑ On(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile	EnableFirewall	

(3.23) 3932 Status of the 'Windows Firewall: Inbound connections (Public)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Inbound connections (Public) setting can determine which inbound network connections are allowed into the system via the public interface configuration. As configuring this setting can potentially block required port entry points as well as reduce the network attack surface, this should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Inbound connections (Public) using the registry key pathHKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile /v DefaultInboundAction. A value of 0 indicates the inbound connection is set to allow; a value of 1 indicates the inbound connection is set to block.

Expected	**equal to**
	Block (1)
	OR, any of the selected values below:
	☐ Allow(0)
	☑ Block(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PublicProfile	DefaultInboundAction	

(3.24) 8164 Status of the 'Windows Firewall: Outbound connections (Public)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Apply local firewall rules (Public)' policy setting determines if local rules for the 'Public' connection will be applied. As local [host] firewall rules can conflict with domain settings that enforce more stringent security rules, this setting should be configured according to the needs of the business.

The following Integer value(s) X indicates the current status of the setting Windows Firewall: Apply local firewall rules (Public) using the registry path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DefaultOutboundAction. The value 0 indicates that the setting is set to allow connections, A value 1 indicates that the setting is set to block connections.

Expected **equal to**

Allow (0)

OR, any of the selected values below:

- [x] Allow(0)
- [ ] Block(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PublicProfile	DefaultOutboundAction	

(3.25) 3965 Status of the 'Windows Firewall: Display a notification (Public)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Windows Firewall: Display a notification (Public)' setting generates a user alert, showing that a block was generated by a firewall policy due to some application/external user activity. As a policy exception added by an application may increase the potential for a malware attack or unauthorized user entry, this capability should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Display a notification (Public) using the registry key pathreg query HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile /v DisableNotifications. A value of 0 indicates the policy is set to yes; a value of 1 indicates this policy is set to no.

Expected **equal to**

Yes (0)

OR, any of the selected values below:

- [x] Yes(0)
- [ ] No(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PublicProfile	DisableNotifications	

(3.26) 5262 Status of the 'Windows Firewall: Allow unicast response (Public)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Allow unicast response (Public)' setting determines whether unicast responses to the local system's outbound broadcast/multicast messages will be permitted or blocked. By blocking these types of responses, you can reduce the risk of attack by malformed ICMP packets. Note: This setting can be set using the registry key-value,

located at HKLM\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile (DisableUnicastResponsesToMulticastBroadcast).

This List Integer value(s) X indicate the current status of the setting Windows Firewall: Public: Allow unicast response using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\DisableUnicastResponsesToMulticastBroadcast. A value of 0 indicates the setting is set to Yes, A value of 1 indicates the setting is set to No.

Expected	**matches list**
	No (1)
	OR, any of the selected values below:
	☐ Yes(0)
	☑ No(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\WindowsFirewall\PublicProfile	DisableUnicastResponsesToMulticastBroadcast	

(3.27) 3960 Status of the 'Windows Firewall: Apply local firewall rules (Public)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The ‘Windows Firewall: Apply local firewall rules (Public)' setting determines if local rules for the 'Public' connectio n will be applied. As local [host] firewall rules can conflict with domain settings that enforce more stringent securit y rules, this setting should be configured according to the business.

This Integer value X indicates the current status of the Windows Firewall: Apply local firewall rules (Public) policy. A value of 0 indicates the policy is set to no; a value of 1 indicates this policy is set to yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile	AllowLocalPolicyMerge	

(3.28) 3966 Status of the 'Windows Firewall: Apply local connection security rules (Public)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Status of the 'Windows Firewall: Apply local connection security rules (Public)' setting enables or disables the ability to create and apply local connection security rules. As this grants or restricts the ability of users with administrative privileges to create & apply local connection security rules, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Apply local connection security rules (Public) using the registry key path HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile /v AllowLocalIPsecPolicyMerge. A value of 0 indicates the policy is set to no; a value of 1 indicates the policy is set to yes.

Expected	**equal to**
	No (0)
	OR, any of the selected values below:
	☑ No(0)
	☐ Yes(1)
	☐ Not configured

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile	AllowLocalIPsecPolicyMerge	

(3.29) 8166 Status of the 'Windows Firewall: Log file path and name (Public)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The "Windows Firewall: Public: Logging: Name" setting is used to specify the path and name of the file in which Windows Firewall will write its log information. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This List String value(s) X indicate the current status of the setting Windows Firewall: Public: Logging: Name using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFilePath.

Expected	**matches regular expression list**
	\%systemroot\%\\system32\\logfiles\\firewall\\publicfw\.log
	OR, any of the selected values below:
	Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging	LogFilePath	

(3.30) 8168 Status of the 'Windows Firewall: Log File Size (Public)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Public: Logging: Size limit (KB)' setting is used to to specify the size limit of the file in which Windows Firewall will write its log information. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

The integer value X indicates the current status of the setting Windows Firewall: Public: Logging: Size limit (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogFileSize.

Expected	**greater than or equal to**
	16384
	OR, any of the selected values below:
	Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging	LogFileSize	

(3.31) 8165 Status of the 'Windows Firewall: Log dropped packets (Public)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The "Windows Firewall: Public: Logging: Log dropped packets" setting is used to log when Windows Firewall with Advanced Security discards an inbound packet for any reason. The log records why and when the packet was dropped. Look for entries with the word DROP in the action column of the log. If events are not recorded it may be difficult or

impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Public: Logging: Log dropped packets using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogDroppedPackets. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PublicProfile\Logging	LogDroppedPackets	

(3.32) 8167 Status of the 'Windows Firewall: Log Successful Connections (Public)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Public: Logging: Log successful connections' setting is used to log when Windows Firewall with Advanced Security allows an inbound connection. The log records why and when the connection was formed. Look for entries with the word ALLOW in the action column of the log. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. It should be used according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Public: Logging: Log successful connections using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PublicProfile\Logging\LogSuccessfulConnections. A value of 0 indicates the setting is set to No, A value of 1 indicates the setting is set to Yes.

Expected	**equal to**
	Yes (1)
	OR, any of the selected values below:
	☐ No(0)
	☑ Yes(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\ WindowsFirewall\PublicProfile\Logging	LogSuccessfulConnections	

(3.33) 3948 Status of the 'Windows Firewall: Inbound connections (Private)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Firewall: Inbound connections (Private)' setting enables the operation of Windows Firewall 'Private' profile setting, to allow user selection of specific, permitted inbound connections for this system. As enabling a firewall can reduce the number of potential number of network-based attack vectors, while excessive rule-sets can block necessary connections, this capability should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Windows Firewall: Inbound connections (Private) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile\DefaultInboundAction. A value of 0 indicates the setting is set to Allow, A value of 1 indicates the setting is set to Block.

Expected	**equal to**
	Block (1)
	OR, any of the selected values below:

	☐ Allow(0)
	☑ Block(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsFirewall\PrivateProfile	DefaultInboundAction	

4. Advanced Audit Policy Configuration

(4.1) 4517 Status of the 'Credential Validation' audit policy setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Credential Validation' security policy setting tracks local and domain accounts credential submission activities during logon requests. Examples of these activities include validations and failures of credentials and confirmed and failed mappings for logon requests. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Credential Validation object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Credential Validation

(4.2) 4511 Status of the 'Application Group Management' security policy setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Application Group Management' security policy setting tracks application group management activities. Examples of these activities are creating, changing, deleting, basic application groups and when members and non-members are added to application groups. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Application Group Management object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)

	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Application Group Management

(4.3) 4508 Status of the 'Computer Account Management' audit policy setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Computer Account Management' audit policy setting tracks activities around managing computer accounts. Examples of these activities include creating, deleting, and modifying computer accounts. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Account Management object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Computer Account Management

(4.4) 4512 Status of the 'Audit Policy: Account Management: Other Account Management Events' audit policy setting — Passed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Other Account Management Events' security policy setting tracks user account management events. Some of these events include access of an account password hash and when a API call is made for Password Policy Checking. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Other Account Management Events object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)

	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Other Account Management Events

(4.5) 4509 Status of the 'Security Group Management' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Security Group Management' security policy setting tracks security group management activities. Some of these activities include creation, modification, deletion, and type changes of the security group. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Security Group Management object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Security Group Management

(4.6) 4507 Status of the 'Audit Policy: Account Management: User Account Management' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'User Account Management' audit policy setting tracks user account management activities. Some of these activities include creating, modifying, and deleting user accounts, password creation or modifications, and backup or restoration of Credential Manager credentials. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the User Account Management object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
User Account Management

(4.7) 4497 Status of the 'Process Creation' audit policy setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Process Creation' audit policy setting tracks events triggered by process creation (start) and the name of the user or application responsible. Some of these events are recorded when a new process is started or when a token is assigned to a new process. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Process Creation object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success (1)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☑ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☐ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	No Auditing (0)

Extended Evidence:

Subcategory
Process Creation

(4.8) 4477 Status of the 'Account Lockout' security policy setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Account Lockout' security policy setting tracks logon failures on locked-out accounts. This type of forensic event information may be useful in detecting or identifying malicious users attempting to crack user account passwords. Repeated failed logon activity on a known account that is disabled could be an indicator that the site is under brute force or other password attack. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\Audit Policies\Logon/Logoff\Audit Policy: Logon-Logoff: Account Lockout object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success (1)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☑ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☐ Success and Failure(3)
	☐ Dissolvable Agent installation failed

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Account Lockout

(4.9) 4476 Status of the 'Audit Policy: Logon-Logoff: Logoff' policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Logoff' security policy setting tracks logoff events. This security policy setting tracks user and account logoff activity. This type of forensic event information may be useful in detecting or identifying malicious users attempting to subvert system security or cause damage to critical systems/data. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\Logon/Logoff\Audit Logoff\Audit Policy: Logon-Logoff: Logoff object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success (1)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☑ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☐ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Logoff

(4.10) 4475 Status of the 'Audit Policy: Logon-Logoff: Logon' policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Logon' security policy setting tracks logon attempts. This security policy setting tracks user logon activity (successful and failed) and Security Identifiers (SIDs). This type of forensic event information may be useful in detecting or identifying malicious users attempting to subvert system security or cause damage to critical systems/data. In addition, dependent upon regulatory requirements the organization may be subject to, these policy settings could be required for compliance. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\Logon/Logoff\Audit Logon\Audit Policy: Logon-Logoff: Logon object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Logon

(4.11) 4482 Status of the 'Audit Policy: Logon-Logoff: Other Logon/Logoff Events' policy setting **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Other Logon/Logoff Events' security policy setting tracks additional logon/logoff events such as wired or wireless authentications, screen saver invocations or dismissals, and remote desktop session re-connections and disconnections. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Other Logon/Logoff Events object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Other Logon/Logoff Events

(4.12) 4481 Status of the 'Audit Policy: Logon-Logoff: Special Logon' policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Special Logon' security policy setting tracks users logon who belong to the 'Special Logon' group. The 'Special Logon' group members have Administrator level privileges and can escalate the rights of other objects. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Special Logon object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success (1)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☑ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☐ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Special Logon

(4.13) 8255 Status of the 'Removable Storage' audit policy settings **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Audit Policy: Object Access: Removable Storage' setting allows auditing for user attempts to access file system objects on a removable storage device. It is important to track which users have attempted to access removable storage with other related information for non-repudiation. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As audit logs help in case of security incidences, they should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Object Access: Removable Storage object. A value of 0 indicates that the setting is set to no auditing; a value of 1 indicates that the setting is set to success; a value of 2 indicates that the setting is set to failure; a value of 3 indicates that the setting is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable agent not enabled
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Removable Storage

(4.14) 4501 Status of the 'Audit Policy: Policy Change: Audit Policy Change' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Audit Policy Change' audit policy setting tracks changes to the System Audit Policy and several object and user audit settings. Some of the objects that can be audited are audit settings on policy objects, user, SACL, file, and registry key settings. Special Group list objects can also be audited. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Audit Policy Change object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**any of the selected values below:**
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Audit Policy Change

(4.15) 4502 Status of the 'Authentication Policy Change' audit policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Authentication Policy Change' audit policy setting tracks events generated by changes to authentication policies. Some of these changes include granting access to a computer from a network, grants for service logons, authentications for batch job logons, and local and remote access grants. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Authentication Policy Change object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success (1)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☑ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☐ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Authentication Policy Change

(4.16) 4494 Status of the 'Sensitive Privilege Use' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Sensitive Privilege Use' audit policy setting tracks events where sensitive privileges are used. Examples of some of these sensitive privileges are managing audit and security logs, modifying firmware, generation of security audits, and acting as part of the operating system. Depending on the type and size of a given company, the use of audit logs may be required to meet regulatory requirements. As with all critical systems and devices, audit logs should be enabled, monitored and managed in accordance with the requirements and expectations of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Sensitive Privilege Use object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Sensitive Privilege Use

(4.17) 4473 Status of the 'IPsec Driver' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'IPsec Driver' security policy setting tracks the activities and events of the IPsec driver. These events include drops (failed integrity or replay checks), notifications (cleartext, startup, shut down), and failures in loading IPsec filters, failed

initializations or incomplete network interfaces. Depending upon regulatory requirements, these security policy settings may be required. As with all critical systems and devices, any security policy setting should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\System\Audit IPSec Driver\Audit Policy: System: IPsec Driver object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
IPsec Driver

(4.18) 4474 Status of the 'Other System Events' security policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Other System Events' security policy setting tracks Windows Firewall service, driver, security policy, BranchCache, and cryptography notifications and events. Examples of these events would be Firewall service and driver startup, shutdown, and failed initializations or failed user notifications, driver runtime errors, and various BranchCache errors. Depending upon regulatory requirements, these security policy settings may be required. As with all critical systems and devices, security policy settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies\System: 'Audit Other System Events' object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Other System Events

(4.19) 4470 Status of the 'Security State Change' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Security State Change' audit policy setting tracks changes in system security states. This setting can be configured to audit system start, shut down, changes to time, and Administrator recovery from CrashOnAuditFail events. Depending

upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and audit logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\System\Audit Security State Change\Audit Policy: System: Security State Change object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable agent not enabled
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Security State Change

(4.20) 4471 Status of the 'Audit Policy: System: Security System Extension' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Security System Extension' audit policy setting tracks critical system events generated by installing new security extension code(s) and/or installing new services. This audit policy can track when a Local Security Authority has started a trusted logon process, loaded a security or authentication package. This audit policy can also track when a new service is installed on the system. Depending upon regulatory requirements, these audit policy settings may be required. As with all critical systems and devices, audit settings and logs should be enabled, monitored, and managed according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\System\Audit Security System Extension\Audit Policy: System: Security System Extension object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
Security System Extension

(4.21) 4472 Status of the 'System Integrity' audit policy setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The System Integrity audit policy setting reports on the integrity of the security system, including potential disk device errors, verification failures, etc. As enabling this audit facility has the potential to fill up a large amount of log space and cause a self-inflicted denial-of-service condition, it should be used according to the needs of the business.

This Integer value X indicates the current status of the Detailed Security Auditing (DSA) settings for the Computer Configuration\Windows Settings\Security Settings\Advanced Audit Policy Configuration\System Audit Policies - Local Group Policy Object\System\Audit System Integrity\Audit Policy: System: System Integrity object. A value of 0 indicates that DSA is set to no auditing; a value of 1 indicates that DSA is set to success; a value of 2 indicates that DSA is set to failure; a value of 3 indicates that DSA is set to success and failure.

Expected	**equal to**
	Success and Failure (3)
	OR, any of the selected values below:
	☐ No Auditing(0)
	☐ Success(1)
	☐ Subcategory not found
	☐ Failure(2)
	☑ Success and Failure(3)
	☐ Dissolvable Agent installation failed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Success and Failure (3)

Extended Evidence:

Subcategory
System Integrity

5. Administrative Templates (Computer)

(5.1) 9003 Status of the 'Lock screen camera' setting

Failed **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Lock screen camera' setting specifies if the Camera feature should be available on the lock screen or not. If the setting is not specified malicious users can gain the access over the camera and can be able to compromise the system. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the lock screen camera setting on the host.

Expected	**any of the selected values below:**
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\Personalization	NoLockScreenCamera	

(5.2) 9004 Status of the 'Lock screen slide show' setting

Failed **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Lock screen slide show' setting specifies if slide show can be played on the lock screen. If the setting is not specified malicious users can gain access over the slide show content and compromise the system. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current value of the Lock Screen Slide Show setting on the host.

Expected	**any of the selected values below:**
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Personalization	NoLockScreenSlideshow	

(5.3) 10012 Status of the 'LAPS AdmPwd GPO Extension / CSE is installed' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Local Administrator Password Solution (LAPS)' setting allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and member servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed. In order to utilize LAPS, a minor Active Directory Schema update is required, and a Group Policy Client Side Extension (CSE) must be installed on each managed computer. This setting should be configured according to the business needs.

The following List string value of X indicates the status of the LAPS AdmPwd GPO Extension / CSE setting using registry key path HKLM\Software\ Microsoft\Windows NT\CurrentVersion\Winlogon\GPExtensions\ on the host.

Expected **matches regular expression list**

AdmPwd.dll

OR, any of the selected values below:

☐ Not Installed

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Installed

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows NT\ CurrentVersion\Winlogon\ GPExtensions\{D76B9641-3288-4f75-942D-087D-E603E3EA}	DllName	

(5.4) 10015 Status of the 'Do not allow password expiration time longer than required by policy' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Local Administrator Password Solution (LAPS)' setting allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and member servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed. By enabling this setting, planned password expiration longer than password age dictated by "Password Settings" policy is NOT allowed. This setting should be configured according to the business needs.

The following Integer value of X indicates the status of the Do not allow password expiration time longer than required by policy setting using the registry key path HKLM\Software\Policies\Microsoft Services\AdmPwd\PwdExpirationProtectionEnabled on the host.

Expected **any of the selected values below:**

☑ Enabled(1)

☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft Services\ AdmPwd	PwdExpirationProtectionEnabled	

(5.5) 10008 Status of the 'Local Admin Password Management' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Local Administrator Password Solution (LAPS)' setting allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and member servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed. This setting should be configured according to the business needs.

The following Integer value of X indicates the status of the Enable Local Admin Password Management setting using the registry key path HKLM\Software\Policies\Microsoft Services\AdmPwd\AdmPwdEnabled on the host.

Expected	**any of the selected values below:**
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft Services\AdmPwd	AdmPwdEnabled	

(5.6) 10009 Status of the 'Password Complexity' Local Administrator Password Solution (LAPS) Failed CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy ‘password complexity’ setting provides for system-wide password complexity requirements.This makes the select ion of mixed-case, numerical, and 'punctuation' symbols mandatory during password creation. This exponentially increases the size of the 'symbol-set' that must be addressed when conducting a brute-force attack. Password complexity provides one of the best; first, lines of defense against unauthorized access, this value should be set according to the needs of the business.

The following Integer value of X indicates the status of the Password Settings: Password Complexity setting using the registry key path HKLM\Software\Policies\Microsoft Services\AdmPwd\PasswordComplexity on the host. A Value of 1 indicates the password complexity is configured with option Large Letters; a value of 2 indicates the password complexity is configured with option Large Letters + Small Letters; a value of 3 indicates the password complexity is configured with option Large Letters + Small Letters + Numbers; a value of 4 indicates the password complexity is configured with option Large Letters + Small Letters + Numbers + Specials.

Expected	**any of the selected values below:**
	☐ Large Letters(1)
	☐ Large Letters + Small Letters(2)
	☐ Large Letters + Small Letters + Numbers(3)
	☐ Not Configured
	☑ Large Letters + Small Letters + Numbers + Specials(4)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft Services\AdmPwd	PasswordComplexity	

(5.7) 10010 Status of the 'Password Length' Local Administrator Password Solution (LAPS) Failed CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The password length policy setting determines the minimum number of characters that should be used to make up a password for a user account. Each character that is added to the password length squares the difficulty of breaking the password via brute force, which attempts using every combination possible within the password symbol set-space, in order to discover a user's password. To provide adequate defense against a dictionary or brute force attacks against the passwords, the minimum length of a password should be long enough to provide adequate security and still short enough for users to easily remember. This value should be configured as appropriate to the needs of the business.

The following Integer value of X indicates the status of the Password Settings: Password Length setting using the registry key path HKLM\Software\Policies\Microsoft Services\AdmPwd\PasswordLength on the host.

Expected	**greater than or equal to**
	15
	OR, any of the selected values below:
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft Services\AdmPwd	PasswordLength	

(5.8) 10011 Status of the 'Password Age' Local Administrator Password Solution (LAPS) Failed CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

One characteristic that makes 'user identification' via password a secure/workable solution is setting a 'password expiration' requirement. Each time a new password is created, replacing one that has been in place for a given period of time, this resets the difficulty of breaking a password via brute-force to its maximum level; it can also help ensure that a compromised 'hack' account with a password that has expired is then closed. While no 'secure maximum' for limiting the use of a password has been agreed upon, 30 days is considered to be the maximum allowed for most enterprise environments. However, this tactic must be used along with other password security factors, such as increasing the complexity the password set-space by requiring mixed-cases and/or special characters, to further increase the difficulty of breaking any password by brute-force attacks.

The following Integer value of X indicates the status of the Password Settings: Password Age (Days) setting using the registry key path HKLM\Software\Policies\Microsoft Services\AdmPwd\PasswordAgeDays on the host.

Expected **in range**

1-30

OR, any of the selected values below:

- [ ] Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft Services\AdmPwd	PasswordAgeDays	

(5.9) 1169 Status of the 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' setting Passed CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

Automatic logon feature allows a user to automatically be logged into the system without presenting credentials at startup. Besides the obvious risk of anyone having physical access to the system being capable of being authenticated simply by turning the system on, there is additional risk in that the credentials for the account being automatically logged on is stored in clear text within the registry. NOTE: A software update to the GPO editor is required to view this object. (HKLM\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\AutoAdminLogon)

This integer value X indicates the status of the setting MSS: (AutoAdminLogon) Enable Automatic Logon using the configuration path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\AutoAdminLogon . A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **equal to**

Disabled (0)

OR, any of the selected values below:

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] RegSubKey not found
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Disabled (0)

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon	AutoAdminLogon	0

(5.10) 4741 Status of the 'MSS: (DisableIPSourceRoutingIPv6) IP source routing protection level (protects against packet spoofing)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'MSS: (DisableIPSourceRoutingIPv6) IP source routing protection level (protects against packet spoofing)' setting is intended to provide protection against source-routing spoofing on [multi-homed] Microsoft-based systems, that have at least two valid network interface devices enabled and connected. (All Microsoft-based systems having more than one valid networking device enabled can be used as a router or firewall between network segments, whether this is intended or not.) As a vulnerability exists that could allow a malicious user to circumvent routing rules by 'spoofing' the device to make it look like malicious or invalid traffic was sent from the protected side, this should be disabled/restricted according to the needs of the business. NOTE: To configure the system to drop all source routed packets set the value of this parameter to 2. The registry key for MSS: (DisableIPSourceRoutingIPv6) must be created in the Windows registry tree (HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\DisableIPSourceRouting) for this control to work properly.

This Integer value X indicates the current status of the setting MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing) Using the registry key pathHKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\DisableIPSourceRouting. A value of 0 indicates this is set to No additional protection, source routed packets are allowed; a value of 1 indicates this set to Medium, source routed packets ignored when IP forwarding is enabled; a value of 2 indicates this is set to Highest protection, source routing is completely disabled.

Expected	**equal to**
	Highest protection, source routing is completely disabled (2)
	OR, any of the selected values below:
	☐ No additional protection, source routed packets are allowed(0)
	☐ Medium, source routed packets ignored when IP forwarding is enabled(1)
	☐ RegSubKey not found
	☑ Highest protection, source routing is completely disabled(2)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters	DisableIPSourceRouting	

(5.11) 1172 Status of the 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'DisableIPSourceRouting' setting is intended to provide protection against source-routing spoofing on [multi-homed] Microsoft-based systems, that have at least two valid network interface devices enabled and connected. (All Microsoft-based systems having more than one valid networking device enabled can be used as a router or firewall between network segments, whether this is intended or not.) As a vulnerability exists that could allow a malicious user to circumvent routing rules by 'spoofing' the device to make it look like malicious or invalid traffic was sent from the protected side, this should be disabled/restricted according to the needs of the business. NOTE: To configure the system to drop all source routed packets set the value of this parameter to 2. The registry key for MSS: (DisableIPSourceRouting) must be created in the Windows registry tree (HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\DisableIPSourceRouting) for this control to work properly.

This Integer value X indicates the status of the setting MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing) using the registry key path HKLM\System\CurrentControlSet\Services\Tcpip\Parameters\DisableIPSourceRouting. A value of 0 indicates the setting IP source routing is enabled; a value of 1 indicates the setting IP source routing is disabled when IP forwarding is enabled; a value of 2 indicates the setting IP source routing is disabled.

Expected	**greater than or equal to**
	Highest protection,source routing is completely disabled (2)
	OR, any of the selected values below:
	☐ No additional protection, source routed packets are allowed(0)
	☐ Medium, source routed packets ignored when IP forwarding is enabled(1)
	☑ Highest protection,source routing is completely disabled(2)
	☐ Key not found

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters	DisableIPSourceRouting	

(5.12) 1193 Status of the 'MSS: Allow ICMP redirects to override OSPF generated routes (EnableICMPRedirect)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' setting allows Windows to alter a pre-established route for packets, using the 'shortest path first (SPF)' routing algorithm to speed up data transfer. As enabling this feature permits alteration of the routing table and attackers can impersonate/spoof 'accepted' routes, redirecting packets through a 'man-in-the-middle (MITM)' attack-foundation host, potentially compromising sensitive information, this SPF capability should be set as appropriate to the needs of the business. NOTE: A software update to the GPO editor is required to view this object. Registry Key/value path- HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\EnableICMPRedirect.

This Integer value X indicates the status of the setting MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes, using registry key path HKLM\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters\EnableICMPRedirect. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegSubKey not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters	EnableICMPRedirect	1

(5.13) 1462 Status of the 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds (300,000 is recommended)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The TCP session 'keep-alive' setting sets the value (in milliseconds) for the periodicity of the network subsystem's attempts at verification that a given TCP session is still active. (The default value of '300000' sends out a keep-alive request verification every 5 minutes.) As a 'keep-alive' setting that is too high or too low is vulnerable to denial-of-service attacks, this value should be set as appropriate to the needs of the business. Note: The registry key for MSS: (KeepAliveTime) must be created in the Windows registry tree (HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\KeepAliveTime) for this control to work properly.

This Integer value X indicates the current status of the setting MSS: How often keep-alive packets are sent in milliseconds , using registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\KeepAliveTime. A setting of 300000 (in milliseconds) requires a request to be sent every five minutes.

Expected	**in range**
	1-300000
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Tcpip\Parameters	KeepAliveTime	

(5.14) 1195 Status of the 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from the 'WINS servers' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This 'NetBIOS Name-Release' setting determines whether or not a system releases its NetBIOS name after getting a name-release request. As this blocking capability was added to help administrators protect against 'name-release' attacks that can facilitate unauthorized access to systems and files, this capability should be set as appropriate to the needs of the business. Note: The registry key for MSS: (NoNameReleaseOnDemand) must be created in the Windows registry tree (MACHINE\System\CurrentControlSet\Services\Netbt\Parameters\NoNameReleaseOnDemand) for this control to work properly.

This Integer value X indicates the current status of the setting MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers (Only recommended for servers), using registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Netbt\Parameters\NoNameReleaseOnDemand. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Netbt\Parameters	NoNameReleaseOnDemand	

(5.15) 1184 Status of the 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'ICMP Internet Router Discovery Protocol' (IRDP) uses the Internet Control Message Protocol (ICMP) to send router advertisement/solicitation messages to networked systems to provide router IP addresses. This setting will block the systems from accepting and/or caching these 'advertisements.' As these messages propagate through UDP and can easily be forged to point to a gateway-host that is operating as the foundation link for a 'man-in-the-middle' (MITM) attack, IRDP messaging capability should be disabled/restricted as appropriate to the needs of the business. Note: The registry key-value for MSS: (PerformRouterDiscovery) must be created in the Windows registry tree (MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\PerformRouterDiscovery) for this control to work properly.

This Integer value X indicates the status of the setting MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS) using registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\PerformRouterDiscovery. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled; a value of 2 indicates the setting is Enable only if DHCP sends the Perform Router Discovery Option .

Expected **any of the selected values below:**

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ Enable only if DHCP sends the Perform Router Discovery Option(2)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Tcpip\Parameters	PerformRouterDiscovery	

(5.16) 1458 Status of the 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Enable Safe DLL Search Mode' setting as defined within the 'HKLM\System\CurrentControlSet\Control\Session

Manager\SafeDllSearchMode' registry key, determines whether or not [dll] code that a user loads will run from the system directory first or the current directory. As modifying the way Windows locates driver files (.dll's) by forcing the OS to check the Windows directory first (for files installed during the OS installation/update process) instead of pulling possible malware [driver] files from the user's home directory, can block the execution of malware-based dll's, this should be set as appropriate to the needs of the business. Note: The registry key-value for MSS: (SafeDllSearchMode) must be created in the Windows registry tree (MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager\SafeDllSearchMode) for this control to work properly.

This Integer value X indicates the current status of the setting (SafeDllSearchMode) Enable Safe DLL search mode setting from the registry key HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session Manager\SafeDllSearchMode. A value of 0 indicates the setting requires search of the current directory first; a value of 1 indicates the setting requires search the system directory first..

Expected	**equal to**
	Search system directory first (Enabled) (1)
	OR, any of the selected values below:
	☐ Search current directory first (Disabled)(0)
	☑ Search system directory first (Enabled)(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\ Session Manager	SafeDllSearchMode	

(5.17) 1196 Status of the 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Screen saver grace period' setting determines how long is permitted between the start of the screen saver program and requirement of a password to unlock the system. As permitting any grace period may allow a malicious user to gain control of the system while it is unattended and unlocked, this value should be set as appropriate to the needs of the business. (ScreenSaverGracePeriod)

The integer value X indicates the value of the setting MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows NT\CurrentVersion\Winlogon\ScreenSaverGracePeriod.

Expected	**less than or equal to**
	5
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Microsoft\Windows NT\ CurrentVersion\Winlogon	Screensavergraceperiod	

(5.18) 4742 Status of the 'MSS: (TCPMaxDataRetransmissions) IPv6 How many times unacknowledged data is retransmitted' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'MSS: (TCPMaxDataRetransmissions) IPv6 How many times unacknowledged data is retransmitted' setting determines what the maximum number of retransmissions data packets will be allowed per IPv6-based connection prior to abandonment. The base value for this setting is set dynamically according to the round-trip times which get measured on each IPv6 connection. If/when any resumption of responses occurs, this value will be reset. If this is not implemented, there is a risk of DoS attack occurring as a malicious user could prevent the acknowledgement messages for transmitted packets which results in continuous retransmissions exhausting all available resources on the target system. As with all critical systems, security controls should be reviewed and assessed to determine proper usage and applicability for individual environments and set in accordance with business requirements and expectations.

This Integer value X indicates the current status of the setting MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted, using registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip6\Parameters\TcpMaxDataRetransmissions.

Expected	**in range**
	1-3
	OR, any of the selected values below:
	RegSubKey not found
	Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters	TCPMaxDataRetransmissions	

(5.19) 1449 Status of the 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted (3 recommended, 5 is default)' setting controls the number of times TCP will retransmit an individual data segment (not a 'connect' segment) before dropping the connection. (The retransmission timeout is doubled with each successive retransmission on a connection.) As the value of the 'TCPMaxDataRetransmissions' parameter can help avoid denial-of-service conditions when dealing with a possible embryonic connections-based attack, by not tying up the receiving system's resources, requiring continuing responses to connections that are never completed, this should be set as appropriate to the needs of the business. NOTE: This key must be created in the Windows registry to work properly; the timeout's retransmission time doubles for each succeeding retry and automatically resets after a transmission response succeeds.

This Integer value X indicates the current status of the MSS: (TCPMaxDataRetransmissions) setting from the HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\Tcpip\Parameters\TcpMaxDataRetransmissions registry key. It shows how many times an unacknowledged data packet will be retransmitted. A value of 5 (default setting) indicates that a maximum of 5 retransmission attempts of specific packets within a TCP stream will be performed; a setting of 3 would provide 3 retries. (The interval between retries doubles for each attempt.)

Expected	**in range**
	1-3
	OR, any of the selected values below:
	Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Services\Tcpip\Parameters	TcpMaxDataRetransmissions	

(5.20) 1463 Status of the 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Event Log' can be set to trigger a notification event when it reaches a certain level of its set capacity. As this can notify the Administrator of the log reaching a certain level by triggering a '523 Event,' showing that the Event Log is nearly full and prevent a system shutdown caused by the Security Event log reaching capacity is full (see CID-1156), this should be set as appropriate to the needs of the business. NOTE: 'The security event log is XX percent full' warning should be generated as a '523 Event.'

This Integer value X indicates the current status of the setting MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning from the registry path HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security\WarningLevel .

Expected	**less than or equal to**
	90
	OR, any of the selected values below:
	Key not found

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Eventlog\Security	WarningLevel	

(5.21) 4191 Status of the 'Turn on Mapper I/O (LLTDIO) driver' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn on Mapper I/O (LLTDIO) driver' Group Policy setting searches for and communicates with other computers running Mapper I/O (LLTDIO) on the network, these discovered objects automatically build the Network Map feature. As this capability can be vulnerable to known spoof attacks, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Turn on Mapper I/O (LLTDIO) driver policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\LLTD	EnableLLTDIO	

(5.22) 4192 Status of the 'Turn on Responder (RSPNDR) driver' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn on Responder (RSPNDR) driver' Group Policy setting is a component of Link Layer Topology Discovery (LLTD) protocol and answers the LLTD Mapper I/O requests to build the Network Map. As this protocol can be vulnerable to known spoof attacks, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Turn on Responder (RSPNDR) driver policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\LLTD	EnableRspndr	

(5.23) 2581 Status of the 'Turn off Microsoft Peer-to-Peer Networking Services' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off Microsoft Peer-to-Peer Networking Services' setting determines whether or not the system will run Microsoft Peer-to-Peer Networking Services. When this setting is enabled, the system will not run peer-to-peer protocols. It is always best practice to turn off any unnecessary services to reduce the overall threat surface of the system. If this service is not required for the systems' operations, the setting should be enabled as appropriate to the needs of the business.

This Integer value X indicates the current status of the Turn off Microsoft Peer-to-Peer Networking Services setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ RegTopKey not found

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\policies\Microsoft\Peernet	Disabled	

(5.24) 2616 Status of the 'Prohibit installation and configuration of Network Bridge on the DNS domain network' setting — Failed — MEDIUM

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Prohibit installation and configuration of Network Bridge on the DNS domain network' setting determines whether or not the system will permit a user to install and configure the Network Bridge feature. The Network Bridge feature allows a user to build a MAC (layer 2) bridge, allowing the user to connect two or more network segments. When this setting is disabled, the user is permitted to create or modify Network Bridge configurations. The creation of a Network Bridge between a private network and public Internet connection may create an unsecured link between the two networks and allow a malicious user to gain inappropriate access and/or control. If this function is not required for the systems' operation, it should be disabled/restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the Prohibit installation and configuration of Network Bridge on the DNS domain network setting. A value of 0 indicates the setting is enabled; a value of 1 indicates the setting is disabled.

Expected	any of the selected values below:
	☑ Enabled(0)
	☐ Disabled(1)
	☐ Not Configured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Network Connections	NC_AllowNetBridge_NLA	

(5.25) 10081 Status of the 'Require domain users to elevate when setting a network's location' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Require domain users to elevate when setting a network's location' setting determines whether to require domain users to elevate when setting a network's location. Allowing regular users to set a network location increases the risk and attack surface. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Require domain users to elevate when setting a network's location setting using registry key path HKLM\Software\Policies\Microsoft\Windows\Network Connections\NC_StdDomainUserSetLocation on the host. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Configured

Extended Evidence:

Key	Name	Value

HKLM\Software\Policies\Microsoft\Windows\ Network Connections	NC_StdDomainUserSetLocation	

(5.26) 10592 Status of the 'Hardened UNC Paths' setting for Netlogon **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Hardened UNC Paths' setting allows you to configure secure access to UNC paths. Universal Naming Convention (UNC) is a standardized notation that Windows uses to access file resources; in most cases these resource are located on a remote server. UNC allows the system to access files using the standard path format. If this setting is set properly, then Windows only allows access to the specified UNC paths after fulfilling additional security requirements. This setting should be configured according to the business needs.

The following List String value of X indicates the status of the Hardened UNC Paths for NETLOGON setting using registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:*\NETLOGON on the host.

Expected	**is contained in regular expression list**
	RequireMutualAuthentication\=1,\sRequireIntegrity\=1
	OR, any of the selected values below:
	Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\policies\Microsoft\Windows\ NetworkProvider\HardenedPaths	*\NETLOGON	

(5.27) 10593 Status of the 'Hardened UNC Paths' setting for Sysvol **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Hardened UNC Paths' setting allows you to configure secure access to UNC paths. Universal Naming Convention (UNC) is a standardized notation that Windows uses to access file resources; in most cases these resource are located on a remote server. UNC allows the system to access files using the standard path format. If this setting is set properly, then Windows only allows access to the specified UNC paths after fulfilling additional security requirements. This setting should be configured according to the business needs.

The following List String value of X indicates the status of the Hardened UNC Paths for SYSVOL setting using registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:*\SYSVOL on the host.

Expected	**is contained in regular expression list**
	RequireMutualAuthentication\=1,\sRequireIntegrity\=1
	OR, any of the selected values below:
	Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\policies\Microsoft\Windows\ NetworkProvider\HardenedPaths	*\SYSVOL	

(5.28) 4842 Status of the 'Internet Protocol version 6 (IPv6) components' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Internet Protocol version 6 (IPv6) components' setting provides for IPv6 connectivity on the system. As enabling IPv6 connectivity if the system is not using it natively can allow a secondary data channel to be opened that can be exploited for unauthorized access, this capability should be set according to the needs of the business.

The following List String value(s) X indicate the current status of the IPV6 settings defined within the HKLM\SYSTEM\CurrentControlSet\Services\ Tcpip6\Parameters\DisabledComponents registry key. A value of -1 indicates that all IPv6 components disabled except the IPv6 loopback interface; a value of 0 indicates that all IPv6 components enabled; a value of 1 indicates that all tunnel IPv6 interfaces disabled; a value of 16 indicates that native IPv6 interfaces disabled; a value of 17 indicates that all IPv6 interfaces disabled except for the IPv6 loopback interface; a value of 32 indicates that use IPv4 instead of IPv6 in prefix policies.

Expected	**matches regular expression list**
	255
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters	DisabledComponents	

(5.29) 4193 Status of the 'Configuration of wireless settings using Windows Connect Now' group policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Configuration of wireless settings using Windows Connect Now' Group Policy setting automatically starts a network wizard gathering wireless network choices from the user, automatically configures the authentication and encryption settings on the computer, and stores a copy of these settings on a USB flash drive for use/reuse later. As this setting can conflict with required network configurations and open unsecured channels, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the Configuration of wireless settings using Windows Connect Now policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\WCN\Registrars	EnableRegistrars	

(5.30) 2610 Status of the 'Prohibit Access of the Windows Connect Now wizards' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Prohibit Access of the Windows Connect Now wizards' setting determines whether or not users are granted access to the Windows Connect Now wizards. Windows Connect Now is a Windows Vista component intended to provide a simple and secure technology designed to configure network devices. When this setting is enabled, all Windows Connect Now wizards are disabled and users are denied access to all wizard tasks. As unsecured network connections to the Internet may open an attack vector that could allow a malicious user to gain inappropriate access and/or control, the capability to create and configure network connections should be restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the Prohibit Access of the Windows Connect Now wizards setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegSubKey not found
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\WCN\UI	DisableWcnUi	

(5.31) 8394 Configure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' policy setting prevents computers from establishing multiple connections to either Internet or to a Windows domain. If this setting is enabled, when the system has one active connection, a new connection to the Internet or to the Windows domain will be blocked. But Additional manual connection attempts by users to the Internet/Windows domain will not be blocked using this policy setting. If this setting is disabled or nor configured, Multiple simultaneous connections to the Internet or to a Windows domain are allowed. The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the managed corporate network. This policy setting need to be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Minimize the number of simultaneous connections to the Internet or a Windows Domain using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\fMinimizeConnections. A value of 0 indicates the service is set to Disabled; a value of 1 indicates the setting is set to Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WcmSvc\GroupPolicy	fMinimizeConnections	

(5.32) 8395 Status of the Configure 'Prohibit connection to non-domain networks' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Prohibit connection to non-domain networks' setting prevents computers from connecting to both a domain based network and a non-domain based network at the same time. If the policy setting is enabled the computer responds to automatic and manual network connection attempts based on the circumstances like Automatic Connection attempts and Manual connection attempts, If the setting is disabled or not configured computers are allowed to connect simultaneously to both domain and non-domain networks. The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the managed corporate network. This should be configured according to the needs of the business.

This Integer value X indicates the current status of the setting Prohibit connection to non-domain networks when connected to domain authenticated network using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WcmSvc\GroupPolicy\fBlockNonDomain. A value of 0 indicates the service is set to Disabled; a value of 1 indicates the service is set to Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WcmSvc\GroupPolicy	fBlockNonDomain	

(5.33) 9024 Status of the 'Apply UAC restrictions to local accounts on network logons' settings **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This setting specifies whether local accounts should be used for remote administration via network logon such as NET USE, connecting to C$, etc. Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the Apply UAC restrictions to local accounts on network logons setting on the host.

Expected	any of the selected values below:
	☑ Enabled(0)
	☐ Disabled(1)
	☐ Not Confugured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Confugured

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	LocalAccountTokenFilterPolicy	

(5.34) 9025 Status of the 'WDigest Authentication' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'WDigest Authentication' setting specifies if a copy of the user's plaintext password is to be retained in memory. If this setting is not specified malicious users can gain access and result in credential theft. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the WDigest Authentication setting on the host.

Expected	any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SYSTEM\CurrentControlSet\Control\ SecurityProviders\WDigest	UseLogonCredential	

(5.35) 9440 Status of the 'Include command line in process creation events' setting — Failed — MEDIUM

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Include command line in process creation events' setting allows you to determines what information is logged in security audit events when a new process has been created. The command line information for every process will be logged in plain text in the security event log as part of the Audit Process Creation event. When this policy setting, any user with access to read the security events will be able to read the command line arguments for any successfully created process. Command line arguments can contain sensitive or private information such as passwords or user data which may lead to unauthorized activities on the system. This setting should be set as per the business requirement.

The Integer value X indicates the status of the setting Include command line in process creation events using the registry key path HKLM\Software\ Microsoft\Windows\CurrentVersion\Policies\System\Audit\ProcessCreationIncludeCmdLine_Enabled. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System\Audit	ProcessCreationIncludeCmdLine_Enabled	

(5.36) 8188 Status of the 'Boot-Start Driver Initialization Policy' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The "Choose the boot-start drivers that can be initialized:" policy setting allows you to specify which boot-start drivers are initialized based on a classification determined by an Early Launch Antimalware boot-start driver. The Early Launch Antimalware boot-start driver can return the following classifications for each boot-start driver: i.e Good, Bad, Bad but required for boot, Unknown. If the setting is enabled you will be allowed to choose which boot-start drivers to initialize the next time the machine is started. The boot start drivers determined to be Good, Unknown or Bad but Boot Critical are initialized and the initialization of drivers determined to be Bad is skipped if the setting is disabled or not configured. This policy setting helps reduce the impact of malware that has already infected your system. If your malware detection application does not have Early Launch Antimalware boot-start driver or its disabled this setting has no effect and all boot-start drivers will be initialized. This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Choose the boot-start drivers that can be initialized using the registry key path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Policies\EarlyLaunch\DriverLoadPolicy. A value of 1 indicates the setting is set toGood and unknown, A value of 3 indicates the setting is set to Good, unknown and bad but critical, A value of 7 indicates the setting is set to All, A value of 8 indicates the setting is set to Good only.

Expected	**any of the selected values below:**
	☐ Good and unknown(1)
	☑ Good, unknown and bad but critical(3)
	☐ All(7)
	☐ Good only(8)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\System\CurrentControlSet\Policies\EarlyLaunch	DriverLoadPolicy	

(5.37) 3923 Status of the 'Registry policy processing (Option: Do not apply during periodic background processing)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Registry policy processing' settings determine when registry policies will be updated and affects the policies existing within the 'Administrative Templates' folder, as well as all additional policies that have values stored within the registry. This should be configured according to the needs of the business to ensure that all policy settings are applied and in compliance with expectations. By enabling this, registry settings that were 'customized' by a user will be overridden and the approved/appropriate settings will be applied.

This integer value X indicates the status of the setting Registry policy processing using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoBackgroundPolicy, A value of 0 indicates the setting isDisabled, A value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	NoBackgroundPolicy	

(5.38) 7501 Status of the 'Registry policy processing option: Process even if the Group Policy objects have not changed' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Registry policy processing option 'Process even if the Group Policy objects have not changed' reapplies group policies even when policies haven't changed. As updating policies while the system is in use can potentially damage data, while reapplying the policy can potentially lock out an intruder, this capability must be set according to the needs of the business.

This integer value X indicates the status of the setting Registry policy processing(Option: Process even if the Group Policy objects have not changed) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}\NoGPOListChanges, A value of 0 indicates the setting isEnabled, A value of 1 indicates the setting is Disabled.

Expected	**any of the selected values below:**
	☑ Enabled(0)
	☐ Disabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Group Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}	NoGPOListChanges	

(5.39) 4194 Status of the 'Turn Off Background Refresh of Group Policy' setting **Passed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn Off Background Refresh' Group Policy setting prohibits automatically updating current Group Policy settings while the system has a user actively logged into a session. As this setting can obstruct the needed refresh of a GPO and the establishment of new security requirements on the system, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the Turn Off Background Refresh of Group Policy policy. A value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☐ Enabled(1)
	☐ Disabled(0)
	☑ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	DisableBkGndGroupPolicy	

(5.40) 8397 Status of Configure 'Turn off access to the Store' **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off access to the Store' policy setting specifies whether to use the Store service for finding an application to open a file with an unhandled file type or protocol association. If this policy setting is enabled, the "Look for an app in the Store" item in the Open with dialog is removed. If this policy setting is disabled or not configured user is allowed to use the Store service and the Store item is available in the Open With dialog. Users should be prevented from accessing the Store application. This policy setting need to be configured according to the needs of the business.

This Integer value X indicates the status of the service Turn off access to the Store using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Explorer\NoUseStoreOpenWith. A value of 0 indicates the service is Disabled; a value of 1 indicates the service is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Explorer	NoUseStoreOpenWith	

(5.41) 3922 Status of the 'Turn off downloading of print drivers over HTTP' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off downloading of print drivers over HTTP' setting determines the capability for allowing the user to download print drivers using an HTTP browser. As print drivers from Internet sites can be corrupted, contain a Trojan Horse, or host other sorts of malware, allowing users to download print drivers over HTTP, which may impact the system's stability and security, should be set according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off downloading of print drivers over HTTP using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows NT\Printers\DisableWebPnPDownload. A value of 0 indicates setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows NT\ Printers	DisableWebPnPDownload	

(5.42) 10082 Status of the 'Turn off handwriting personalization data sharing' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Turn off handwriting personalization data sharing' setting allows you to turns off data sharing from the handwriting recognition personalization tool. Handwriting recognition personalization tool enables Tablet PC users to adapt handwriting recognition to their own writing style by providing writing samples. The tool can optionally share user writing samples with Microsoft to improve handwriting recognition in future versions of Windows. If this setting is not configured, users can share writing samples from the handwriting recognition personalization tool with Microsoft which is unacceptable in many environments. This setting should be configured according to the business needs.

The following Integer value of X indicates the status of the Turn off handwriting personalization data sharing setting using registry key path HKLM\ Software\Policies\Microsoft\Windows\TabletPC\PreventHandwritingDataSharing on the host. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ TabletPC	PreventHandwritingDataSharing	

(5.43) 10083 Status of the 'Turn off handwriting recognition error reporting' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Turn off handwriting recognition error reporting' setting allows you to turns off the handwriting recognition error reporting tool. Handwriting recognition error reporting tool enables users to report errors encountered in Tablet PC Input Panel. The tool generates error reports and transmits them to Microsoft over a secure connection. If this setting is not configured, users can start the handwriting recognition error reporting tool or send error reports to Microsoft. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Turn off handwriting recognition error reporting setting using registry key path HKLM\Software\Policies\Microsoft\Windows\HandwritingErrorReports\PreventHandwritingErrorReports on the host. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\HandwritingErrorReports	PreventHandwritingErrorReports	

(5.44) 4095 Status of the 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Windows 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is a group policy setting that automates connecting to Microsoft.com to download a list of Internet Service Providers (ISPs). As this setting can change existing internet service connectivity and could interfere with established service pack updating schedules or alter restricted configuration settings, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com for ISPs policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\Internet Connection Wizard	ExitOnMSICW	

(5.45) 3920 Status of the 'Turn off Internet download for Web publishing and online ordering wizards' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off Internet download for Web publishing and online ordering wizards' are used by Windows to show the providers recommended by Microsoft to link to for online ordering/web publishing. As allowing the use of this kind of service can potentially allow the downloading of malicious content, this capability should be restricted according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off Internet download for Web publishing and online ordering wizards using the registry key pathHKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoWebServices A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value

HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\Explorer	NoWebServices	

(5.46) 3919 Status of the 'Turn off printing over HTTP' service **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off printing over HTTP' service allows a user to use the HTTP protocol to send out print jobs. As HTTP is an unsecured, Internet-capable protocol that can potentially be sent through the Cloud as well as the network in a clear-text state, this capability should be restricted according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off printing over HTTP using the registry key pathHKEY_LOCAL_MACHINE\ Software\Policies\Microsoft\Windows NT\Printers\DisableHTTPPrinting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows NT\ Printers	DisableHTTPPrinting	

(5.47) 4097 Status of the 'Windows Registration Wizard' registry key value **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Registration Wizard' identifies one of several channels to be used for the activation and validation of software products to the manufacturer (Microsoft). Depending on how this registry key is set, the registration and validation of software products can be performed on a Volume Licensing (all licenses are activated/validated from a single source) or on an independent 'per unit' basis. As this 'key value' choice can trigger multiple and/or unauthorized activation and validation channels increasing unnecessary traffic across network links, this key value should be set according to the requirements and expectations of the business.

This Integer value X indicates the current status of the Turn off Registration if URL connection is referring to Microsoft.com policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Registration Wizard Control	NoRegistration	

(5.48) 3908 Status of the 'Turn off Search Companion content file updates' service **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This service can allow the Search Companion to automatically upload content updates to the current local/Internet search requirements. As this capability could permit the unconscious uploading of malware content by the user, it should be restricted according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off Search Companion content file updates using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\SearchCompanion\DisableContentFileUpdates. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\SearchCompanion	DisableContentFileUpdates	

(5.49) 4098 Status of the 'Order Prints' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Group Policy setting 'Order Prints' facilitate the ordering of [picture] prints via the Internet under the 'Internet Communication Management GPO. As this setting could enable unauthorized user activities, it should be set according to the needs of the business.

This Integer value X indicates the current status of the Turn off the 'Order Prints' picture task policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer	NoOnlinePrintsWizard	

(5.50) 3921 Status of the 'Turn off the 'Publish to Web' task for files and folders' group policy **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off the 'Publish to Web' task for files and folders' group policy setting determines whether or not a user will be allowed to publish items, such as files/folders to the Internet from the 'File and Folder Tasks.' As allowing this type of document publication may put confidential/proprietary information at risk, this capability should be set/restricted according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off the 'Publish to Web' task for files and folders using the registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoPublishingWizard. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer	NoPublishingWizard	

(5.51) 3907 Status of the 'Windows Messenger Customer Experience Improvement Program' policy **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This capability defines whether or not Windows Messenger will collect and send anonymous information on Windows Messenger usage. As this could be the foundation of a potential information disclosure attack, it should be enabled or disabled according to the needs of the business.

This Integer value X indicates the current status of the setting Turn off the Windows Messenger Customer Experience Improvement Program using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Messenger\Client\CEIP. A value of 1 indicates the setting is disabled; a value of 2 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(1)
- ☑ Enabled(2)
- ☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Messenger\Client	CEIP	

(5.52) 10084 Status of the 'Turn off Windows Customer Experience Improvement Program (CEIPEnable)' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Turn off Windows Customer Experience Improvement Program (CEIPEnable)' setting defines whether or not Windows Messenger will collect and send anonymous information on Windows Messenger usage. As this could be the foundation of a potential information disclosure attack, it should be enabled or disabled according to the needs of the business.

The following Integer value of X indicates the status of the Turn off Windows Customer Experience Improvement Program setting using registry key path HKLM\Software\Policies\Microsoft\SQMClient\Windows\CEIPEnable on the host.

Expected **any of the selected values below:**

- ☑ Enabled(0)
- ☐ Disabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\SQMClient\Windows	CEIPEnable	

(5.53) 4143 Status of the 'Disable Windows Error Reporting' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Disable Windows Error Reporting' Group Policy setting determines whether or not errors are reported to Microsoft. As this setting can potentially release privileged corporate information on application function, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Disable Windows Error Reporting policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Windows Error Reporting	Disabled	

(5.54) 10085 Status of the 'Disallow copying of user input methods to the system account for sign-in' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Disallow copying of user input methods to the system account for sign-in' setting allows you to prevent automatic copying of user input methods to the system account for use on the sign-in screen. The user is restricted to the set of input methods that are enabled in the system account. If this setting is not configured, then the user will be able to use input methods enabled for their user account on the sign-in page. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Disallow copying of user input methods to the system account for sign-in setting using registry key path HKLM\Software\Policies\Microsoft\Control Panel\International\BlockUserInputMethodsForSignIn on the host.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Control Panel\ International	BlockUserInputMethodsForSignIn	

(5.55) 9008 Status of the 'Do not display network selection UI' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not display network selection UI' setting specifies whether anyone can interact with available networks UI on the logon screen. If the setting is not specified unauthorized user could disconnect the PC from the network or can connect the PC to other available networks without signing into Windows and can be able to compromise the system.This setting should be restricted according to the needs of the business.

This integer value of X indicates the current setting of the Display Network Selection UI setting on the host.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ System	DontDisplayNetworkSelectionUI	

(5.56) 8176 Status of the 'Do not enumerate connected users on domain-joined computers' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not enumerate connected users on domain-joined computers' policy setting prevents connected users from being enumerated on domain-joined computers. If the setting is enabled the Logon UI will not enumerate any connected users on domain-joined computers, connected users will be enumerated on domain-joined computers if this policy setting is disabled/not configured. A malicious user could use this feature to collect accounts names of other users, and then information can be used for attacks such as guessing passwords.. This setting should be set as per the need of the business.

This Integer value X indicates the current status of the setting Do not enumerate connected users on domain-joined computers using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\DontEnumerateConnectedUsers. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\System	DontEnumerateConnectedUsers	

(5.57) 8177 Status of the 'Enumerate local users on domain-joined computers' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Enumerate local users on domain-joined computers' policy setting allows local users to be enumerated on domain-joined computers. If the setting is enabled the Logon UI will enumerate all local users on domain-joined computers, local users will not be enumerated on domain-joined computers if this policy setting is disabled/not configured. A malicious user could use this feature to collect accounts names of other users, and then information can be used for attacks such as guessing passwords. This setting should be set as per the need of the business.

This Integer value X indicates the current status of the setting Enumerate local users on domain-joined computers using the registry key path KEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\EnumerateLocalUsers. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\System	EnumerateLocalUsers	

(5.58) 8399 Status of the Configure 'Turn off app notifications on the lock screen' — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off app notifications on the lock screen' policy setting prevents app notifications from appearing on the lock screen. If this setting is enabled, no app notifications will be displayed on the lock screen. If this policy setting is disabled or not configured, users can choose which apps display notifications on the lock screen. App notifications might display sensitive business or personal data. This policy setting need to be configured according to the needs of the business.

This Integer value of X indicates the current status of the service Turn off app notifications on the lock screen using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\DisableLockScreenAppNotifications. A value of 0 indicates the service is set to Disabled; a value of 1 indicates the service is set to Enabled.

Expected **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\System	DisableLockScreenAppNotifications	

(5.59) 8175 Status of the 'Turn on PIN sign-in' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn on PIN sign-in' setting allows you to control whether a domain user can sign in using a PIN. If this policy is enabled, a domain user can set up and sign in with a PIN. A domain user can't set up and use a PIN if the policy setting is disabled/not configured . Note that the user's domain password will be cached in the system vault when using this feature. A PIN are created from a much smaller selection of characters than a password, so in most cases a PIN will be much less robust than a password. This setting should be set as per the need of the business.

This Integer value X indicates the current status of the setting Turn on PIN sign-in using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\AllowDomainPINLogon. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected — **any of the selected values below:**

- [x] Disabled(0)
- [ ] Enabled(1)
- [ ] Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\System	AllowDomainPINLogon	

(5.60) 4110 Status of the 'Require a Password When a Computer Wakes (on Battery)' Group Policy setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Require a Password When a Computer Wakes (on Battery)'s group policy setting forces the user to reenter the password when the system resumes from a state of sleep while on battery power. As this group policy invokes security settings that help deter unauthorized access, it should be configured according to the needs of the business.

This integer value X indicates the status of the setting Require a Password When a Computer Wakes (On Battery) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51\DCSettingIndex, A value of 0 indicates the setting isDisabled, A value of 1 indicates the setting is Enabled.

Expected — **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)
- [ ] Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51	DCSettingIndex	

(5.61) 4111 Status of the Windows Group Policy 'Require a Password When a Computer Wakes (Plugged In)' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Require a Password When a Computer Wakes (Plugged In)' group policy setting forces the user to reenter the password when the system resumes from a state of sleep. As this group policy invokes security settings that help deter unauthorized access, it should be configured according to the needs of the business.

This integer value X indicates the status of the setting Require a Password When a Computer Wakes (Plugged In) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51\ACSettingIndex, A value of 0 indicates the setting isDisabled, A value of 1 indicates the setting is Enabled.

Expected — **any of the selected values below:**

- [ ] Disabled(0)
- [x] Enabled(1)

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51	ACSettingIndex	

(5.62) 3900 Status of the 'Offer Remote Assistance' setting (Terminal Services) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Offer Remote Assistance' settings are configured to control the remote assistance capability that allows expert users and/or system administrators to offer remote assistance to someone on another system. This utility employs Terminal Services to provide this functionality and could allow malicious users the ability to gain access to systems from remote locations. As a result, this should be set in compliance with internal security requirements and expectations to meet the needs of the business.

This integer value X indicates the status of the setting Configure Offer Remote Assistance using the registry key path HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal Services\fAllowUnsolicited, A value of 0 indicates the setting isDisabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

☑ Disabled(0)

☐ Enabled(1)

☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fAllowUnsolicited	

Permission Translation:

M : Read control

(5.63) 3899 Status of the 'Solicited Remote Assistance' policy setting (Terminal Services) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Solicited Remote Assistance' group policy is used by Systems Administrators to control the remote assistance capability through Terminal Services that allows users to send 'requests' to another person (possibly an IT Support resource) to connect to their system remotely for 'expert assistance' with a problem. This policy must actually be 'configured' to disallow the user from setting up Remote Assistance via the Control Panel (by default, the user can enable this function) which could be in violation of internal security requirements and expectations. As with all Group Policy Objects and Services, a risk assessment should be performed to determine the correct settings to meet the needs of the business.

This integer value X indicates the status of the setting Configure Solicited Remote Assistance using the registry key path HKEY_LOCAL_MACHINE\Software\policies\Microsoft\Windows NT\Terminal Services\fAllowToGetHelp, A value of 0 indicates the setting isDisabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

☑ Disabled(0)

☐ Enabled(1)

☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value

HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fAllowToGetHelp	

Permission Translation:

M : Read control

(5.64) 1513 Status of the 'RPC Endpoint Mapper Client Authentication' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'RPC Endpoint Mapper Client Authentication' service blocks anonymous or null connections to the RPC endpoint mapping service. As RPC has generally weak or non-existent authentication for connection to RPC services, this capability should be disabled/restricted as appropriate to the needs of the business. NOTE: The Manufacturer recommends that this be disabled unless a specific and critical legacy application that requires anonymous RPC must use it.

This Integer value X indicates the current status of the setting RPC Endpoint Mapper Client Authentication using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows NT\Rpc\EnableAuthEpResolution. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected — **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows NT\RPC	EnableAuthEpResolution	

(5.65) 1514 Status of the 'Restrictions for Unauthenticated RPC clients' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

From Windows SP2 onward, the 'Restrictions for Unauthenticated RPC clients' requires that all anonymous callbacks to RPC services to be rejected. This 'Require Authentication' policy can be set to varying degrees, such as totally disabled, accept all callbacks; set it partially enabled, accept anonymous RPC callbacks from Named Pipes only (the default); set it fully enabled, requiring RPC calls to be 'Authenticated without exceptions.' (While some applications have been written to use RPC callbacks without authentication, this is a new option and does not apply to legacy applications.) As RPC has generally weak or non-existent authentication for connection to RPC services, this capability should be set as appropriate to the needs of the business.

This Integer value X indicates the current status of the setting RPC Runtime Unauthenticated Client Restriction to Apply using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows NT\Rpc\RestrictRemoteClients. A value of 0 indicates the setting is set to None, A value of 1 indicates the setting is set to Authenticated, A value of 2 indicates the setting is set to Authenticated without exceptions. NOTE: Post-Vista Windows systems may require this to be set to a value of 1 for Authenticated to successfully read and report all object scans.

Expected — **any of the selected values below:**

- ☐ None(0)
- ☑ Authenticated(1)
- ☐ Authenticated without exceptions(2)
- ☐ Key not found

Actual — **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\RPC	RestrictRemoteClients	

(5.66) 10362 Status of the 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This policy setting configures Microsoft Support Diagnostic Tool (MSDT) interactive communication with the support provider. MSDT gathers diagnostic data for analysis by support professionals. Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information. This setting should be configured according to the business needs.

The Integer value X indicate the status of the setting Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider using the registry key path HKLM\SOFTWARE\Policies\Microsoft\Windows\ScriptedDiagnosticsProvider\Policy\DisableQueryRemoteServer.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ScriptedDiagnosticsProvider\Policy	DisableQueryRemoteServer	

(5.67) 10086 Status of the 'Enable/Disable PerfTrack' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Enable/Disable PerfTrack' setting specifies whether to enable or disable tracking of responsiveness events. This policy exist to restrict this feature for a specific user, set the consent level, and designate specific programs for which error reports could be sent. If this setting is not configured, DPS will enable Windows Performance PerfTrack by default which may cause potential for unauthorized or undesired usage, data leakage, or unintentional communications. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Enable/Disable PerfTrack setting using registry key path HKLM\Software\Policies\Microsoft\Windows\WDI\ScenarioExecutionEnabled on the host.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\WDI\{9c5a40da-b965-4fc3-8781-88dd50a6299d}	ScenarioExecutionEnabled	

(5.68) 10087 Status of the 'Enable Windows NTP Client' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Enable Windows NTP Client' setting specifies whether the Windows NTP Client is enabled or not. Network Time Protocol (NTP) is a client/server application. Each workstation, router, or server must be equipped with NTP client software to synchronize its clock to the network time server. If this setting is not configured, local computer clock does not synchronize time with NTP servers. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Enable Windows NTP Client setting using registry key path HKLM\Software\Policies\Microsoft\W32Time\TimeProviders\NtpClient on the host.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured

Actual	Last Updated:03/21/2017 at 17:02:53 (GMT+0500)
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\W32Time\TimeProviders\NtpClient	Enabled	

(5.69) 10088 Status of the 'Enable Windows NTP Server' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

he policy 'Enable Windows NTP Server' setting specifies whether the Windows NTP Server is enabled or not. Network Time Protocol (NTP) is a client/server application. Each workstation, router, or server must be equipped with NTP client software to synchronize its clock to the network time server. If this setting is not configured, your computer cannot service NTP requests from other computers. This setting should be set according to the business needs.

The following Integer value of X indicates the status of the Enable Windows NTP Server setting using registry key path HKLM\Software\Policies\Microsoft\W32Time\TimeProviders\NtpServer on the host.

Expected	any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\W32Time\TimeProviders\NtpServer	Enabled	

(5.70) 9009 Status of the 'Allow Microsoft accounts to be optional' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Allow Microsoft accounts to be enabled' setting specifies if the Microsoft accounts are optional for Windows Store apps that require an account to sign in. This provides the organization with greater control over relevant credentials. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current value of the Allow Microsoft accounts to be optional setting on the host.

Expected	any of the selected values below:
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System	MSAOptional	

(5.71) 10006 Status of the 'Disallow Autoplay for non-volume devices' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This policy setting disallows Autoplay for MTP devices like cameras or phones. If this setting is not configured, then attacker could use this feature to launch a program to damage a client computer or data on the computer. This setting should be configured according to the business needs.

The following Integer value of X indicates the status of the Autoplay for non-volume devices setting using the registry key path HKLM\Software\Policies\Microsoft\Windows\Explorer\NoAutoplayfornonVolume on the host. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Explorer	NoAutoplayfornonVolume	

(5.72) 10007 Status of the 'default behavior for AutoRun' **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This policy setting allows you to set the default behavior for Autorun commands. Autorun commands are generally stored i n autorun.inf files. These commands enable applications to start, start installation programs, or start other routines. If this setting is not configured, this code may be executed without user's knowledge or consent, which may lead to secu rity concerns. This setting should be configured according to the business needs.

The following Integer value of X indicates the status of the Set the default behavior for AutoRun setting using the registry key path HKLM\Software\ Microsoft\Windows\CurrentVersion\Policies\Explorer\NoAutorun on the host. A value of 1 indicates the setting is set to Do not execute any autorun commands; a value of 2 indicates the setting is set to Automatically execute autorun commands.

Expected	**any of the selected values below:**
	☑ Do not execute any autorun commands(1)
	☐ Automatically execute autorun commands(2)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\Explorer	NoAutorun	

(5.73) 1183 Status of the 'Disable Autorun for all drives' setting for the HKLM key **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off Autoplay for all drives' setting (HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\ NoDriveTypeAutoRun) allows the system to refuse to automatically run a program, such as 'setup.exe,' from a portable storage medium, such as a CD-ROM. As these 'autoplay' type of programs executions are known to be vulnerable to running exploits by malicious users, who insert malicious code hooks into the 'autorun.inf' files and the system will automatically launch these as soon as the media is read, this parameter should be set as appropriate to the needs of the business. NOTE: Setting this parameter to a value of '255' should disable the 'autoplay' for all types of removable media/ drives. (NoDriveTypeAutoRun)

This Integer value X indicates the status of the setting Turn off Autoplay for all drives (NoDriveTypeAutoRun), using registry key path HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoDriveTypeAutoRun. A value of 181 indicates the setting is configured to Autoplay disabled on network and removable drives; a value of 255 indicates the setting is configured to Autoplay disabled; a value of 145 indicates the setting is Not configured for Windows Vista, Windows XP Desktop, Windows 2008 Server ; a value of 149 indicates the setting is Not configured for windows 2000, Windows 2003 Server.

Expected	**equal to**
	All drives (255)
	OR, any of the selected values below:
	☐ CD-ROM/Removable Drives(181)
	☑ All drives(255)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	All drives (255)

Extended Evidence:

Key	Name	Value
HKLM\software\microsoft\windows\currentversion\policies\explorer	nodrivetypeautorun	255

(5.74) 8425 Status of "Do not display the password reveal button" — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This "Do not display the password reveal button" policy setting allows to configure the display of the password reveal button in password entry user experiences. If this policy setting is enabled, the password reveal button will not be displayed after a user types a password in the password entry text box. If this policy setting is disabled or not configured the password reveal button will be displayed after a user types a password in the password entry text box. By default, the password reveal button is displayed after a user types a password in the password entry text box. This is very useful when using long and complex password but the potential risk is that someone else can see your password while observing your screen surreptitiously. This policy setting need to configured according to the needs of the business.

This Integer value X indicates the status of the service Do not display the password reveal button using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\CredUI\DisablePasswordReveal. A value of 0 indicates the service is Disabled; a value of 1 indicates the service is set to Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\CredUI	DisablePasswordReveal	

(5.75) 3897 Status of 'Enumerate administrator accounts on elevation' setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Enumerate administrator accounts on elevation' capability displays the 'administrator' account list on the system. As showing this list may allow a malicious user to target a specific, privileged account for an attack or exploit, this capability should be set in accordance with the needs of the business.

This Integer value X indicates the current status of the Enumerate Administrator Accounts On Elevation setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI	EnumerateAdministrators	

Permission Translation:

M : Read control

(5.76) 9117 Status of the "Ensure EMET is installed" setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The enhanced mitigation experience toolkit (EMET) is free, supported, software developed by Microsoft that allows an

enterprise to apply exploit mitigations to to applications that run on Windows. EMET mitigations help reduce the reliability of exploits that target vulnerable software running on Windows from malicious users who might compromise the system. This setting should be restricted according to the needs of the business.

This list string value(s) of X indicate the current value of the EMET installation on the host.

Expected	**matches regular expression list**
	EMET 5.*
	OR, any of the selected values below:
	☐ EMET not installed
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	EMET not installed

(5.77) 9533 Status of the 'Default Action and Mitigation Settings - AntiDetours' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Default Action and Mitigation Settings - AntiDetours' setting allows you to configure default action after detection and advanced ROP mitigation settings. When EMET detects an exploit there should be a default action performed if no other mitigation has been configured. If this setting is not configured, no default action will be performed which may cause overlooking of exploits. This setting should be configured according to the business needs.

The Integer value X indicates the status of the setting Default Action and Mitigation Settings - AntiDetours using the registry key path HKLM\Software\Policies\Microsoft\EMET\SysSettings\AntiDetours. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled; a value of 2 indicates the setting is User Configured.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ User Configured(2)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	AntiDetours	

(5.78) 9534 Status of the 'Default Action and Mitigation Settings - BannedFunctions' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Default Action and Mitigation Settings - BannedFunctions' setting allows you to configure default action after detection and advanced ROP mitigation settings. ROP is an exploitation technique that facilitates the execution of code when mitigation's like the Data Execution Prevention are in place. In order to do that, the ROP technique uses snippets of code that are already present in the memory region of the attacked application. Banned Functions allows you to enable additional APIs, configured in a list that will be blocked when used. In this version only ntdll!LdrHotPatchRoutine is configured to mitigate potential exploits abusing this API. This setting will provide the actual protection from exploits and should be set as per the business requirement.

The Integer value X indicates the status of the setting Default Action and Mitigation Settings - BannedFunctions using the registry key path HKLM\Software\Policies\Microsoft\EMET\SysSettings\BannedFunctions. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled; a value of 2 indicates the setting is User Configured.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ User Configured(2)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	BannedFunctions	

(5.79) 9536 Status of the 'Default Action and Mitigation Settings - ExploitAction' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Default Action and Mitigation Settings - ExploitsAction' setting allows you to configure default action after detection and advanced ROP mitigation settings. ROP is an exploitation technique that facilitates the execution of code when mitigation like the Data Execution Prevention are in place. In order to do that, the ROP technique uses snippets of code that are already present in the memory region of the attacked application. This setting will provide the actual protection from exploits and should be set as per the business requirement.

The Integer value X indicates the status of the setting Default Action and Mitigation Settings - ExploitAction using the registry key path HKLM\Software\Policies\Microsoft\EMET\SysSettings\ExploitAction. A value of 0 indicates the setting is set to Audit Only; a value of 1 indicates the setting is set to Stop Program; a value of 2 indicates the setting is set to User Configured.

Expected **any of the selected values below:**

- ☐ Audit Only(0)
- ☐ Stop Program(1)
- ☑ User Configured(2)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	ExploitAction	

(5.80) 9535 Status of the 'Default Action and Mitigation Settings - DeepHooks' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Default Action and Mitigation Settings - DeepHooks' setting allows you to configure default action after detection and advanced ROP mitigation settings. ROP is an exploitation technique that facilitates the execution of code when mitigation's like the Data Execution Prevention are in place. In order to do that, the ROP technique uses snippets of code that are already present in the memory region of the attacked application. When the EMET software is installed on a system running the Host IPS software and the EMET 'Deep Hooks' feature is enabled, any application that is hooked by both EMET and Host IPS will become unresponsive on start up. Thus it protects critical APIs and the subsequent lower level APIs used by the top level critical API. This setting should be set as per the business requirement.

The Integer value X indicates the status of the setting Default Action and Mitigation Settings - DeepHooks using the registry key path HKLM\Software\Policies\Microsoft\EMET\SysSettings\DeepHooks. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled; a value of 2 indicates the setting is User Configured.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ User Configured(2)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	DeepHooks	

(5.81) 9043 Status of the 'Default Protections for Internet Explorer' setting. **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Default Protections for Internet Explorer' setting determines if the EMET mitigation are applied to Internet Explorer. If the setting is not specified malicious users can increase the reliability of exploits on the target and compromise the system. This setting should be restricted according to the needs of the business.

The List String values of X indicate the current status of the Default Protections for Internet Explorer setting on the host.

Expected	**matches regular expression list**
	*\\Internet\sExplorer\\iexplore.exe
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Internet Explorer\iexplore.exe	

(5.82) 9064 Status of the 'Default Protections for Popular Software' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Default Protections for Popular Software' setting specifies if the EMET (Enhanced Mitigation Experience Toolkit) mitigation is applied to other popular software. If this setting is not specified malicious users can exploit and compromise the system. This setting should be restricted according to the needs of the business.

This List String value(s) of X indicate the current value of the Default Protections for Popular Software setting on the host.

Expected	**matches regular expression list**
	*\\Google\\Chrome\\Application\\chrome\.exe\s\-SEHOP
	*\\Skype\\Phone\\Skype\.exe\s\-EAF
	*\\Mozilla\sFirefox\\firefox\.exe
	*\\Mozilla\sFirefox\\plugin\-container\.exe
	*\\Mozilla\sThunderbird\\thunderbird\.exe
	*\\Foxit\sReader\\Foxit\sReader\.exe
	*\\Mozilla\sThunderbird\\plugin\-container\.exe
	*\\Google\\Google\sTalk\\googletalk\.exe\s\-DEP\s\-SEHOP
	*\\WinRAR\\unrar\.exe
	*\\iTunes\\iTunes\.exe
	*\\VideoLAN\\VLC\\vlc\.exe
	*\\Windows Live\\Writer\\WindowsLiveWriter\.exe
	*\\Winamp\\winamp\.exe
	*\\Microsoft\sLync\\communicator\.exe
	*\\Windows\sLive\\Mail\\wlmail\.exe
	*\\mIRC\\mirc\.exe
	*\\Windows\sMedia\sPlayer\\wmplayer\.exe\s\-SEHOP \-EAF\s\-MandatoryASLR
	*\\Opera\\opera\.exe
	*\\WinRAR\\rar\.exe
	*\\Windows\sLive\\Photo\sGallery\\WLXPhotoGallery\.exe
	*\\WinRAR\\winrar\.exe
	*\\Pidgin\\pidgin\.exe
	*\\WinZip\\winzip32\.exe
	*\\Real\\RealPlayer\\realconverter\.exe
	*\\WinZip\\winzip64\.exe
	*\\7\-Zip\\7z\.exe\s\-EAF
	*\\Real\\RealPlayer\\realplay\.exe
	*\\7\-Zip\\7zFM\.exe\s\-EAF
	*\\Safari\\Safari\.exe
	*\\7\-Zip\\7zG\.exe\s\-EAF
	*\\SkyDrive\\SkyDrive\.exe
	\\Adobe\\Adobe\sPhotoshop\sCS\\Photoshop\.exe

	*\\QuickTime\\QuickTimePlayer\.exe
	OR, any of the selected values below:
	☐ Value not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Windows Media Player\wmplayer.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Skype\Phone\Skype.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Microsoft Lync\communicator.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Windows Live\Mail\wlmail.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Windows Live\Photo Gallery\WLXPhotoGallery.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Windows Live\Writer\WindowsLiveWriter.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\SkyDrive\SkyDrive.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Google\Chrome\Application\chrome.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Google\Google Talk\googletalk.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Mozilla Firefox\firefox.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Mozilla Firefox\plugin-container.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Mozilla Thunderbird\thunderbird.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Mozilla Thunderbird\plugin-container.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Adobe\Adobe Photoshop CS*\Photoshop.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Winamp\winamp.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Opera\opera.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Opera*\opera.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\WinRAR\winrar.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\WinRAR\rar.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\WinRAR\unrar.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\WinZip\winzip32.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\WinZip\winzip64.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\VideoLAN\VLC\vlc.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Real\RealPlayer\realconverter.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Real\RealPlayer\realplay.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\mIRC\mirc.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\7-Zip\7z.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\7-Zip\7zG.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\7-Zip\7zFM.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Safari\Safari.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\QuickTime\QuickTimePlayer.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\iTunes\iTunes.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Pidgin\pidgin.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Foxit Reader\Foxit Reader.exe	

(5.83) 9065 Status of the 'Default Protections for Recommended Software' setting — Failed — SERIOUS

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Default Protections for Recommended Software' setting determine if recommended EMET mitigation are applied. If this setting is not specified malicious users can exploit and compromise the system. This setting should be restricted according to the needs of the business.

This List String value(s) of X indicate the current value of the Default Protections for Recommended Software setting on the host.

Expected	**matches regular expression list**
	\\OFFICE1\\MSACCESS\.EXE
	*\\Java\\jre6\\bin\\java\.exe \-HeapSpray
	\\Adobe\\Acrobat\\Acrobat\\Acrobat\.exe

	\\OFFICE1\\EXCEL\.EXE
	*\\Java\\jre6\\bin\\javaw\.exe \-HeapSpray
	*\\Java\\jre6\\bin\\javaws\.exe \-HeapSpray
	*\\Java\\jre7\\bin\\java\.exe \-HeapSpray
	*\\Java\\jre7\\bin\\javaw\.exe \-HeapSpray
	*\\Java\\jre7\\bin\\javaws\.exe \-HeapSpray
	\\OFFICE1\\LYNC\.EXE
	\\OFFICE1\\OUTLOOK\.EXE
	\\OFFICE1\\OIS\.EXE
	\\OFFICE1\\POWERPNT\.EXE
	\\OFFICE1\\PPTVIEW\.EXE
	\\OFFICE1\\MSPUB\.EXE
	\\OFFICE1\\VISIO\.EXE
	\\OFFICE1\\VPREVIEW\.EXE
	\\OFFICE1\\WINWORD\.EXE
	*\\Windows NT\\Accessories\\wordpad\.exe
	\\OFFICE1\\INFOPATH\.EXE
	\\Adobe\\Reader\\Reader\\AcroRd32\.exe
	OR, any of the selected values below:
	☐ Value not found
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Windows NT\Accessories\wordpad.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\OUTLOOK.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\WINWORD.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\EXCEL.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\POWERPNT.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\MSACCESS.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\MSPUB.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\INFOPATH.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\VISIO.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\VPREVIEW.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\LYNC.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\PPTVIEW.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\OFFICE1*\OIS.EXE	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Adobe*\Reader\AcroRd32.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Adobe\Acrobat*\Acrobat\Acrobat.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Java\jre*\bin\java.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Java\jre*\bin\javaw.exe	
HKLM\Software\Policies\Microsoft\EMET\Defaults	*\Java\jre*\bin\javaws.exe	

(5.84) 9057 Status of the 'System ASLR' setting

Failed **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'System ASLR' setting determines how applications become enrolled in address space layout randomization (ASLR). If the setting is not specified malicious users can gain access by using exploits targeting memory corruption vulnerabilities. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the System ASLR setting on the host.

Expected	**any of the selected values below:**
	☑ Application Opt-In(3)
	☐ Not Configured

	☐ Disabled(4)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	ASLR	

(5.85) 9058 Status of the 'System DEP' setting for 'Application Opt-Out' **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'System DEP' setting determines how applications become enrolled in data execution protection (DEP). If this setting is not specified malicious users might gain access to unmarked pages of application memory as non-executable thereby allowing the ability to run attacker-controlled code. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the System DEP setting on the host.

Expected	**any of the selected values below:**
	☐ Always On(1)
	☑ Application Opt-Out(2)
	☐ Application Opt-In(3)
	☐ Not Configured
	☐ Disabled(4)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	DEP	

(5.86) 9059 Status of the 'System SEHOP' setting for 'Application Opt-Out' **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'System SEHOP' setting determines how applications become enrolled in structured exception handler overwrite protection (SEHOP). If this setting is not specified malicious users might gain access by corrupting these structures in a controlled manner and exploit may be able to execute arbitrary code. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current status of the System SEHOP setting on the host.

Expected	**any of the selected values below:**
	☑ Application Opt-Out(2)
	☐ Application Opt-In(3)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\EMET\SysSettings	SEHOP	

(5.87) 3944 Status of the 'Application: Control Event Log behavior when the log file reaches its maximum size' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Application: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging

requirements for forensic purposes, this setting should be configured according to the needs of the business.

This integer value X indicates the status of the setting Application: Control Event Log behavior when the log file reaches its maximum size using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Application\Retention. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Application	Retention	

(5.88) 7502 Status of the [GPO-based] 'Application: Maximum log size' setting (in KB) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Application Event Log' provides a standardized method for Windows applications, such as services or other system-integrated applications, to log application (for local or remote viewing) of each instance of an application start, stop, or status change. System logging and adequate log storage is essential to auditing/tracking system security events, but this can be difficult to balance. As log files need enough space to retain a useful longitudinal baseline, yet be limited in size, to prevent the output itself from becoming a Denial of Service (DoS) attack (by filling up the disk storage) the permitted log size should be set as appropriate to business needs.

This integer value X indicates the status of the setting Application: Maximum Log Size (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Application\MaxSize.

Expected	**greater than or equal to**
	32768
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Application	MaxSize	

(5.89) 3943 Status of the 'Security: Control Event Log behavior when the log file reaches its maximum size' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Security: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging requirements for forensic purposes, this setting should be configured according to the needs of the business.

This integer value X indicates the status of the setting Security: Control Event Log behavior when the log file reaches its maximum size using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Security\Retention. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Security	Retention	

(5.90) 7503 Status of the [GPO-based] 'Security: Maximum log size' setting (in KB) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The GPO-based 'Security Log' provides information on security events, such as login and privilege use. As these files can become DoS triggers if allowed to grow continuously, but still need to be large enough to retain a useful amount of data for performing a forensic investigations, the value restricting Security Log size should be set as appropriate to the needs of the organization.

This integer value X indicates the status of the setting Security: Maximum Log Size (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\Security\MaxSize.

Expected	**greater than or equal to**
	196608
	OR, any of the selected values below:
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Security	MaxSize	

(5.91) 9013 Status of the 'Setup: Control Event Log behavior when the log file reaches its maximum size' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

This policy setting specifies Event Log behavior when the log file reaches its maximum size. If enabled this policy setting and a log file reaches its maximum size, new events are not written to the log and are lost. When events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current value of the Setup: Retain old events setting on the host.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Setup	Retention	

(5.92) 9014 Status of the 'Setup: Maximum Log Size (KB)' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Setup: Maximum Log Size (KB)' setting specifies the maximum size of the log file in kilobytes. If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.This setting should be restricted according to the needs of the business.

This integer value of X indicates the current value of the Maximum Log Size setting on the host.

Expected **greater than or equal to**

32768

OR, any of the selected values below:

☐ Key Not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key Not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\Setup	MaxSize	

(5.93) 3942 Status of the 'System: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'System: Control Event Log behavior when the log file reaches its maximum size' Group Policy setting stops logging events when a maximum file size limit is reached. As this setting may conflict with established continuous logging requirements for forensic purposes, this setting should be configured according to the needs of the business.

This integer value X indicates the status of the setting System: Control Event Log behavior when the log file reaches its maximum size using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\System\Retention. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **equal to**

Disabled (0)

OR, any of the selected values below:

☑ Disabled(0)

☐ Enabled(1)

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\EventLog\System	Retention	

(5.94) 7504 Status of the [GPO-based] 'System: Maximum log size' setting (in KB) — Failed — CRITICAL

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The GPO-based 'System Event Log' provides information on [operating] system events, such as OS segment startup events, such as the 'Routing/Remote Access' service and the associated events that occur during process initialization. By setting the 'Max System Event Log Size' guidelines to an appropriate value, this can prevent the log file from becoming a DoS trigger (if it were allowed to grow unchecked), but still be of sufficient size to retain a useful amount of data for doing a forensic investigation.

This integer value X indicates the status of the setting System: Maximum Log Size (KB) using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\EventLog\System\MaxSize.

Expected **greater than or equal to**

32768

OR, any of the selected values below:

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value

HKLM\Software\Policies\Microsoft\Windows\ EventLog\System	MaxSize	

(5.95) 8274 Status of the 'Configure Windows SmartScreen Option: Pick one of the following setting' policy setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Pick one of the following settings' policy setting allows you to manage the behavior of Windows SmartScreen. Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. If this setting is enabled windows smartscreen behavior will be controlled using options such as "Require approval from an administrator before running downloaded unknown software", "Give user a warning before running downloaded unknown software". If this setting is disabled or not configured, Windows SmartScreen behavior is managed by administrators on the PC by using Windows SmartScreen Settings in Action Center. Windows SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet.This should be set as appropriate to the needs of the business.

This integer value X indicates the status of the setting Pick one of the following settings using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\System\EnableSmartScreen. A value of 0 indicates the setting is set to Turn off SmartScreen, a value of 1 indicates the setting is set to Give user a warning before running downloaded unknown software, a value of 2 indicates the setting is set to Require approval from an administrator before running downloaded unknown software.

Expected **any of the selected values below:**

- ☐ Turn off SmartScreen(0)
- ☐ Give user a warning before running downloaded unknown software(1)
- ☑ Require approval from an administrator before running downloaded unknown software(2)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ System	EnableSmartScreen	

(5.96) 8273 Status of the 'Turn off Data Execution Prevention for Explorer' policy setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off Data Execution Prevention for Explorer' policy setting can allow certain legacy plug-in applications to function without terminating Window Explorer. As permitting Explorer to continue functioning during the operation of these applications can permit the introduction of malware into Explorer, this capability should be set according to the need of the business.

This integer value X indicates the status of the setting Turn off Data Execution Prevention for Explorer using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\Explorer\NoDataExecutionPrevention. A value of 0 indicates the setting is Disabled, a value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Explorer	NoDataExecutionPrevention	

(5.97) 2621 Status of the 'Turn off heap termination on corruption' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off heap termination on corruption' setting determines whether or not the system will fail an application if the

heap becomes corrupted. (When this permitted, applications continue to run even when the heap is corrupted and this is occasionally necessary for troubleshooting.) As this capability to corrupt the Heap may allow a malicious user to compromise a vulnerable system it should be restricted as appropriate to the needs of the business.

This Integer value X indicates the current status of the Turn off heap termination on corruption setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled. A value of 0 indicates the setting is Disabled, a value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Explorer	NoHeapTerminationOnCorruption	

(5.98) 2619 Status of the 'Turn off shell protocol protected mode' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off shell protocol protected mode' setting determines the level of shell protocol functionality. The shell protocol provides system functionality to allow applications to open folders and/or files. When this setting is enabled, the system will allow applications to open folders and launch files. When this setting is disabled or not configured, the shell protocol is set to 'protected mode.' When the shell protocol is set to 'protected mode,' applications are permitted to open only a restricted list of folders and are not permitted to open any files. It is always best practice to turn off any unnecessary services to reduce the overall threat surface. If this function is not required for the systems' operation, it should be disabled to reduce the risk of a malicious user gaining inappropriate access and/or control.

This Integer value X indicates the current status of the Turn off shell protocol protected mode setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Microsoft\Windows\ CurrentVersion\Policies\Explorer	PreXPSP2ShellProtocolBehavior	

(5.99) 8420 Status of the 'Turn off location' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Turn off location' setting turns off the location feature for this computer. If the setting is enabled, the location feature will be turned off and all programs on the computer will not be able to use the location information from this feature. All programs on the computer can use location information from the location feature if this setting is disabled or not configured. This setting need to be configured according to the needs of the business.

This Integer value X indicates the status of the service Turn off location using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\ Windows\LocationAndSensors\DisableLocation. A value of 0 indicates the service is Disabled; a value of 1 indicates the service is set to Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ LocationAndSensors	DisableLocation	

(5.100) 3876 Status of the 'Do not allow passwords to be saved' policy setting (Terminal Services) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not allow password to be saved' policy setting prevents user's of Terminal Services from saving their passwords within the local Client files. As with all credentials used to access critical systems/data, their protection must have primacy in any responsible security program to avoid misuse by malicious users. Best practice dictates that the location in which credentials are maintained should be kept to a minimum to reduce the threat landscape to a manageable level. This check can be run periodically to ensure the requirements and expectations of the business are being met regarding the protections defined by internal policy or regulation(s).

This integer value X indicates the status of the setting Do not allow passwords to be saved using the registry key path HKEY_LOCAL_MACHINE\ SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\DisablePasswordSaving. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	DisablePasswordSaving	

(5.101) 4121 Status of the 'Restrict Terminal Services users to a single remote session' Group Policy setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Restrict Terminal Services users to a single remote session' Group Policy setting restricts users from starting multiple remote sessions with Terminal Server. As this setting can enable multiple remote Terminal services sessions and increase the risk of unauthorized access it should be configured according to the needs of the business.

This Integer value X indicates the current status of the Restrict Terminal Server users to a Single Remote Session policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabed(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fSingleSessionPerUser	

(5.102) 4123 Status of the 'Do not allow COM port redirection' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not allow COM port redirection' Group Policy setting specifies whether or not to allow the redirection of an RDP clients' 'COM port' data into the Terminal Services session. As this capability may allow unauthorized data into the session, risking the launch of a possible session hijacking or privilege escalation exploit, this setting should be restricted according to the needs of the business.

This Integer value X indicates the current status of the Do not allow COM port redirection within a Terminal Server session policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fDisableCcm	

(5.103) 3875 Status of the 'Do not allow drive redirection' setting (Terminal Services) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not allow drive redirection' policy setting is responsible for preventing client drive mapping in Terminal Services sessions. These drives show up in the Windows Explorer folder structure and are recurring when such maps are established. This setting has the ability to stem this action from occurring. As the establishment of invalid drive mappings may be used for nefarious purposes resulting in data leakage, corruption or deletion. Whenever possible to do so on Production systems, this capability should be disabled to reduce the threat landscape to manageable/acceptable levels.

This Integer value X indicates the current status of the Do not allow drive redirection policy. Using registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\fDisableCdm. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disbaled(0)
- ☑ Enabled(1)
- ☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fDisableCdm	

(5.104) 4124 Status of the 'Do not allow LPT port redirection' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not allow LPT port redirection' Group Policy setting specifies whether or not to allow the redirection of an RDP clients' 'LPT port' data into the Terminal Services session. As this capability may allow unauthorized data into the session, risking the launch of a possible session hijacking or privilege escalation exploit, this setting should be restricted according to the needs of the business.

This Integer value X indicates the current status of the Do not allow LPT port redirection policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fDisableLPT	

(5.105) 4125 Status of the 'Do not allow supported Plug and Play redirection' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not allow supported Plug and Play redirection' Group Policy setting specifies whether or not to allow the redirection of a Plug-and-play (PNP) device data exchange into a Terminal Services session. As this capability may allow unauthorized data into the session, risking the launch of a possible session hijacking/privilege escalation exploit, this setting should be restricted according to the needs of the business.

This Integer value X indicates the current status of the Do not allow supported Plug and Play device redirection in a Terminal Services session policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fDisablePNPRedir	

(5.106) 3891 Status of the 'Always prompt for password upon connection' setting (Terminal Services) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

By default, users can store their credentials when establishing shortcuts for Remote Desktop connections which allows them to logon without having to enter a password. This control checks to see if the Terminal Services server will defeat this default capability using this security setting and forcing it down to all systems requesting connections requiring a password to be entered for access. If it is allowed for cached credentials to be stored in shortcuts, a malicious user could exploit the credentials stored in the shortcut and gain access to sensitive systems and data. Run this check periodically to ensure that all security settings meet the needs and requirements of the business.

This integer value X indicates the status of the setting Always prompt for password upon connection using the registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\fPromptForPassword. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fPromptForPassword	

Permission Translation:

M : Read control

(5.107) 4133 Status of the 'Require secure RPC communication' Group Policy setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Require secure RPC communication' Group Policy setting requires that RDP-based RPC traffic have strengthened communications security, by accepting only authenticated/encrypted connection requests. As secure RPC communications can significantly alleviate security risks but may break connections with legacy applications, this capability should be configured according to the needs of the business.

This Integer value X indicates the current status of the Require secure RPC communication policy. A value of 0 indicates the policy is Disabled; a value of 1 indicates the policy is Enabled; a value of RegTopKey not found indicates the policy is Not Configured.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	fEncryptRPCTraffic	

(5.108) 2635 Status of the 'Set Client Connection Encryption Level' setting (Terminal Services) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Set Client Connection Encryption Level' setting determines the level of encryption used to secure Terminal Services (Remote Desktop Protocol) communications between client and server. The policy setting has four possible configurations to determine the level of encryption used to secure data sent between the terminal servers and clients. A policy setting of 'High' secures communications using 128-bit encryption. A policy setting of 'Client Compatible' secures communications using the maximum encryption key length supported by the client. A policy setting of 'Low,' secures communications using 56-bit encryption. When the policy setting is disabled or not configured, data sent between the client and terminal server will not be encrypted. As sensitive and/or confidential information is susceptible to interception by a malicious user, data sent using Terminal Services communications should be secured using an encryption policy appropriate to the needs of the business.

This integer value X indicates the status of the setting Encryption Level using the registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\MinEncryptionLevel. A value of 1 indicates the setting is set to Low, A value of 2 indicates the setting is set to Client Compatible, A value of 3 indicates the setting is set to High.

Expected **equal to**

High (3)

OR, any of the selected values below:

- ☐ Low(1)
- ☐ Client Compatible(2)
- ☑ High(3)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	MinEncryptionLevel	

(5.109) 4137 Status of the 'Set time limit for active but idle Terminal Services sessions (and Idle session limit)' Group Policy setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Windows Group Policy setting 'Set time limit for active but idle Terminal Services sessions (and Idle session limit) allows the limiting of the duration of active and/or idle Terminal Services sessions that are either still active or disconnected. As limiting of the user session time limit may close a user session prematurely, while not limiting sessions may use up excessive system resources, this capability should be restricted according to the needs of the business.

The following Integer value X indicates the current status of the Set time limit for active but idle Terminal Services sessions (and Idle session limit) policy setting defined by the HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\MaxIdleTime registry key value.

Expected **in range**

1- 900000

OR, any of the selected values below:

☑ Enabled (Never)(0)
☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	MaxIdleTime	

(5.110) 4135 Status of the 'Set Time Limit for Disconnected Sessions' Group Policy setting (Terminal Services) **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Set Time Limit for Disconnected Sessions' Group Policy setting limits the duration of idle Terminal Services sessions upon 'user disconnect' (as opposed to user logoff, which closes the session), when a user exits an RDP/Terminal Services session. As limiting the time for disconnected sessions reduces risk of unauthorized access via an open session, this capability should be restricted according to the needs of the business.

This Integer value X indicates the current status of the Set Time Limit for Disconnected Sessions policy. A value of 0 indicates the policy is Enabled (Never); a value big than 10000 indicates the policy is Enabled (Not Never); a value of RegTopKey not found indicates the policy is Not Configured.

Expected **equal to**

60000

OR, any of the selected values below:

☐ Enabled (Never)(0)
☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	MaxDisconnectionTime	

(5.111) 4140 Status of the 'Do not delete temp folder upon exit' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do Not Delete Temp Folder upon Exit' Group Policy setting' determines whether or not Terminal Services will maintain the presence of temporary folders created during a session. As temporary folder creation within a user profile on the Terminal Services server may be maintaining user-critical data, while also providing a potential vector for the installation of malware and/or privilege escalation exploits, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Do Not Delete Temp Folder upon Exit policy. A value of 1 indicates the policy is disabled; a value of 0 indicates the policy is enabled.

Expected **any of the selected values below:**

☐ Enabled(0)
☑ Disabled(1)
☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	DeleteTempDirsOnExit	

(5.112) 4139 Status of the 'Do not use temporary folders per session' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Do not use temporary folders per session' Group Policy setting' determines whether or not Terminal Services may create temporary folders in a session. As temporary folder creation within a user profile on the Terminal Services server may provide a vector for the installation of malware or privilege escalation exploits, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Do not use temporary folders per session policy. A value of 1 indicates the policy is disabled; a value of 0 indicates the policy is enabled.

Expected **any of the selected values below:**

- ☐ Enabled(0)
- ☑ Disabled(1)
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services	PerSessionTempDir	

(5.113) 2612 Status of the 'Turn off downloading of enclosures' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The 'Turn off downloading of enclosures' setting determines whether or not users are permitted to download enclosures (file attachments) from RSS feeds. RSS feeds use what are called, "enclosures" to attach multimedia content to the feed. The actual content is not embedded in the feed, rather, these enclosures consist of a hyperlink to the files associated with the entry. Whenever this policy setting is enabled, users will not be permitted to download such "enclosures" from RSS feeds. Uncontrolled/unmanaged file downloads may contain malicious software such as a viruses or Trojans, therefore, this feature should be disabled as appropriate to the needs of the business.

This Integer value X indicates the current status of the Turn off downloading of enclosures setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ RegSubKey not found
- ☐ Not Configured

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Internet Explorer\Feeds	DisableEnclosureDownload	

(5.114) 4119 Status of the 'Allow indexing of encrypted files' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The Windows Group Policy setting 'Allow indexing of encrypted files' permits the indexing/searching of the contents and/or properties of files that have been encrypted. As this capability might facilitate unauthorized access to confidential materials, it should be configured according to the needs of the business.

This Integer value X indicates the current status of the Allow indexing of encrypted files policy. A value of 0 indicates the policy is disabled; a value of 1 indicates the policy is enabled.

Expected **equal to**

Disabled (0)

OR, any of the selected values below:

- ☑ Disabled(0)
- ☐ Enabled(1)
- ☐ Key not found

Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Windows Search	AllowIndexingEncryptedStoresOrItems	

(5.115) 9442 Status of the 'Set what information is shared in Search' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Set what information is shared in Search' setting allows you to control what information is shared with Bing in Search.This policy allows you to specify one of three settings, which users won't be able to change: User info and location; User info only; Anonymous info. This setting should be configured according to the needs of the business

The Integer value X indicates the status of the setting Set what information is shared in Search using the registry key path HKLM\SOFTWARE\Policies\ Microsoft\Windows\Windows Search\ConnectedSearchPrivacy. A value of 1 indicates the setting is User Info and location; a value of 2 indicates the setting is User info only; a value of 3 indicates the setting is Anonymous info.

Expected	**any of the selected values below:**
	☐ User info and location(1)
	☐ User info only(2)
	☑ Anonymous info(3)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Windows Search	ConnectedSearchPrivacy	

(5.116) 9404 Status of 'Prevent the usage of OneDrive for file storage' setting **Passed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:09 (GMT+0500)

The policy 'Prevent the usage of OneDrive for file storage' setting allows you to prevent apps and features from working with files on OneDrive. If this setting is not configured on the machine, then user will not be enforced to store the work files to the storage solution that is designed for business.This setting should be configured according to the needs of the business.

The Integer value X indicates the status of the setting Prevent the usage of OneDrive for file storage using the registry key path HKLM\Software\ Policies\Microsoft\Windows\Skydrive\DisableFileSync. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☑ Enabled(1)
	☑ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ Skydrive	DisableFileSync	

(5.117) 10016 Status of the 'Turn off KMS Client Online AVS Validation' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy ‘Key Management Service (KMS)’setting is a Microsoft license activation method that entails setting up a loca l server that stores the licenses. The server itself needs to connect to Microsoft to activate the KMS service, but subs equent on-network clients can activate Microsoft Windows OS and/or their Microsoft Office via the KMS server instead of

connecting directly to Microsoft. Preventing this information from being sent can help reduce privacy concerns. This set ting should be configured according to the business needs.

The following Integer value of X indicates the status of the Turn off KMS Client Online AVS Validation setting using registry key path HKLM\Software\Policies\Microsoft\Windows NT\CurrentVersion\Software Protection Platform\NoGenTicket on the host. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows NT\CurrentVersion\Software Protection Platform	NoGenTicket	

(5.118) 8419 Status of the 'Turn off Automatic Download of updates' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Turn off Automatic Download of updates' setting enables or disables the automatic download of updates. If the setting is enabled automatic download of updates is turned off. If the setting is disabled or not configured then automatic download of updates is tuned on. Sometimes it required to prevent automatic update of applications acquired through the Store. This should be configured according to the needs of the business.

This Integer value X indicates the status of the service Turn off Automatic Download of updates using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsStore\AutoDownload. A value of 4 indicates the service is Disabled; a value of 2 indicates the service is set to Enabled.

Expected	**any of the selected values below:**
	☐ Enabled(2)
	☐ Not Configured
	☑ Disabled(4)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsStore	AutoDownload	

(5.119) 9424 Status of 'Turn off the offer to update to the latest version of Windows' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Turn off the offer to update to the latest version of Windows' setting allows you to enables or disables the Store offer to update to the latest version of Windows. If this setting is not configured on the machine, then user get regular prompts for installing Windows update for free which may become annoying to them. This setting should be configured according to the needs of the business.

The Integer value X indicates the status of the setting Configure 'Turn off the offer to update to the latest version of Windows' using the registry key path HKLM\Software\Policies\Microsoft\WindowsStore\DisableOSUpgrade. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value

HKLM\Software\Policies\Microsoft\WindowsStore	DisableOSUpgrade	

(5.120) 8416 Status of the 'Turn off the Store application' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Turn off the Store application' setting denies or allows to the store application. If the setting is enabled access to store application will be denied. If the policy setting is disabled or not configured access to the store application is allowed. store application access can be prevented from users in order to avoid malicious activities. This should be configured according to the needs of the business.

This Integer value X indicates the status of the service Turn off the Store application using registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\WindowsStore\RemoveWindowsStore. A value of 0 indicates the service is Disabled; a value of 1 indicates the service is set to Enabled.

Expected **any of the selected values below:**

- ☐ Disabled(0)
- ☑ Enabled(1)
- ☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\WindowsStore	RemoveWindowsStore	

(5.121) 4141 Status of the 'Configure Microsoft SpyNet Reporting' Group Policy setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Configure Microsoft SpyNet Reporting' Group Policy setting 'Configure Microsoft SpyNet Reporting' automatically joins, connects and reports (based on membership level) to Microsoft's online community 'SkyNet'. As this setting might unintentionally release personal or corporate information to Microsoft, this setting should be configured according to the needs of the business.

This Integer value X indicates the current status of the Computer Configuration\Policies\Administrative Templates\Windows Components\Windows Defender\MAPS\Join Microsoft MAPS policy through the registry key path HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Spynet:SpynetReporting. A value of 0 indicates the policy is Enabled (No Membership); a value of 1 indicates the policy is Enabled (Basic); a value of 2 indicates the policy is Enabled (Advanced).

Expected **any of the selected values below:**

- ☑ Enabled (No Membership)(0)
- ☐ Enabled (Basic)(1)
- ☐ Enabled (Advanced)(2)
- ☐ RegTopKey not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows Defender\SpyNet	SpyNetReporting	

(5.122) 10432 Status of the 'Default consent' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Default Consent' setting determines the default consent behavior of Windows Error Reporting. Windows Error Reporting will allow Windows to send descriptions of the issues/problems/errors on your system to Microsoft and can search for resolutions of the problem/error/issues. Not configuring this setting automatically sends memory dump data to Microsoft, which could disclose confidential information. This setting should be configured according to the business needs.

The Integer value X indicate the status of the setting Default consent using the registry key path HKLM\SOFTWARE\Policies\Microsoft\Windows\Windows Error Reporting\Consent\DefaultConsent.

Expected **any of the selected values below:**

	☑ Always ask before sending data(1) ☐ Send parameters(2) ☐ Send parameters and safe additional data(3) ☐ Not Configured ☐ Send all data(4)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Windows Error Reporting\Consent	DefaultConsent	

(5.123) 10513 Status of the 'Automatically send memory dumps for OS-generated error reports' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Automatically send memory dumps for OS-generated error reports' policy setting is used to control whether memory dumps in support of OS-generated error reports can be sent to Microsoft automatically. This policy does not apply to error reports generated by 3rd-party products, or additional data other than memory dumps. Memory dumps may contain sensitive information and should not be automatically sent to anyone. The setting should be configured according to the needs of the business.

The Integer value of X indicates the status of the setting Automatically send memory dumps for OS-generated error reports on the host.

Expected	**any of the selected values below:**
	☑ Disabled(0) ☐ Enabled(1) ☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Wow6432Node\Policies\ Microsoft\Windows\Windows Error Reporting	AutoApproveOSDumps	

(5.124) 2618 Status of the 'Enable user control over installs' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Enable user control over installs' setting determines whether or not the system permits a user to modify the installation options of Windows Installer. The Windows Installer contains default security features that prevent users from modifying installation options such as the installation directory. When this setting is enabled, users are permitted to modify the installation options of Windows Installer. The ability to modify these options is typically restricted to system administrators. As enabling this setting bypasses several of the default security features of Windows Installer, this functionality should be restricted/disabled as appropriate to the needs of the business.

This Integer value X indicates the current status of the Enable user control over installs setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0) ☐ Enabled(1) ☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ Installer	EnableUserControl	

(5.125) 8198 Status of the 'Windows Installer: Set Always install with elevated privileges' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The Windows Installer: Set Always install with elevated privileges setting can require the use of elevated privileges for the installation of any program on the system. As without elevated privileges, program installation applies the current user's permissions during program installation, this value should be set according to the needs of the business.

This integer value X indicates the status of the setting Always install with elevated privileges using the registry key path HKLM\Software\Policies\Microsoft\Windows\Installer\AlwaysInstallElevated. A value of 0 indicates the setting is Disabled; a value of 1 indicates the setting is Enabled.

Expected	**equal to**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\Installer	AlwaysInstallElevated	

(5.126) 2614 Status of the 'Disable IE security prompt for Windows Installer scripts' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Disable IE security prompt for Windows Installer scripts' setting determines whether or not the user is notified when a Internet based application attempts to install software on the local machine. When this setting is disabled, the user is prompted to allow or deny permission for the Internet browser to install software on the local machine. When this setting is enabled, the user permission prompt is suppressed and software installation is permitted by the system. If this function is not required for the system' operation, it should be disabled as appropriate to the needs of the business in order to reduce the risk of a malicious user gaining inappropriate access and/or control. NOTE: Enabling this feature may be appropriate for enterprises that distribute programs to their employees via Web-based tools.

This Integer value X indicates the current status of the Disable IE security prompt for Windows Installer scripts setting. A value of 0 indicates the setting is disabled; a value of 1 indicates the setting is enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ RegSubKey not found
	☐ RegTopKey not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	RegTopKey not found

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer	SafeForScripting	

(5.127) 9015 Status of the 'Sign-in last interactive user automatically after a system-initiated restart' setting **Passed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Sign-in last interactive user automatically after a system-initiated restart' setting specifies if the device will automatically sign-in the last interactive user after Windows Update restarts the system. If the setting is not specified malicious users can gain access and can be able to compromise the system. This setting should be restricted according to the needs of the business.

This integer value of X indicates the current setting of the Sign-in last interactive user automatically after a system-initiated restart setting on the host.

Expected	any of the selected values below:
	☐ Enabled(0)
	☑ Disabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Disabled (1)

Extended Evidence:

Key	Name	Value
HKLM\Software\Microsoft\Windows\ CurrentVersion\Policies\System	DisableAutomaticRestartSignOn	1

(5.128) 10027 Status of the 'Turn on PowerShell Script Block Logging' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'PowerShell Script Block Logging' allow you to enables logging of all PowerShell script which is input to the Microsoft-Windows-PowerShell/Operational event log. If this setting is not configured, then potential risks of capturing passwords in the logs may emerge. This setting should only be used for debugging purposes, not in normal operation and configured according to the business needs.

The following integer value of X indicates the status of the Turn on PowerShell Script Block Logging setting using registry key path HKLM\Software\ Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging\ScriptBlockLogging\EnableScriptBlockLogging on the host.

Expected	any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ PowerShell\ScriptBlockLogging	EnableScriptBlockLogging	

(5.129) 10028 Status of the 'Turn on PowerShell Transcription' setting **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy ‘PowerShell Transcription’ setting allows you to capture the input and output of Windows PowerShell commands into text-based transcripts. If this setting is not configured, there is a risk that passwords could get stored in plain text in the PowerShell_transcript output file which may cause unauthorized access. This setting should be set according to the business needs.

The following integer value of X indicates the status of the Turn on PowerShell Transcription setting using registry key path HKLM\Software\Policies\ Microsoft\Windows\PowerShell\Transcription\EnableTranscripting on the host.

Expected	any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Not Configured
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Not Configured

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ PowerShell\Transcription	EnableTranscripting	

(5.130) 8249 Status of the 'Allow Basic authentication' setting (WinRM client) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Allow Basic authentication' policy setting allows you to manage whether the Windows Remote Management (WinRM) client uses Basic authentication. If this policy setting is enabled, the WinRM client will use Basic authentication. If the setting is disabled/not configured then the WinRM client will not use Basic authentication. If this setting set as "HTTP transport" then the username/password are sent over the network as clear text. Basic authentication is less powerful then other authentication methods, its because login credentials including passwords are transmitted in plain text. An attacker who is able to access the packets over the network can easily have the access to the credentials that are used for accessing remote hots via winRM. This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Allow Basic authentication using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowBasic. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\WinRM\Client	AllowBasic	

(5.131) 8253 Status of the 'Allow unencrypted traffic' setting (WinRM client) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Allow unencrypted traffic' policy setting allows you to manage whether the Windows Remote Management (WinRM) client sends and receives unencrypted messages over the network. If this policy setting is enabled the WinRM client sends and receives unencrypted messages over the network. If this is disabled/not configured the WinRM client sends or receives only encrypted messages over the network. Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network. This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Allow unencrypted traffic using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowUnencryptedTraffic. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\WinRM\Client	AllowUnencryptedTraffic	

(5.132) 8248 Status of the 'Disallow Digest authentication' setting (WinRM client) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Disallow Digest authentication' policy setting allows you to manage whether the Windows Remote Management (WinRM) client will not use Digest authentication. If this policy is enabled, the WinRM client will not use Digest authentication. If the policy setting is disabled/not configured, the WinRM client will use Digest authentication. Digest authentication is less robust than other authentication methods available in WinRM, If an attacker get the access over the network where WinRM is running may be able to get the credentials used for the access via WinRM. This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Disallow Digest authentication using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Client\AllowDigest. A value of 0 indicates the setting is Enabled, A value of 1 indicates the setting is Disabled.

Expected	**any of the selected values below:**
	☑ Enabled(0)
	☐ Disabled(1)

☐ Key not found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WinRM\Client	AllowDigest	

(5.133) 8250 Status of the 'Allow Basic authentication' setting (WinRM service) **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Allow Basic authentication' policy setting allows you to manage whether the Windows Remote Management (WinRM) service accepts Basic authentication from a remote client. If this policy setting is enabled, the WinRM service will accept Basic authentication from a remote client. If the setting is disabled or not configured, the WinRM service will not accept Basic authentication from a remote client. Basic authentication is less powerful then other authentication methods, its because login credentials including passwords are transmitted in plain text. An attacker can easily get the credentials that are used to access remote hosts via WinRM. A This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Allow Basic authentication using the registry key path HKEY_LOCAL_MACHINE\Software\ Policies\Microsoft\Windows\WinRM\Service\AllowBasic. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

☑ Disabled(0)
☐ Enabled(1)
☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WinRM\Service	AllowBasic	

(5.134) 8252 Status of the 'Allow unencrypted traffic' setting (WinRM service) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Allow unencrypted traffic' policy setting allows you to manage whether the Windows Remote Management (WinRM) service sends and receives unencrypted messages over the network. If the setting is enabled WinRM client sends and receives unencrypted messages over the network. If this setting is disabled WinRM client sends or receives only encrypted messages over the network. Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network. This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Allow unencrypted traffic using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\ Microsoft\Windows\WinRM\Service\AllowUnencryptedTraffic. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected **any of the selected values below:**

☑ Disabled(0)
☐ Enabled(1)
☐ Key not Found

Actual **Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**

Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WinRM\Service	AllowUnencryptedTraffic	

(5.135) 8251 Status of the 'Disallow WinRM from storing RunAs credentials' setting (WinRM service) **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Disallow WinRM from storing RunAs credentials' policy setting allows you to manage whether the Windows Remote Management (WinRM) service will not allow RunAs credentials to be stored for any plug-ins. If the setting is enabled the WinRM service will not allow the RunAsUser or RunAsPassword configuration values to be set for any plug-ins. If the settings is disabled or do not configured, the WinRM service will allow the RunAsUser and RunAsPassword configuration values to be set for plug-ins and the RunAsPassword value will be stored securely. Although the ability to store RunAs credentials is a convenient feature it increases the risk of account compromise slightly. A This setting should be set as per the need of the business.

This integer value X indicates the status of the setting Disallow WinRM from storing RunAs credentials using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WinRM\Service\DisableRunAs. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**any of the selected values below:**
	☐ Disabled(0)
	☑ Enbaled(1)
	☐ Key not Found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not Found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WinRM\Service	DisableRunAs	

(5.136) 5268 Status of the 'Allow remote shell access' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

Remote Shells allows users to run commands on another system across network connections. By managing the access users have to this capability, the risk of malicious code introduction onto the system, as well as other activities that could cause damage to the functionality of the system, is greatly reduced. This check can be used to ensure critical and/or systems with sensitive/protected data are in compliance with organizational security and standards and expectations. NOTE: It is important to keep all patches up to date as Microsoft has indicated that the Windows Shell was known to have weaknesses that allowed remote code execution if updates are not applied to protect against it.

The following List Integer value(s) X indicate the current status of the Windows Remote Shell - Allow Remote Shell Access setting defined within the HKLM\Software\Policies\Microsoft\Windows\WinRM\Service\WinRS\AllowRemoteShellAccess registry key.

Expected	**any of the selected values below:**
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Key not found

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WinRM\Service\WinRS	AllowRemoteShellAccess	

(5.137) 7805 Status of Windows 'Automatic Updates' (WSUS) setting (NoAutoUpdate) **Passed** **URGENT**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The Windows 'Automatic Updates' (WSUS) setting configures how Automatic Updates are applied to the Windows system. The 'NoAutoUpdate' sub-setting determines whether to enable or disable automatic updates and compliments other related settings which manage updates. If automatic update to systems is not enabled, it would mean that the systems do not always have the most recent critical operating system updates and service packs installed. System updated and service packs have fixes against known or published vulnerabilities. To ensure that systems are protected against exploitation and compromise due to known vulnerabilities on a regular basis, this setting should be set as per the need of the organization.

This integer value X indicates the status of the setting Configure Automatic Updates using the configurtaion path HKEY_LOCAL_MACHINE\Software\ Policies\Microsoft\Windows\WindowsUpdate\AU\NoAutoUpdate. A value of 0 indicates the setting is Enabled, A value of 1 indicates the setting is Disabled.

Expected	**equal to**

	Enabled (0)
	OR, any of the selected values below:
	☐ Disabled(1)
	☑ Enabled(0)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (0)

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WindowsUpdate\AU	NoAutoUpdate	0

(5.138) 8272 Status of the 'Configure Automatic Updates Option: Scheduled install day' policy setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Scheduled install day' policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If this setting is enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them. If this setting is disabled, Windows updates will need to be download and install manually if available. Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. This should be set as appropriate to the needs of the business.

This integer value X indicates the status of the setting Scheduled install day using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\ Microsoft\Windows\WindowsUpdate\AU\ScheduledInstallDay. A value of 0 indicates the setting is set to Every day, a value of 1 indicates the setting is set to Every Sunday, a value of 2 indicates the setting is set to Every Monday, a value of 3 indicates the setting is set to Every Tuesday, a value of 4 indicates the setting is set to Every Wednesday, a value of 5 indicates the setting is set to Every Thursday, a value of 6 indicates the setting is set to Every Friday, a value of 7 indicates the setting is set to Every Saturday.

Expected	**equal to**
	Every day (0)
	OR, any of the selected values below:
	☑ Every day(0)
	☐ Every Sunday(1)
	☐ Every Monday(2)
	☐ Every Tuesday(3)
	☐ Every Wednesday(4)
	☐ Every Thursday(5)
	☐ Every Friday(6)
	☐ Every Saturday(7)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Every Friday (6)

Extended Evidence:

Key	Name	Value
HKLM\Software\Policies\Microsoft\Windows\ WindowsUpdate\AU	ScheduledInstallDay	6

(5.139) 5263 Status of the 'No auto-restart with logged on users for scheduled automatic updates' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'No auto-restart with logged on users for scheduled automatic updates' setting, when enabled, disallows the automatic reboot on systems that have been updated via the Automatic Updates capability, while users are logged on. Unplanned and/or unexpected reboots can be an inconvenience to users and result in the reduction of productivity or timely completion of work. This setting can help avoid that by waiting until all users are logged off before rebooting to apply updates.

This List integer value(s) X indicate the status of the setting No auto-restart with logged on users for scheduled automatic updates installations using the registry key path HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows\WindowsUpdate\AU\NoAutoRebootWithLoggedOnUsers. A value of 0 indicates the setting is Disabled, A value of 1 indicates the setting is Enabled.

Expected	**matches list**
	Disabled (0)
	OR, any of the selected values below:
	☑ Disabled(0)
	☐ Enabled(1)
	☐ Key not found
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	Enabled (1)

Extended Evidence:

Key	Name	Value
HKLM\SOFTWARE\Policies\Microsoft\Windows\ WindowsUpdate\AU	NoAutoRebootWithLoggedOnUsers	1

6. Administrative Templates (User)

(6.1) 9302 Status of "Enable screen saver" configuration for Windows users **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Screen Saver' Group Policy setting provides Hide screen saver, No screen saver, Specify a screen saver, and password protect options for screen saver modes. As there are exploits that allow a screensaver to be replaced by a command prompt with system-level access privileges before the user logs on, this capability should be set in accordance with the needs of the business.

This List String value(s) of X indicate the value of registry ScreenSaveActive for logging/logged on users Or users containing Administrator name. A value of 1 indicates the status as Enabled; a value of 0 indicates the status as Disabled.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.2) 9301 Status of the 'Force specific screen saver:Screen saver executable name' Setting [Windows users] **Passed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Force specific screen saver:Screen saver executable name' setting permits specific screen saver instances to run and allow users to change screen saver options. Screen savers can be used to as a security feature when they are set to lock upon initialization and require a password for access to be restored. Depending on the internal requirements and expectations for 'idle-time' thresholds, this should be set as appropriate to the needs of the business

This List String value(s) of X indicate the value of registry scrnsave.exe for logging/logged on users Or users containing Administrator name.

Expected	**matches regular expression list**
	.*:(?!161803399999999)
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.3) 9303 Status of "Password protect the screen saver" setting for Windows users **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Password protect the screen saver' Group Policy setting ensures the screen saver locks requiring a password after a period of time. As there are exploits that allow an unprotected screensaver to be replaced by a command prompt with system-level access privileges before the user logs on, this capability should be set in accordance with the needs of the business.

This List String value(s) of X indicate the value of registry ScreenSaverIsSecure for logging/logged on users Or users containing Administrator name. A value of 1 indicates the status as Enabled; a value of 0 indicates the status as Disabled.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.4) 9297 Status of the "Screen saver timeout" [ScreenSaveTimeOut] setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Screen Saver timeout' Group Policy setting determines how long the system's screen or I/O devices will be remain visible/accessible to the user or passers-by after the last input keystroke/mouse-click has been made. As allowing potentially unfettered access to visible data or I/O capabilities on the system can allow unauthorized data access, this value should be set according to the needs of the business.

This List String value(s) of X indicate the value of registry ScreenSaveTimeOut for logging/logged on users Or users containing Administrator name.

Expected	**matches regular expression list**
	.*:([0-9]|[1-9][0-9]|[1-8][0-9][0-9]|900)$
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.5) 9842 Status of the 'Turn off toast notifications on the lock screen' setting **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Turn off toast notifications on the lock screen' setting turns off toast notifications on the lock screen. If the setting is enabled, applications will not be able to raise toast notifications on the lock screen, If the setting is disabled or not configured toast notifications on the lock screen are enabled and can be turned off by admin user or local user. No reboots or service restarts are required for this policy setting to take effect. Though the feature is very handy for users, applications that provide toast notifications might display sensitive personal or business data while the device is unattended. This should be configured according to the needs of the business.

The List String value/s of X indicates the status of the service Turn off toast notifications on the lock screen using registry key path HKEY_USERS\SOFTWARE\Policies\Microsoft\Windows\CurrentVersion\PushNotifications\NoToastApplicationNotificationOnLockScreen. A value of username:0 indicates the service is Disabled for the user; a value of username:1 indicates the service is Enabled for the user.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.6) 9827 Status of the 'Turn off Help Experience Improvement Program' setting per user basis **Failed** **SERIOUS**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Turn off Help Experience Improvement Program' setting specifies whether users can participate in the Help Experience Improvement program and can help Microsoft to improve the quality and relevance of their Help experience. The Help Experience Improvement program collects information about how customers use words and phrases into the Windows Help Search box. As this capability may allow the release of proprietary information to Microsoft, it should be configured according to the needs of the business.

The List String value/s X indicates the status of the Turn off Help Experience Improvement Program setting. A value of username:1 indicates the setting is enabled for the user; a value of username:0 indicates the setting is disabled for the user.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.7) 9304 Status of the "Do not preserve zone information in file attachments" setting for Windows users **Failed** **SERIOUS**

The 'Do not preserve zone information in file attachments' Group Policy setting restricts the display of network information in file attachments. As this setting can either reveal or restrict private network information that may be used for exploits, this setting should be configured according to the needs of the business.

This List String value(s) of X indicate the value of registry SaveZoneInformation for logging/logged on users Or users containing Administrator name. A value of 1 indicates the status as Enabled; a value of 2 indicates the status as Disabled.

Expected	**matches regular expression list**
	.*:2
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.8) 9305 Status of the "Notify antivirus programs when opening attachments" configuration [For Windows user] **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Notify antivirus programs when opening attachments' setting configures the sequence for the system to determine file attachment risk. As this capability can interrupt the proper functioning of specific anti-virus software, it should be configured according to the needs of the business

This List String value(s) of X indicate the value of registry ScanWithAntiVirus for logging/logged on users Or users containing Administrator name. A value of 3 indicates the status as Enabled; a value of 1 indicates the status as Disabled.

Expected	**matches regular expression list**
	.*:3
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.9) 9830 Status of the 'Prevent users from sharing files within their profile' setting **Failed** **MEDIUM**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The 'Prevent users from sharing files within their profile' setting enables or disables file sharing among users. As this setting could facilitate the unauthorized sharing of confidential information, it should be configured according to the needs of the business

The List String value/s X indicates the status of the setting Prevent users from sharing files within their profile using the registry key path HKEY_USERS\SID\Software\Microsoft\Windows\CurrentVersion\Policies\Explorer\NoInplaceSharing. A value of username:1 indicates the setting is enabled for the user; a value of username:0 indicates the setting is disabled for the user.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.10) 10089 Status of the 'Always install with elevated privileges' setting for Windows User **Failed** **CRITICAL**

Evaluation date: 03/21/2017 at 17:09:10 (GMT+0500)

The policy 'Always install with elevated privileges' setting can require the use of elevated privileges for the installation of any program on the system. As without elevated privileges, program installation applies the current user's permissions during program installation, this value should be set according to the needs of the business.

The List String value of X indicates the status of the Always install with elevated privileges setting using registry key path HKEY_USERS\SID\Software\Policies\Microsoft\Windows\Installer\AlwaysInstallElevated on the host.

Expected	**matches regular expression list**
	.*:0
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

(6.11) 9836 Status of the 'Prevent Codec Download' setting **Failed** **MEDIUM**

The policy 'Prevent Codec Download' setting allows you to prevent Windows Media Player from downloading codecs. If this setting is not configured, automatic downloading of codecs may occurs, which cause malicious code to be installed on the system. This setting should be configured according to the business needs.

The List String value/s X indicates the status of the setting Prevent Codec Download using the registry key path HKEY_USERS\SID\Software\Policies\Microsoft\WindowsMediaPlayer\PreventCodecDownload. A value of username:1 indicates the setting is enabled for the user.

Expected	**matches regular expression list**
	.*:1
Actual	**Last Updated:03/21/2017 at 17:02:53 (GMT+0500)**
	S-HRT-P786-RM1\adc.admin:Setting not found

Appendix

Report Template

Policy Report Template

Template Settings

Trend Duration:	Last 30 days
Group By:	Hosts
Status:	Passed, Failed and Error
Criticality:	UNDEFINED, MINIMAL, MEDIUM, SERIOUS, CRITICAL, URGENT
Control Statistics:	No
Host Statistics:	Yes
Show Report details:	Yes
Show control rationale:	Yes
Show hosts summary:	Yes
Show control evidence:	Yes
Show extended evidence (if applicable):	Yes
Show control exceptions:	Yes
Show exception history:	Yes
Show control glossary:	No
Show Appendix:	Yes
Frameworks selected:	All

CONFIDENTIAL AND PROPRIETARY INFORMATION.
Qualys provides the QualysGuard Service "As Is," without any warranty of any kind. Qualys makes no warranty that the information contained in this report is complete or error-free. Copyright 2017, Qualys, Inc.